



The attached document has been archived and is provided solely for historical purposes.

It may have been superseded by another document (indicated below).

Archived Document

Title:	X.509 Certificate Policy for the U.S. Federal Common Policy Framework Version 2.9
Publication Date:	October 25, 2024
Archive Date:	February 14, 2025
Archive Notes:	This document has been superseded.

Superseding Document

Title:	X.509 Certificate Policy for the U.S. Federal Common Policy Framework Version 2.10
Publication Date:	October 25, 2024
URL:	Current Version: https://www.idmanagement.gov/docs/fpki-x509-cert-policy-common.pdf

Additional Information

Contact:	fpki@gsa.gov
-----------------	--



**X.509 Certificate Policy
for the
U.S. Federal PKI
Common Policy Framework**

Version 2.9

October 25, 2024

Signature Page

BALDRIDGE.TIM
.W.1455368100



Digitally signed by
BALDRIDGE.TIM.W.1455368100
Date: 2024.11.13 10:45:17 -06'00'

Co-chair, Federal Public Key Infrastructure Policy Authority

MATTHEW
ARNOLD



Digitally signed by MATTHEW
ARNOLD
Date: 2024.11.13 12:58:05 -05'00'

Co-chair, Federal Public Key Infrastructure Policy Authority

Recent Revision History

(See [Appendix E](#) for Full Revision History)

Document Version	Document Date	Revision Details
2.2	December 1, 2021	2020-02: Updates to Section 5.4 and Section 5.5 to clarify the purpose of audit and archive, align recorded events and clarify archive retention periods. Updated reference links included. Implementation date is November 1, 2022. 2020-03: Removes the prohibition on container technology and generalizes terminology. Effective as of December 1, 2021.
2.3	September 9, 2022	2022-01A: Update to Section 5.5.2 to provide specificity for archive record retention periods, assisting RAs, or other archiving elements, to understand what artifacts need to be archived, and for how long in certain scenarios. Implementation date is November 1, 2022.
2.4	April 17, 2023	2023-02: Incorporates changes to multiple sections based on the comments received by the CPWG to include certificate suspension requirements, 3rd party key recovery request handling, public key parameters, key generation specifics, and remote workstation definition. Changes effective as of September 1, 2023.
2.5	July 6, 2023	2023-04: Clarifies the audit and archive requirements for assignment of Trusted Roles. Additionally, removes obsolete references. Change effective immediately.
2.6	November 3, 2023	2023-06: Clarify the requirements around certificate modifications, define requirements for certificate restoration, align audit and archive terminology for

		certificate status changes, and generalize two document references. Change effective immediately.
2.7	February 2, 2024	2024-02: Clarify the definition of a “remote workstation used to administer the CA” in order to accommodate current secure practices. 2024-03: Clarify policy language based on the 2023 FPKI annual compliance audit, specifically regarding interoperation with CAs issuing under different policies and the time to process revocation requests. Change effective immediately.
2.8	May 8, 2024	2024-05: Clarify the definition of a “remote workstation used to administer the CA” in order to more clearly delineate parity with CA security controls. Change effective immediately.
2.9	October 25, 2024	2024-06: Add requirements around role-based certificates that can be used to support delegated digital signatures that convey the authority of a given role to specific delegates. 2024-07: Clarify the description of the trusted agent role to ensure that it is not confused with a standard trusted role. Additionally, clarify seemingly conflicting policy language regarding Key Recovery Officials (KROs) and Third Party Key Recovery Requestors to include their responsibilities. 2024-08: Clarify the key storage requirements for Third-Party recovery of PIV key management keys that were originally issued to subscribers asserting common-hardware policies. Additionally,

		clarify requirements for securely recording private key activation data. Change effective immediately.
--	--	--

Table of Contents

1. Introduction	15
1.1. Overview	16
1.1.1. Certificate Policy (CP)	16
1.1.2. Relationship between the CP and the CPS	16
1.1.3. Scope	16
1.1.4. Interoperation with CAs Issuing under Different Policies	17
1.2. Document Name and Identification	17
1.3. PKI Participants	21
1.3.1. PKI Authorities	21
1.3.1.1. Federal Chief Information Officers Council	21
1.3.1.2. Federal PKI Policy Authority (FPKIPA)	21
1.3.1.3. FPKI Management Authority (FPKIMA)	21
1.3.1.4. FPKI Management Authority Program Manager	21
1.3.1.5. Policy Management Authority (PMA)	21
1.3.2. Certification Authorities	22
1.3.3. Registration Authorities	22
1.3.4. Key Recovery Authorities	23
1.3.4.1. Key Escrow Database	23
1.3.4.2. Data Decryption Server	23
1.3.4.3. Key Recovery Agent	23
1.3.4.4. Key Recovery Official	23
1.3.5. Key Recovery Requestors	24
1.3.5.1. Internal Third-Party Requestor	24
1.3.5.2. External Third-Party Requestor	24
1.3.6. Subscribers	24
1.3.7. Relying Parties	25
1.3.8. Other Participants	25
1.4. Certificate Usage	26
1.4.1. Appropriate Certificate Uses	26
1.4.2. Prohibited Certificate Uses	26
1.5. Policy Administration	26
1.5.1. Organization Administering the Document	26

1.5.2.	Contact Person	26
1.5.3.	Person Determining CPS Suitability for the Policy	26
1.5.4.	CPS Approval Procedures	27
1.6.	Definitions and Acronyms	27
2.	Publication and Repository Responsibilities	27
2.1.	Repositories	27
2.2.	Publication of Certification Information	27
2.2.1.	Publication of Certificates and Certificate Status	27
2.2.2.	Publication of CA Information	28
2.3.	Time or Frequency of Publication	28
2.4.	Access Controls on Repositories	28
3.	Identification and Authentication	29
3.1.	Naming	29
3.1.1.	Types of Names	29
3.1.1.1.	Subject Names	29
3.1.1.2.	Subject Alternative Names	31
3.1.2.	Need for Names to Be Meaningful	33
3.1.3.	Anonymity or Pseudonymity of Subscribers	33
3.1.4.	Rules for Interpreting Various Name Forms	33
3.1.5.	Uniqueness of Names	33
3.1.6.	Recognition, Authentication, and Role of Trademarks	34
3.2.	Initial Identity Validation	34
3.2.1.	Method to Prove Possession of Private Key	34
3.2.2.	Authentication of Organization Identity	34
3.2.3.	Authentication of Individual Identity	34
3.2.3.1.	Authentication of Human Subscribers	34
3.2.3.2.	Authentication of Devices	38
3.2.3.3.	Authentication for Role-Based Certificates	38
3.2.4.	Non-verified Subscriber Information	39
3.2.5.	Validation of Authority	39
3.2.6.	Criteria for Interoperation	39
3.3.	Identification and Authentication for Re-Key Requests	39
3.3.1.	Identification and Authentication for Routine Re-key	39
3.3.2.	Identification and Authentication for Re-key after Revocation	40

3.4.	Identification and Authentication for Revocation Request	40
3.5.	Identification and Authentication for Key Recovery Requests	40
3.5.1.	Third-Party Requestor Authentication	40
3.5.2.	Subscriber Authentication	41
3.5.3.	KRA Authentication	41
3.5.4.	KRO Authentication	41
3.5.5.	Data Decryption Server Authentication	41
4.	Certificate Life-Cycle Operational Requirements	42
4.1.	Certificate Application	42
4.1.1.	Who Can Submit a Certificate Application	42
4.1.2.	Enrollment Process and Responsibilities	42
4.2.	Certificate Application Processing	42
4.2.1.	Performing Identification and Authentication Functions	43
4.2.2.	Approval or Rejection of Certificate Applications	43
4.2.3.	Time to Process Certificate Applications	43
4.3.	Certificate Issuance	43
4.3.1.	CA Actions During Certificate Issuance	43
4.3.2.	Notification to Subscriber by the CA of Issuance of Certificate	43
4.4.	Certificate Acceptance	44
4.4.1.	Conduct Constituting Certificate Acceptance	44
4.4.2.	Publication of the Certificate by the CA	44
4.4.3.	Notification of Certificate Issuance by the CA to Other Entities	44
4.5.	Key Pair and Certificate Usage	44
4.5.1.	Subscriber Private Key and Certificate Usage	44
4.5.2.	Relying Party Public key and Certificate Usage	44
4.6.	Certificate Renewal	44
4.6.1.	Circumstance for Certificate Renewal	45
4.6.2.	Who May Request Renewal	45
4.6.3.	Processing Certificate Renewal Requests	45
4.6.4.	Notification of New Certificate Issuance to Subscriber	45
4.6.5.	Conduct Constituting Acceptance of a Renewal Certificate	45
4.6.6.	Publication of the Renewal Certificate by the CA	45
4.6.7.	Notification of Certificate Issuance by the CA to Other Entities	45
4.7.	Certificate Re-key	46

4.7.1.	Circumstance for Certificate Re-key	46
4.7.2.	Who May Request Certification of a New Public Key	46
4.7.3.	Processing Certificate Re-keying Requests	46
4.7.4.	Notification of New Certificate Issuance to Subscriber	46
4.7.5.	Conduct Constituting Acceptance of a Re-keyed Certificate	46
4.7.6.	Publication of the Re-keyed Certificate by the CA	46
4.7.7.	Notification of Certificate Issuance by the CA to Other Entities	47
4.8.	Certificate Modification	47
4.8.1.	Circumstance for Certificate Modification	47
4.8.2.	Who May Request Certificate Modification	47
4.8.3.	Processing Certificate Modification Requests	47
4.8.4.	Notification of New Certificate Issuance to Subscriber	47
4.8.5.	Conduct Constituting Acceptance of Modified Certificate	48
4.8.6.	Publication of the Modified Certificate by the CA	48
4.8.7.	Notification of Certificate Issuance by the CA to Other Entities	48
4.9.	Certificate Revocation and Suspension	48
4.9.1.	Circumstances for Revocation	48
4.9.2.	Who Can Request Revocation	49
4.9.3.	Procedure for Revocation Request	49
4.9.4.	Revocation Request Grace Period	50
4.9.5.	Time within which CA must Process the Revocation Request	50
4.9.6.	Revocation Checking Requirements for Relying Parties	50
4.9.7.	CRL Issuance Frequency	50
4.9.8.	Maximum Latency for CRLs	51
4.9.9.	On-line Revocation/Status Checking Availability	51
4.9.10.	On-line Revocation Checking Requirements	51
4.9.11.	Other Forms of Revocation Advertisements Available	52
4.9.12.	Special Requirements Related to Key Compromise	52
4.9.13.	Circumstances for Suspension and Restoration	52
4.9.14.	Who Can Request Suspension and Restoration	52
4.9.15.	Procedure for Suspension and Restoration Requests	52
4.9.16.	Limits on Suspension Period	53
4.10.	Certificate Status Services	53
4.10.1.	Operational Characteristics	53

4.10.2.	Service Availability	53
4.10.3.	Optional Features	54
4.11.	End Of Subscription	54
4.12.	Key Escrow and Recovery	54
4.12.1.	Key Escrow and Recovery Policy and Practices	54
4.12.1.1.	Key Escrow Process and Responsibilities	54
4.12.1.2.	Key Recovery Process and Responsibilities	54
4.12.1.3.	Key Recovery Through KRA	55
4.12.1.4.	Automated Self-Recovery	56
4.12.1.5.	Key Recovery During Token Issuance	56
4.12.1.6.	Key Recovery by Data Decryption Server	56
4.12.1.7.	Who Can Submit a Key Recovery Application	57
4.12.1.8.	Requestor Authorization Validation	57
4.12.1.9.	Subscriber Authorization Validation	57
4.12.1.10.	KRA Authorization Validation	57
4.12.1.11.	KRO Authorization Validation	57
4.12.1.12.	Data Decryption Server Authorization Validation	57
4.12.2.	Session Key Encapsulation and Recovery Policy and Practices	57
5.	Facility, Management, and Operational Controls	58
5.1.	Physical Controls	58
5.1.1.	Site Location and Construction	58
5.1.2.	Physical Access	58
5.1.2.1.	Physical Access for CA Equipment	58
5.1.2.2.	Physical Access for RA Equipment	59
5.1.2.3.	Physical Access for CSS Equipment	59
5.1.2.4.	Physical Access for KED Equipment	59
5.1.2.5.	Physical Access for DDS Equipment	59
5.1.2.6.	Physical Access for KRA and KRO Equipment	59
5.1.3.	Power and Air Conditioning	59
5.1.4.	Water Exposures	60
5.1.5.	Fire Prevention and Protection	60
5.1.6.	Media Storage	60
5.1.7.	Waste Disposal	60
5.1.8.	Off-Site Backup	60

5.2.	Procedural Controls	60
5.2.1.	Trusted Roles	60
5.2.2.	Number of Persons Required per Task	61
5.2.3.	Identification and Authentication for Each Role	61
5.2.4.	Roles Requiring Separation of Duties	61
5.3.	Personnel Controls	62
5.3.1.	Qualifications, Experience, and Clearance Requirements	62
5.3.2.	Background Check Procedures	62
5.3.3.	Training Requirements	62
5.3.4.	Retraining Frequency and Requirements	63
5.3.5.	Job Rotation Frequency and Sequence	63
5.3.6.	Sanctions for Unauthorized Actions	63
5.3.7.	Independent Contractor Requirements	63
5.3.8.	Documentation Supplied to Personnel	63
5.4.	Audit Logging Procedures	63
5.4.1.	Types of Events Recorded	64
5.4.2.	Frequency of Processing Log	67
5.4.3.	Retention Period for Audit Log	68
5.4.4.	Protection of Audit Log	68
5.4.5.	Audit Log Backup Procedures	68
5.4.6.	Audit Collection System (Internal vs. External)	68
5.4.7.	Notification to Event-Causing Subject	68
5.4.8.	Vulnerability Assessments	69
5.5.	Records Archival	69
5.5.1.	Types of Events Archived	69
5.5.2.	Retention Period for Archive	71
5.5.3.	Protection of Archive	71
5.5.4.	Archive Backup Procedures	72
5.5.5.	Requirements for Time-Stamping of Records	72
5.5.6.	Archive Collection System (Internal or External)	72
5.5.7.	Procedures to Obtain and Verify Archive Information	72
5.6.	Key Changeover	72
5.7.	Compromise and Disaster Recovery	73
5.7.1.	Incident and Compromise Handling Procedures	73

5.7.2.	Computing Resources, Software, and/or Data Are Corrupted	73
5.7.3.	Entity Private Key Compromise Procedures	74
5.7.3.1.	CA Private Key Compromise Procedures	74
5.7.3.2.	KRS Private Key Compromise Procedures	74
5.7.4.	Business Continuity Capabilities after a Disaster	75
5.8.	CA or RA Termination	75
6.	Technical Security Controls	76
6.1.	Key Pair Generation and Installation	76
6.1.1.	Key Pair Generation	76
6.1.1.1.	CA Key Pair Generation	76
6.1.1.2.	Subscriber Key Pair Generation	76
6.1.1.3.	CSS Key Pair Generation	76
6.1.1.4.	PIV Content Signing Key Pair Generation	77
6.1.2.	Private Key Delivery to Subscriber	77
6.1.3.	Public Key Delivery to Certificate Issuer	77
6.1.4.	CA Public Key Delivery to Relying Parties	77
6.1.5.	Key Sizes	78
6.1.6.	Public Key Parameters Generation and Quality Checking	79
6.1.7.	Key Usage Purposes (as per X.509 v3 Key Usage Field)	79
6.2.	Private Key Protection and Cryptographic Module Engineering Controls	80
6.2.1.	Cryptographic Module Standards and Controls	80
6.2.2.	Private Key (n out of m) Multi-Person Control	81
6.2.3.	Private Key Escrow	81
6.2.4.	Private Key Backup	82
6.2.5.	Private Key Archival	83
6.2.6.	Private Key Transfer into or from a Cryptographic Module	83
6.2.7.	Private Key Storage on Cryptographic Module	83
6.2.8.	Method of Activating Private Key	83
6.2.9.	Method of Deactivating Private Key	84
6.2.10.	Method of Destroying Private Key	84
6.2.11.	Cryptographic Module Rating	85
6.3.	Other Aspects of Key Pair Management	85
6.3.1.	Public Key Archival	85
6.3.2.	Certificate Operational Periods and Key Usage Periods	85

6.4.	Activation Data	86
6.4.1.	Activation Data Generation and Installation	86
6.4.2.	Activation Data Protection	86
6.4.3.	Other Aspects of Activation Data	87
6.5.	Computer Security Controls	87
6.5.1.	Specific Computer Security Technical Requirements	87
6.5.2.	Computer Security Rating	88
6.6.	Life Cycle Technical Controls	88
6.6.1.	System Development Controls	88
6.6.2.	Security Management Controls	88
6.6.3.	Life Cycle Security Controls	89
6.7.	Network Security Controls	89
6.8.	Time-Stamping	89
7.	Certificate, CRL, and OCSP Profiles	89
7.1.	Certificate Profile	89
7.1.1.	Version Number(s)	90
7.1.2.	Certificate Extensions	90
7.1.3.	Algorithm Object Identifiers	91
7.1.4.	Name Forms	92
7.1.5.	Name Constraints	92
7.1.6.	Certificate Policy Object Identifier	92
7.1.7.	Usage of Policy Constraints Extension	92
7.1.8.	Policy Qualifiers Syntax and Semantics	93
7.1.9.	Processing Semantics for the Critical Certificate Policies Extension	93
7.1.10.	Inhibit Any Policy Extension	93
7.2.	CRL Profile	93
7.2.1.	Version Number(s)	93
7.2.2.	CRL and CRL Entry Extensions	93
7.3.	OCSP Profile	93
7.3.1.	Version Number(s)	93
7.3.2.	OCSP Extensions	93
8.	Compliance Audit and Other Assessments	93
8.1.	Frequency or Circumstances of Assessment	94
8.2.	Identity/Qualifications of Assessor	94

8.3.	Assessor’s Relationship to Assessed Entity	94
8.4.	Topics Covered by Assessment	94
8.5.	Actions Taken as a Result of Deficiency	95
8.6.	Communication of Results	95
9.	Other Business and Legal Matters	95
9.1.	Fees	95
9.1.1.	Certificate Issuance or Renewal Fees	95
9.1.2.	Certificate Access Fees	95
9.1.3.	Revocation or Status Information Access Fees	96
9.1.4.	Fees for other Services	96
9.1.5.	Refund Policy	96
9.2.	Financial Responsibility	96
9.2.1.	Insurance Coverage	96
9.2.2.	Other Assets	96
9.2.3.	Insurance or Warranty Coverage for End-Entities	96
9.3.	Confidentiality of Business Information	96
9.3.1.	Scope of Confidential Information	96
9.3.2.	Information not within the Scope of Confidential Information	96
9.3.3.	Responsibility to Protect Confidential Information	96
9.4.	Privacy of Personal Information	97
9.4.1.	Privacy Plan	97
9.4.2.	Information Treated as Private	97
9.4.3.	Information not Deemed Private	97
9.4.4.	Responsibility to Protect Private Information	97
9.4.5.	Notice and Consent to Use Private Information	97
9.4.6.	Disclosure Pursuant to Judicial or Administrative Process	97
9.4.7.	Other Information Disclosure Circumstances	98
9.5.	Intellectual Property Rights	98
9.6.	Representations and Warranties	98
9.6.1.	CA and KED Representations and Warranties	98
9.6.2.	RA and KRA/KRO Representations and Warranties	99
9.6.2.1.	RA Obligations	99
9.6.2.2.	KRA Obligations	99
9.6.2.3.	KRO Obligations	100

9.6.3.	Subscriber and Data Decryption Server Representations and Warranties	101
9.6.3.1.	Subscriber Representations and Warranties	101
9.6.3.2.	Data Decryption Server Representations and Warranties	101
9.6.4.	Relying Parties Representations and Warranties	102
9.6.5.	Representations and Warranties of Other Participants	102
9.7.	Disclaimers of Warranties	103
9.8.	Limitations of Liability	103
9.9.	Indemnities	103
9.10.	Term and Termination	103
9.10.1.	Term	103
9.10.2.	Termination	103
9.10.3.	Effect of Termination and Survival	103
9.11.	Individual Notices and Communications with Participants	104
9.12.	Amendments	104
9.12.1.	Procedure for Amendment	104
9.12.2.	Notification Mechanism and Period	104
9.12.3.	Circumstances under which OID must be Changed	104
9.13.	Dispute Resolution Provisions	104
9.14.	Governing Law	104
9.15.	Compliance with Applicable Law	104
9.16.	Miscellaneous Provisions	105
9.16.1.	Entire Agreement	105
9.16.2.	Assignment	105
9.16.3.	Severability	105
9.16.4.	Enforcement (Attorneys' Fees and Waiver of Rights)	105
9.16.5.	Force Majeure	105
9.17.	Other Provisions	105
Appendix A:	PIV and Common PIV Interoperable Comparison	106
Appendix B:	References	108
Appendix C:	Acronyms and Abbreviations	111
Appendix D:	Glossary	114
Appendix E:	Full Revision History	124

1. INTRODUCTION

This certificate policy (CP) includes the following distinct certificate policies:

- Three Personal Identity Verification (PIV) authentication policies;
- A PIV Interoperable (PIV-I) authentication policy for use by federal agencies;
- A PIV Card Authentication policy;
- A PIV-I Card Authentication policy for use by federal agencies;
- A policy for devices that sign PIV data objects;
- A policy for federal devices that sign PIV-I data objects;
- A policy for Human Subscribers with software cryptographic modules;
- A policy for Human Subscribers with hardware cryptographic modules;
- A high assurance policy for Human Subscribers;
- A policy for devices with software cryptographic modules; and
- A policy for devices with hardware cryptographic modules.

In this document, the term “device” means a non-person entity, i.e., a hardware device or software application.

Certificates intended for code signing are not covered by this policy.

Where a specific policy is not stated, the requirements in this specification apply equally to all policies.

The Human Subscriber policies apply to certificates issued to federal employees, contractors, and other affiliated personnel for the purposes of authentication, signature, and confidentiality. This CP was explicitly designed to support access to federal systems that have not been designated national security systems.

A Certification Authority (CA) that operates in accordance with this CP will provide the following security management services:

- Key generation/storage
- Key escrow and recovery
- Certificate generation, modification, re-key, and distribution
- Certificate revocation list (CRL) generation and distribution
- Repository management of certificate related items
- Certificate token initialization/programming/management
- System management functions (e.g., security audit, configuration management, archive.)

A Key Recovery System (KRS) is required for CAs operating under this policy that issue PIV key management certificates. The KRS provides the computer system hardware, software, staff and procedures to store private keys securely and recover them when appropriate.

Any CA that asserts these policies in certificates must obtain prior approval from the Federal PKI Policy Authority; approval is dependent upon a Certification Practices Statement (CPS) that clearly describes how each requirement in this CP is fulfilled, or, for Federal agencies that operate their own PKI, a comparable CP. For any section of this policy containing no stipulation, the CPS must indicate whether it is applicable, and if so, describe the associated practices. CAs operated by federal agencies that issue certificates under this policy may operate simultaneously under other policies. CAs that operate simultaneously under this policy and under other policies must assert at least one policy in all issued certificates. CAs must not assert the OIDs in this policy in certificates unless they are issued in accordance with all the requirements of this policy.

The root Certification Authority (CA) associated with the Common Policy Framework is the Federal Common Policy CA, operated by the Federal PKI Management Authority (FPKIMA).

This CP follows the RFC 3647 framework.

1.1. OVERVIEW

1.1.1. Certificate Policy (CP)

This CP applies only to CAs owned by or operated on behalf of the Federal Government that issue certificates according to this policy.

1.1.2. Relationship between the CP and the CPS

This CP states the requirements for the issuance and management of certificates issued by the CAs, and requirements for the operation of the CAs. The Certification Practice Statement (CPS) states how the CA(s) implement the requirements. Each CA that issues certificates under this CP must have a corresponding approved CPS.

1.1.3. Scope

The scope of this U.S. Federal PKI Common Policy Framework CP includes the Certification Authorities used for issuing and managing certificates that are valid to the Federal Common Policy CA on behalf of federal executive branch agencies. This CP applies to certificates issued to CAs, devices, and federal employees, contractors and other affiliated personnel. This CP does not include certificates issued to groups or intended to be shared.

Federal Government departments and agencies operate CAs that are intended to issue certificates for only locally trusted purposes. These CAs do not have a certification path to the Federal Common Policy CA and should not assert the policy OIDs defined in this CP.

1.1.4. Interoperation with CAs Issuing under Different Policies

PKI interoperation with CAs that issue under different policies will be achieved through cross-certification with the Federal Bridge Certification Authority (FBCA). Federal Government agency CAs may obtain a cross-certificate from either the Federal Common Policy CA or Federal Bridge CA at their discretion. In all cases, the CA's Certificate Policy is mapped with the FBCA CP for comparability and the policy mapping approved by the FPKI Policy Authority.

Interoperability may also be achieved through other means, such as trust lists.

1.2. *DOCUMENT NAME AND IDENTIFICATION*

This is the X.509 Certificate Policy for the U.S. Federal PKI Common Policy Framework.

Certificates issued in accordance with this CP must assert at least one of the following OIDs in the certificate policies extension:

id-fpki-common-policy	::= {2 16 840 1 101 3 2 1 3 6}
id-fpki-common-hardware	::= {2 16 840 1 101 3 2 1 3 7}
id-fpki-common-devices	::= {2 16 840 1 101 3 2 1 3 8}
id-fpki-common-devicesHardware	::= {2 16 840 1 101 3 2 1 3 36}
id-fpki-common-authentication	::= {2 16 840 1 101 3 2 1 3 13}
id-fpki-common-high	::= {2 16 840 1 101 3 2 1 3 16}
id-fpki-common-cardAuth	::= {2 16 840 1 101 3 2 1 3 17}
id-fpki-common-piv-contentSigning	::= {2 16 840 1 101 3 2 1 3 39}
id-fpki-common-derived-pivAuth	::= {2 16 840 1 101 3 2 1 3 40}
id-fpki-common-derived-pivAuth-hardware	::= {2 16 840 1 101 3 2 1 3 41}
id-fpki-common-pivi-authentication	::= {2 16 840 1 101 3 2 1 3 45}
id-fpki-common-pivi-cardAuth	::= {2 16 840 1 101 3 2 1 3 46}
id-fpki-common-pivi-contentSigning	::= {2 16 840 1 101 3 2 1 3 47}

CA certificates may contain a subset of these OIDs.

Subscriber certificates must contain an appropriate policy OID as described in the following tables:

FIPS 201 Personal Identity Verification (PIV) Human Subscriber Certificates

Certificates asserting the following policies are issued to Human Subscribers and are limited to use with PIV credentials by FIPS 201.

PIV Authentication certificate with the private key on a PIV credential	id-fpki-common-authentication
Derived PIV Authentication certificate issued in accordance with NIST SP 800-157 where the private key is not on a PIV credential	id-fpki-common-derived-pivAuth-hardware or id-fpki-common-derived-pivAuth as appropriate

Additional Human Subscriber Certificates

Digital signature certificate with the private key on a PIV credential	id-fpki-common-hardware or id-fpki-common-high
Digital signature certificate with the private key not on a PIV credential	id-fpki-common-policy, id-fpki-common-hardware, or id-fpki-common-high
Key Management certificate, whether or not on a PIV credential	id-fpki-common-policy, id-fpki-common-hardware, or id-fpki-common-high
Practice Note – Asserting id-fpki-common-policy for key management certificates is recommended as it provides implementation flexibility for specific use cases such as mobile devices and key recovery.	
Common PIV-I Authentication certificate with the private key on a federally-issued PIV-I credential	id-fpki-common-pivi-authentication
Other authentication certificate	id-fpki-common-policy, id-fpki-common-hardware, or id-fpki-common-high

The requirements associated with id-fpki-common-pivi-authentication are identical to id-fpki-common-authentication, with the exception of the need for a National Agency Check with Inquiries (NACI) and associated favorable adjudication. See Appendix A for additional comparisons between PIV and Common PIV-I credentials.

FIPS 201 Personal Identity Verification (PIV) Device Subscriber Certificates

Certificates asserting the following policies are issued to Device Subscribers and are limited to use with PIV credentials by FIPS 201.

Card Authentication certificate with the private key on a PIV credential	id-fpki-common-cardAuth
Content Signing certificate used to sign PIV data objects in accordance with [FIPS 201] or [SP 800-157]	id-fpki-common-piv-contentSigning

The requirements associated with id-fpki-common-piv-contentSigning are identical to id-fpki-common-devicesHardware except where specifically noted in the text.

Additional Device Subscriber Certificates

Certificates asserting the following policies may be issued to devices or software systems.

FIPS 140 Level 2 or higher hardware cryptographic modules	id-fpki-common-deviceHardware
FIPS 140 Level 1 or higher cryptographic modules	id-fpki-common-devices
Common PIV-I Card Authentication certificate with the private key on a federally-issued PIV-I credential	id-fpki-common-pivi-cardAuth
Common PIV-I Content Signing certificate used to sign federally-issued PIV-I data objects in accordance with [SP 800-157]	id-fpki-common-pivi-contentSigning

The requirements associated with id-fpki-common-pivi-cardAuth are identical to id-fpki-common-cardAuth, with the exception of the need for a NACI and associated favorable adjudication.

The requirements associated with id-fpki-common-pivi-contentSigning are identical to id-fpki-common-piv-contentSigning, except where specifically noted in the text.

1.3. PKI PARTICIPANTS

The following are roles relevant to the administration and operation of CAs under this policy:

1.3.1. PKI Authorities

1.3.1.1. Federal Chief Information Officers Council

The Federal Chief Information Officer (CIO) Council comprises the Chief Information Officers of all cabinet level departments and other independent agencies. The Federal CIO Council has established the framework for the interoperable Federal PKI (FPKI) and oversees the operation of the organizations responsible for governing and promoting its use. In particular, this CP was established under the authority and approval of the Federal CIO Council.

1.3.1.2. Federal PKI Policy Authority (FPKIPA)

The Federal Public Key Infrastructure Policy Authority (FPKIPA) is a sub-council comprised of U.S. Federal Government agency representatives and is chartered under the Federal Chief Information Security Officer (CISO) Council, under the Federal CIO Council. The FPKIPA owns this certificate policy and represents the interest of the Federal CIOs and Federal CISOs.

The FPKIPA is responsible for:

- Maintaining this CP,
- Approving the CPS for each CA that issues certificates under this policy,
- Approving the compliance audit report for each CA issuing certificates under this policy, and
- Ensuring continued conformance of each CA that issues certificates under this policy with applicable requirements as a condition for allowing continued participation.

1.3.1.3. FPKI Management Authority (FPKIMA)

The FPKIMA is the government program that operates and maintains the Federal PKI operational environment on behalf of the U.S. Government.

1.3.1.4. FPKI Management Authority Program Manager

The Program Manager is the individual within the FPKIMA who has principal responsibility for overseeing the operation of the Federal Common Policy CA, including the required repository, and selecting the FPKIMA staff. For additional personnel security controls associated with this role see Section 5.3.1.

1.3.1.5. Policy Management Authority (PMA)

A PMA is an individual or group established by an organization or agency for the purpose of ensuring all PKI components are operated in compliance with an appropriate CPS and this CP. All organizations and agencies operating a PKI under this policy must establish a PMA. The PMA must identify an individual to serve as the liaison for that organization or agency to the FPKIPA.

1.3.2. Certification Authorities

The CA is the collection of hardware, software and operating personnel that create, sign, and issue public key certificates to Subscribers. The CA is responsible for issuing and managing certificates including:

- The certificate manufacturing process
- Publication of certificates
- Revocation of certificates
- Generation and destruction of CA signing keys
- Ensuring that all aspects of the CA services, operations, and infrastructure related to certificates issued under this CP are performed in accordance with the requirements, representations, and warranties of this CP.

CA and related applications (e.g., OCSP, CMS, and KRS) may be hosted on one or more system software layers. Operational and technical security controls including audit logging requirements specified in this CP shall apply to all system software layers, where appropriate and applicable.

1.3.3. Registration Authorities

A Registration Authority (RA) is an entity authorized by the CA to collect, verify, and submit information provided by potential Subscribers for the purpose of issuing public key certificates. The term RA refers to hardware, software, and individuals that may collectively perform this function. Individuals fulfilling the RA function are acting in a Trusted Role, and are considered Officers as defined in Section 5.2.1. The RA is responsible for:

- Control over the registration process.
- The identification and authentication process.

A Trusted Agent is authorized by a PKI to act on its behalf and may record information from and verifies biometrics (e.g., photographs) on presented credentials on behalf of an RA for Applicants who cannot appear before an RA. Trusted Agents are not Trusted Roles; however, the PKI must document any Trusted Agent authorization requirements to include:

- trustworthiness vetting, and
- training or government appointment (e.g., notary public).

All identity proofing audit artifacts produced by a Trusted Agent must be traceable to an individual.

1.3.4. Key Recovery Authorities

For organizations that have implemented Key Recovery, the applicable requirements for physical, personnel, and procedural security controls, technical security controls, and Compliance Audit are applied as follows:

- CA requirements are applied to the KED and to the DDS
- RA requirements are applied to the KRA and KRA automated systems

1.3.4.1. Key Escrow Database

The KED is defined as the function, system, or subsystem that maintains the key escrow repository and responds to key registration requests. The KED also responds to key recovery requests from two or more KRAs or self-recovery by a current subscriber.

Section 5.2.1.2 contains the description of trusted roles required to operate the KED.

1.3.4.2. Data Decryption Server

A DDS is an automated system that has the capability to obtain subscriber private keys from the KED or another DDS for data monitoring or other purposes (e.g., email inspection). DDSs do not provide keys to Subscribers or other Third-Party Requestors. A DDS has access to escrowed key management keys and must meet all security requirements of the KED as outlined in this policy.

Implementation of a DDS is optional based on organizational operations.

1.3.4.3. Key Recovery Agent

A KRA is an individual who is authorized, as specified in the applicable Practice Statement (KRPS or CPS), to recover an escrowed key. The KRAs have high level, sensitive access to the KED and are considered Trusted Roles (see Section 5.2.1). KRAs can recover large numbers of keys, the number and location of KRAs should be closely controlled.

A KRA performs the following functions:

- Confirm validity and completeness of requests,
- Recover copies of escrowed keys; and
- Distribute copies of recovered keys to Requestor, with protection as described in Section 4.12.1.3.

KRAs may conduct requestor identity verification and authorization validation when KROs are not used.

1.3.4.4. Key Recovery Official

Organizations may opt to appoint a Key Recovery Official (KRO) to support key recovery requestor identity verification and authorization validation tasks; however, a KRO is not a Trusted Role.

A KRO's responsibilities are to perform the following functions:

- Verify a Requestor's identity and authorization as stated by this policy;
- Assist authorized requestors in building key recovery requests;
- Utilize secure communication for key recovery requests to and responses from the KRA; and
- Participate in the distribution of escrowed keys to the Requestor, ensuring that it occurs as described by the associated practice statement (CPS or KRPS).

Practice Note: The responsibilities of the Key Recovery Official do not require access to the KED and as a result the KRO is not considered a Trusted Role. However, organizations may assign multiple responsibilities to one person due to resource constraints. In scenarios where Trusted Roles may also be assigned to perform the duties of the KRO, the requirements for Separation of Duties per Section 5.2.4 must be enforced.

1.3.5. Key Recovery Requestors

A Requestor is the person or DDS that requests the recovery of a decryption private key. A Requestor may be the Subscriber or a third-party (e.g., supervisor, corporate officer or law enforcement officer) authorized to request recovery of a Subscriber's escrowed key on behalf of the Subscriber or on behalf of the organization. Any individual who can demonstrate a verifiable authority and a need to obtain a recovered key may be considered a Requestor.

1.3.5.1. Internal Third-Party Requestor

An Internal Third-Party Requestor is any Requestor who is in the Subscriber's supervisory chain or otherwise authorized to obtain the Subscriber's key for the Issuing Organization (i.e., the organization on behalf of which the CA issues certificates to subscribers).

1.3.5.2. External Third-Party Requestor

An External Third-Party Requestor is someone (e.g., investigator) outside the Issuing Organization with a court order or other legal instrument to obtain the decryption private key of the Subscriber.

1.3.6. Subscribers

A Subscriber is the entity whose name appears as the subject in a certificate. For this CP and all certificates issued, Subscribers are limited to federal employees, contractors, affiliated personnel, and devices operated by or on behalf of federal agencies. The term "Subscriber" as used in this document refers only to those who request certificates for uses other than signing and issuing certificates or certificate status information. A Subscriber may be referred to as an "Applicant" after applying for a certificate, but before the certificate issuance procedure is completed.

There is a subset of Human Subscribers who will be issued role-based certificates. These certificates identify a specific role on behalf of which the Subscriber or "private key holder" is authorized to act rather than the Subscriber's name. These certificates are issued in the interest of supporting accepted business practices. The role-based certificate can be used in situations where non-repudiation is desired. Normally, role-based certificates will be issued in addition to

individual Subscriber certificates. A specific role may be identified in certificates issued to multiple Subscribers; however, the key pair will be unique to each individual role-based certificate. For example, there may be four individuals with a certificate issued in the role of “General Counsel, DHS.” However, each of the four certificates will have unique keys and certificate serial numbers. A specific example of a role-based certificate may be a delegated digital signature certificate that is issued to private key holder(s) who have been delegated the authority to sign documents on behalf of a “role holder” who is another individual assigned or appointed to a role that has unique authorization (e.g., “Secretary of Commerce,” who has the authority to provide official submissions to the Office of the Federal Register). Delegated digital signature certificates are limited to those roles that are held by a unique individual within an organization (e.g., Chief Information Officer, GSA is a unique individual whereas Program Analyst, GSA is not).

Practice Note: In many cases a Role-Based certificate may be authorized for the individual(s) assigned to that role, in which case the role holder and the private key holder(s) are the same person. Delegated digital signature certificates are the only instance where an authorized private key holder is a different individual than the role holder named in the subjectDN. In these instances, private key holder traceability is maintained via unique identifiers asserted in the Subject Alternative Name extension.

Practice Note: When determining whether a role-based certificate is authorized, consider whether the role carries inherent authority beyond the job title. Role-based certificates may also be used for individuals on temporary assignment, where the temporary assignment carries an authority not shared by the individuals in their usual occupation, for example: “Watch Commander, Task Force 1”.

1.3.7. Relying Parties

A relying party is the entity that relies on the validity of the binding of the Subscriber’s identity to a public key. The relying party is responsible for deciding whether or how to check the validity of the certificate by checking the appropriate certificate status information. The relying party can use the certificate to verify the integrity of a digitally signed message, to identify the creator of a message, or to establish confidential communications with the holder of the certificate’s private key. A relying party may use information in the certificate (such as certificate policy identifiers, key usage, or extended key usage) to determine its appropriate usage.

For this certificate policy, the relying party may be any entity that wishes to validate the binding of a public key to the name of a Subscriber.

1.3.8. Other Participants

The CAs and RAs operating under this CP may require the services of other security, community, and application authorities, such as compliance auditors.

Participating agencies that do not operate a PKI directly must identify one or more Agency Points of Contact (POC) as liaisons to the issuing PKI and the FPKIPA.

1.4. CERTIFICATE USAGE

1.4.1. Appropriate Certificate Uses

Certificates issued under this CP may be used for authentication to Federal systems.

Certificates issued under this CP may also be used for key management, signature, and confidentiality requirements for Federal Government processes.

This policy is intended to support use cases involving unclassified information, which can include sensitive unclassified data protected pursuant to federal statutes and regulations.

Agencies make risk-informed decisions when using certificates to manage the identities of federal systems and users by evaluating the environment, associated threats, and vulnerabilities in determining the level of risk they are willing to accept based on the sensitivity or significance of the information. This evaluation is done by agencies for each application and is not controlled by this CP.

1.4.2. Prohibited Certificate Uses

Certificates that assert `id-fpki-common-cardAuth` or `id-fpki-common-pivi-cardAuth` must only be used to authenticate the hardware token containing the associated private key and must not be interpreted as authenticating the presenter or holder of the token.

Delegated digital signature certificates must not assert authentication OIDs in a certificate Extended Key Usage (EKU) extension.

Certificates intended for code signing are not permitted under this policy.

1.5. POLICY ADMINISTRATION

1.5.1. Organization Administering the Document

The FPKIPA is responsible for all aspects of this CP.

1.5.2. Contact Person

Contact information for the support and co-chairs for the FPKIPA is fpki@gsa.gov.

1.5.3. Person Determining CPS Suitability for the Policy

The FPKIPA must approve the CPS for each CA that issues certificates under this policy.

1.5.4. CPS Approval Procedures

CAs issuing under this CP are required to meet all requirements. The FPKIPA will not issue waivers.

The FPKIPA makes the determination that a CPS complies with this policy. The CA and RA must operate under an approved CPS. RA practices are documented in the CPS or an associated Registration Practices Statement (RPS). In each case, the determination process must include an independent compliance auditor's results and recommendations. See Section 8 for further details.

1.6. DEFINITIONS AND ACRONYMS

See Appendix B and Appendix C.

2. PUBLICATION AND REPOSITORY RESPONSIBILITIES

2.1. REPOSITORIES

The publicly accessible repository system must be designed and implemented so as to provide 99% availability overall and limit scheduled down-time to 0.5% annually.

2.2. PUBLICATION OF CERTIFICATION INFORMATION

2.2.1. Publication of Certificates and Certificate Status

All CAs that issue CA certificates must publish all CA certificates it issues in a file available via a publicly accessible HTTP URI. This URI must be asserted in the Subject Information Access (SIA) extension in all valid certificates issued to the CA. The file must be a certs-only Cryptographic Message Syntax file that has an extension of .p7c.

With the exception of self-signed certificates, all CA certificates must be published by the Subject CA in a file available via a publicly accessible HTTP URI. This URI must be asserted in the Authority Information Access (AIA) extension in all valid certificates issued by the Subject CA. The file must be:

- a certs-only Cryptographic Message Syntax file that has an extension of .p7c, or
- a single DER encoded certificate that has an extension of .cer

The certs-only Cryptographic Message Syntax format is preferred as it allows flexibility for inclusion of multiple certificates.

All CAs that issue certificates under this policy must publish the latest CRL covering all unexpired certificates via a publicly accessible HTTP URI until such time as all issued certificates have expired. This URI must be asserted in the CRL distribution point extension of all certificates issued by that CA, with the exception of Online Certificate Status Protocol (OCSP) responder certificates that include the id-pkix-ocsp-nocheck extension.

A Certificate Status Server (CSS) provides status information about certificates on behalf of a CA through on-line transactions.

CAs must include a CSS in the form of a delegated OCSP service, as described in [RFC 6960], to provide on-line status information for Subscriber certificates via a publicly accessible HTTP URI in the AIA extension. The operations of the OCSP service are within the scope of this CP.

Pre-generated OCSP responses may be created by the CSS and distributed to OCSP servers. OCSP responses, like CRLs, are publicly distributable data. OCSP servers that lack OCSP response signing capability have the same security requirements as a repository hosting CRLs.

OCSP services that are locally trusted, as described in [RFC 6960], are not covered by this policy.

All certificates must contain only valid Uniform Resource Identifiers (URIs) that are publicly accessible by relying parties.

2.2.2. Publication of CA Information

This CP must be publicly available on <https://www.idmanagement.gov/>.

The CPS and annual PKI Compliance Audit Letter for the Federal Common Policy CA are publicly available on <https://www.idmanagement.gov/>.

Other CAs operating under this policy should make available a redacted CPS and annual PKI Compliance Audit Letter in their organization's public repository.

2.3. TIME OR FREQUENCY OF PUBLICATION

This CP and any subsequent changes must be made publicly available within thirty (30) days of approval.

Publication requirements for CRLs are provided in Sections 4.9.7 and 4.9.12.

2.4. ACCESS CONTROLS ON REPOSITORIES

Repositories hosting CA certificates, CRLs, and pre-generated OCSP responses (if implemented) must be publicly accessible. Information not intended for modification or public dissemination must be protected.

Each CPS must detail what information in the repository is exempt from automatic availability and to whom, and under which conditions the restricted information may be made available.

Posted certificates, CRLs, and pre-generated OCSP responses may be replicated in additional repositories for performance enhancement.

3. IDENTIFICATION AND AUTHENTICATION

3.1. NAMING

3.1.1. Types of Names

This CP establishes requirements for both subject distinguished names and subject alternative names.

3.1.1.1. Subject Names

The CA must assign X.501 distinguished names to all Subscriber certificates. These distinguished names are comprised of a base distinguished name (Base DN) and additional relative distinguished names (RDNs). Base DN may be in either of two forms: a geo-political name or an Internet domain component name.

All geo-political distinguished names must use one of the following Base DNs:

- C=US, o=U.S. Government, ou=department, ou=agency, [ou=*structural_container*]
- C=US, o=U.S. Government, ou=department, [ou=*structural_container*]
- C=US, o=U.S. Government, ou=agency, [ou=*structural_container*]

The organizational units department and agency appear when applicable and are used to specify the federal entity that employs the Human Subscriber or owns the device. At least one of these organizational units must appear in the DN.

Distinguished names based on Internet domain component names must use the following Base DN:

- dc=gov, dc=org0, [dc=org1], ..., [dc=orgN], [o=organization], [ou=*structural_container*]

At a minimum, the org0 domain component must appear in the Base DN. The org1 to orgN domain components appear, in order, when applicable, and are used to specify the federal entity that employs the Human Subscriber or owns the device.

The additional organizational unit *structural_container* in either the geo-political or Internet domain Base DN form is permitted to support local directory requirements, such as differentiation between Human Subscribers and Device Subscribers. This organizational unit may not be employed to further differentiate between subcomponents within an agency.

The distinguished name of the Human Subscriber must include a common name (CN) using one of the following formats:

- Base DN, CN=nickname lastname
- Base DN, CN=firstname initial. lastname
- Base DN, CN=firstname initial lastname
- Base DN, CN=firstname middlename lastname
- Base DN, CN=lastname.firstname.middlename

In the first common name format, nickname may be the Human Subscriber's first name, a form of the first name, middle name, or pseudonym (e.g., Buck) by which the Subscriber is generally known. A generational qualifier, such as "Sr." or "III", or agency specific identifiers (e.g., CN=Giants.John.Gregory.1234567890) may be appended to any of the common name formats specified above.

Additional certificate qualifiers may be appended to the common name in order to provide additional context to the certificate's intended usage. The qualifier must be preceded by a space followed by a hyphen (e.g., CN=John G. Giants -ENC).

Distinguished names assigned to federal contractors and other affiliated persons must follow one of the name forms identified above with (affiliate) appended to the end of the common name (e.g., CN=John G. Giants (affiliate)).

The CA may supplement any of the distinguished name forms for Human Subscribers specified in this section by including a dnQualifier, serial number, or user id. When any of these are included, they may appear:

- as part of a multi-valued RDN with the common name, or
- as a distinct RDN that follows the RDN containing the common name

Role-based signature certificates, to include those that support delegated digital signatures, must be issued under id-fpki-common-hardware (see Section 1.3.6). For these certificates, the common name must specify the role, and may optionally specify the department or agency associated with that role, the name of the individual role holder, and a general purpose for the certificate, as follows:

- CN=role [, department/agency] [firstname lastname (purpose)]

Where the [department/agency] is implicit in the role (e.g., Secretary of Commerce), it may be omitted. Where the role alone is ambiguous (e.g., Chief Information Officer) the department/agency must be present in the common name. The organizational information in the common name must correspond to that in the organizational unit attributes. When the role holder's name is included in the CN, a purpose for the certificate must be included (e.g., (OFR), (delegated), (acting agent), etc.) in order to more readily convey to relying parties that the private key holder is not the named role holder. The order of appearance of role, department, and name (purpose) in the CN is determined by the issuing authority. Additional descriptors that indicate role-based certificates may be included before the role or role holder's name if acceptable for relying party use (e.g. "Office of the Secretary of Commerce," or "On behalf of the Secretary of Commerce").

Practice Note: In the case of "Chief Information Officer", use of department/agency in the common name is redundant to the RDN but is included for usability purposes. Display of the common name is widely supported in applications. Other attributes may or may not be presented to users.

Device Subscriber distinguished names must take the following form:

- Base DN, CN=device name

where device name is a descriptive name for the device.

When id-fpki-common-piv-contentSigning or id-fpki-common-pivi-contentSigning is asserted, the certificate's subject distinguished name must indicate the organization administering the credential issuance system.

When id-fpki-common-cardAuth is asserted, the certificate's subject distinguished name must take one of the following forms:

- Base DN, serialNumber=FASC-N
- Base DN, serialNumber=UUID

When id-fpki-common-pivi-cardAuth is asserted, the certificate's subject distinguished name must take the following form:

- Base DN, serialNumber=UUID

This CP does not restrict the subject distinguished names of CA certificates and Delegated OCSP Responder certificates. However, CA certificates and Delegated OCSP Responder certificates must have subject distinguished names. CA and Delegated OCSP Responder certificate distinguished names may be either a geo-political name or an Internet domain component name. Geo-political distinguished names must be composed of any combination of the following attributes: country; organization; organizational unit; and common name. Internet domain component names are composed of the following attributes: domain component; organizational unit; and common name.

CA subject distinguished names may or may not include a common name, for example:

Base DN, OU=Certification Authorities, OU=Agency CA

If included, the common name in the CA certificates should describe the issuer, such as:

Base DN, OU=Certification Authorities, CN=AgencyX CA-3

3.1.1.2. Subject Alternative Names

Certificates issued under id-fpki-common-authentication or id-fpki-common-cardAuth must include a subject alternative name extension. The subject alternative name extension must include both:

- the pivFASC-N name type [FIPS 201], the value of which must be the FASC-N [PACS] of the subject's PIV credential; and
- a UUID encoded as a URI as specified in Section 3 of [RFC 4122].

Certificates issued under id-fpki-common-cardAuth must not include any other name in the subject alternative name extension.

Certificates issued under `id-fpki-common-pivi-authentication`, `id-fpki-common-pivi-cardAuth`, `id-fpki-common-derived-pivAuth-hardware` and `id-fpki-common-derived-pivAuth` must include a subject alternative name extension that includes:

- a UUID encoded as a URI as specified in Section 3 of [RFC 4122].
- for derived PIV, UUID is unique per certificate

Certificates issued under `id-fpki-common-pivi-cardAuth` must not include any other name in the subject alternative name extension.

Subscriber certificates that contain `id-kp-emailProtection` in the EKU must include a subject alternative name extension that includes a `rfc822Name`.

Role-based certificates including those that support delegated digital signatures, must include at least one subject alternative name extension that uniquely identifies the individual subscriber that controls the private signature key (e.g., `rfc822Name` or `otherName` like Microsoft User Principal Name). Another example of a compliant identifier is the full Distinguished Name from the PIV Authentication certificate of the individual who is to be issued the role-based certificate (e.g., the private key holder) that may be included as a `directoryName`.

For Device Subscriber certificates that assert `serverAuth` in the Extended Key Usage:

- A subject alternative name of type `dNSName` must be included.
- Wildcard domain names are permitted in the `dNSName` values only if all sub-domains covered by the wildcard fall within the same application, cloud service, or system accreditation boundary within the scope of the sponsoring agency.
- Wildcards must not be used in subdomains that host more than one distinct application platform. The use of third-level agency wildcards, (e.g., `*.[agency].gov`), must be prohibited to reduce the likelihood that a certificate will overlap multiple systems or services. Third level wildcards are permitted for `dNSName` dedicated to a specific application (e.g., `*.[application_name].gov`).
- Before requesting a `serverAuth` certificate containing a wildcard, the sponsoring agency must provide evidence to the issuing CA that the scope of the certificate does not now and will not infringe on other agency applications.

Section 3.1 Practice Note: The FASC-N [PACS] consists of 40 decimal digits that are encoded as a 25-byte binary value. This 25-byte binary value may be encoded directly into the `pivFASC-N` name type in the subject alternative name extension, but when included in the subject distinguished name the FASC-N must be encoded as a `PrintableString` that is at most 64 characters long. This policy does not mandate any particular method for encoding the FASC-N within the serial number attribute as long as the same encoding method is used for all certificates issued by a CA. Acceptable methods for encoding the FASC-N within the serial number attribute include encoding the 25-byte binary value as 50 bytes of ASCII HEX or encoding the 40 decimal digits as 40 bytes of ASCII decimal.

Section 3.1 Practice Note: When the UUID appears in the subject alternative name extension of a certificate, it must be encoded as a uniformResourceIdentifier as specified in Section 3 of [RFC 4122]. An example of a UUID encoded as a URI, from RFC 4122, is “urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6”. This policy does not mandate any particular method for encoding the UUID within the serial number attribute as long as the same encoding method is used for all certificates issued by the CA and it is encoded as a PrintableString that is at most 64 characters long. However, it is recommended that the string representation from Section 3 of [RFC 4122] be used. An example would be “f81d4fae-7dec-11d0-a765-00a0c91e6bf6”.

3.1.2. Need for Names to Be Meaningful

Subscriber certificates are meaningful only if the names that appear in the certificates can be understood and used by relying parties. Names used in the certificates must identify in a meaningful way the Subscriber to which they are assigned.

The common name in the distinguished name must represent the Subscriber in a way that is easily understandable for humans. For Human Subscribers, this will typically be a legal name, see Section 3.1.1.

The subject name in CA certificates must match the issuer name in certificates issued by the subject, as required by [RFC 5280].

3.1.3. Anonymity or Pseudonymity of Subscribers

A CA must not issue anonymous certificates.

Role-based certificates may be issued by the CA to support internal operations. CAs may also issue role-based certificates that identify subjects by their organizational roles, as described in Section 3.1.1.

CA certificates must not contain anonymous or pseudonymous identities.

3.1.4. Rules for Interpreting Various Name Forms

Rules for interpreting distinguished name forms are specified in [X.501]. Rules for interpreting e-mail addresses are specified in [RFC 5322]. Rules for interpreting the pivFASC-N name type are specified in [PACS].

3.1.5. Uniqueness of Names

Name uniqueness for certificates issued by each CA must be enforced. Each CA and its associated RAs must enforce name uniqueness within the X.500 namespace. When other name forms are used, they too must be allocated such that name uniqueness is ensured for certificates issued by that CA. Name uniqueness is not violated when multiple certificates are issued to the same entity.

Practice Note: For distinguished names, name uniqueness is enforced for the entire name rather than a particular attribute (e.g., the common name).

The CPS must identify the method for the assignment of subject names.

3.1.6. Recognition, Authentication, and Role of Trademarks

CAs operating under this policy must not issue a certificate knowing that it infringes the trademark of another. The FPKIPA must resolve disputes involving names and trademarks.

3.2. *INITIAL IDENTITY VALIDATION*

3.2.1. Method to Prove Possession of Private Key

The CA must verify the Applicant has possession of the private key that corresponds to the public key in the certificate request. As an example, for signature keys this may be done by the Applicant using its private key to sign a value supplied by the CA. The CA must then validate the signature using the Applicant's public key. The FPKIPA may allow other mechanisms that are at least as secure as those cited here.

In the case where key generation is performed under the CA or RA's direct control, proof of possession is not required. (e.g., key management certificates generated in a system allowing key escrow.)

3.2.2. Authentication of Organization Identity

Requests for CA certificates must include the CA name, address, and documentation of the existence of the CA. Before issuing CA certificates, an authority for the issuing CA must verify the information provided by the requesting organization, in addition to the authenticity of the requesting representative and the representative's authorization to act in the name of the organization.

Before issuing subscriber certificates on behalf of an organization, the issuing CA must verify the authority of requesting representatives.

Requests for Third-Party recovery of Subscriber keys must include validation of the individual's authority to act on behalf of the requesting organization.

3.2.3. Authentication of Individual Identity

For each certificate issued, the CA must authenticate the identity of the individual requester.

3.2.3.1. *Authentication of Human Subscribers*

Procedures used by agencies to authenticate the identity of their own personnel and affiliates may be more stringent than that set forth below. When this is the case, the agency procedures for authentication of the identity of personnel must apply in addition to the requirements in this section.

The RA must ensure that the Applicant's identity information is verified.

At a minimum, procedures for employees must include the following steps:

1. Verify that a request for certificate issuance to the Applicant was submitted by agency management.
2. Verify Applicant's employment through use of official agency records.
3. Establish Applicant's identity by in-person or supervised remote¹ proofing before the RA or trusted agent, as follows:
 - a. The Applicant presents a government-issued form of identification (e.g., an Agency ID badge, a passport, or driver's license) as proof of identity, and
 - b. The RA examines the presented credential for biometric data that can be linked to the Applicant (e.g., a photograph on the credential itself or a securely linked photograph of Applicant), and
 - c. The credential presented in step 3a above must be verified by the RA for currency and legitimacy (e.g., the agency ID is verified as valid). Typically, this is accomplished by querying a database maintained by the organization that issued the credential, but other equivalent methods may be used.
4. Record and maintain a biometric of the Applicant (e.g., a photograph or fingerprint) by the RA or CA. (Handwritten signatures and other behavioral characteristics are not accepted as biometrics for the purposes of this policy.) This establishes an audit trail for dispute resolution.

For contractors and other affiliated personnel, the procedures must include the following steps:

1. Verify that a request for certificate issuance to the Applicant was submitted by an authorized sponsoring agency employee (e.g., contracting officer or contracting officer's technical representative).
2. Verify sponsoring agency employee's identity and employment as follows:
 - a. A digitally signed request from the sponsoring agency employee, verified by a currently valid employee signature certificate issued by an agency CA, may be accepted as proof of both employment and identity,
 - b. Authentication of the sponsoring agency employee with a valid employee PIV-authentication certificate issued by the agency may be accepted as proof of both employment and identity, or
 - c. In-person or supervised remote identity proofing of the sponsoring agency employee may be established before the registration authority as specified in employee authentication above and employment validated through use of the official agency records.

¹ The minimum requirements associated with supervised remote identity proofing are described in NIST SP 800-63A, *Digital Identity Guidelines: Enrollment and Identity Proofing*, Section 5.3.3. In addition, the supervised remote process must have the capability of capturing an approved biometric.

3. Establish Applicant's identity by in-person or supervised remote proofing before the registration authority or trusted agent, as follows:
 - a. The Applicant presents a government-issued form of identification (e.g., an Agency ID badge, a passport, or driver's license) as proof of identity, and
 - b. The RA examines the presented credential for biometric data that can be linked to the Applicant (e.g., a photograph on the credential itself or a securely linked photograph of Applicant), and
 - c. The credential presented in step 3a above must be verified by the RA for currency and legitimacy (e.g., the agency ID is verified as valid). Typically, this is accomplished by querying official records maintained by the organization that issued the credential.
4. Record and maintain a biometric of the Applicant (e.g., a photograph or fingerprint) by the RA or CA. (Handwritten signatures and other behavioral characteristics are not accepted as biometrics for the purposes of this policy.) This establishes an audit trail for dispute resolution.

In the event an Applicant is denied a credential based on the results of the identity proofing process, the sponsoring agency must provide a mechanism for appeal or redress of the decision.

Additionally, the RA must record the process that was followed for issuance of each certificate. The process documentation and authentication requirements must include the following:

- The identity of the person performing the authentication and either:
 - A signed declaration by that person that he or she verified the identity of the Applicant using the format set forth at [28 U.S.C. 1746] (declaration under penalty of perjury); or
 - An auditable record identifying the person performing the identification and recording the assertion that he or she verified the identity of the Applicant.
- Unique identifying number(s) from the ID(s) of the Applicant, or a facsimile of the ID(s);
- The biometric of the Applicant;
- The date and time of the verification; and either:
 - An auditable record indicating the applicant accepted the certificate; or
 - A declaration of identity signed by the Applicant using a handwritten signature or appropriate digital signature and performed in the presence of the person performing the identity authentication, using the format set forth at [28 U.S.C. 1746] (declaration under penalty of perjury).

For certificates issued under id-fpki-common-authentication, id-fpki-common-pivi-authentication, id-fpki-common-pivi-cardAuth, and id-fpki-common-cardAuth, identity must be verified in accordance with the requirements specified for issuing PIV in Section 2.7 of [FIPS 201].

At id-fpki-common-High, id-fpki-common-authentication, and id-fpki-common-pivi-authentication, the Applicant must appear at the RA in person or via supervised remote.

For id-fpki-common-policy and id-fpki-common-hardware, RAs may accept authentication of an Applicant's identity attested to and documented by a trusted agent, assuming agency identity requirements are otherwise satisfied. Authentication by a trusted agent does not relieve the RA of its responsibility to verify required procedures were followed as described above.

For certificates issued under id-fpki-common-derived-pivAuth-hardware and id-fpki-common-derived-pivAuth, identity must be verified in accordance with the requirements specified for issuing derived credentials in [SP 800-157]. At id-fpki-common-derived-pivAuth-hardware, the Applicant must appear at the RA in person or via supervised remote.

The RA or CA must:

- 1) Verify that the request for certificate issuance to the Applicant was submitted by an authorized agency employee.
- 2) Use the PKI-AUTH authentication mechanism from Section 6 of [FIPS 201] to verify that the PIV Authentication certificate on the Applicant's PIV credential is valid and that the Applicant is in possession of the corresponding private key.
- 3) Maintain a copy of the Applicant's PIV Authentication certificate.

Seven days after issuing the derived credential, the CA should recheck the revocation status of the PIV Authentication certificate. This step can detect use of a compromised PIV credential to obtain a derived credential.

For certificates issued under id-fpki-common-derived-pivAuth-hardware, the Applicant must appear in person or via supervised remote to present the PIV credential and perform the PKI-AUTH authentication mechanism. The RA must perform a one-to-one comparison of the Applicant against biometric data stored on the PIV credential, in accordance with [SP 800-76], and must record and maintain the biometric sample used to validate the Applicant.

In cases where a 1:1 biometric match against the biometrics available on the PIV credential or in the chain-of-trust, as defined in [FIPS 201] is not possible:

- 1) The Applicant must present a government-issued form of identification (e.g., a passport or driver's license) in addition to the PIV credential, and
- 2) The RA must examine the presented credentials for biometric data that can be linked to the Applicant (e.g., a photograph on the credential itself or a securely linked photograph of the Applicant), and

The process documentation and authentication requirements must include the following:

- The identity of the person performing the authentication and either:
 - A signed declaration by that person that he or she verified the identity of the Applicant using the format set forth at [28 U.S.C. 1746] (declaration under penalty of perjury); or
 - An auditable record linking the authentication of the person performing the identification to their verification of each Applicant.

- Unique identifying number(s) from second form of identification of the Applicant, or a facsimile of the ID(s);
- The biometric of the Applicant;
- The date and time of the verification;

3.2.3.2. Authentication of Devices

Some computing and communications devices (routers, firewalls, servers, etc.) and software applications will be named as certificate subjects. In such cases, the device must have a human sponsor who is affiliated with the agency under which the certificate is being issued. The sponsor is responsible for providing the following registration information:

- Equipment identification (e.g., serial number) or service name (e.g., DNS name) or unique software application name
- Equipment or software application public keys
- Equipment or software application authorizations and attributes (if any are to be included in the certificate)
- Contact information to enable the CA or RA to communicate with the sponsor when required.

These certificates must be issued only to authorized devices under the subscribing organization's control. In the case a human sponsor is changed, the new sponsor must review the status of each device under his/her sponsorship to ensure it is still authorized to receive certificates. The CPS must describe procedures to ensure that certificate accountability is maintained. See Section 9.6.3 for Subscriber responsibilities.

Before issuing a certificate with a wildcard character (*) in a common name or subject alternative name of type `dNSName`, the CA must establish and follow a documented procedure to ensure that the wildcard does not fall immediately to the left of an agency or organization name, but is qualified down to a unique application, server, or server farm under control of the sponsor's organization (see Section 3.1.1). The device sponsor must demonstrate that the domain name requested is entirely within the namespace to be covered by the wildcard certificate.

The identity of the sponsor must be authenticated by:

- Verification of digitally signed messages sent from the sponsor using a certificate issued under this policy; or
- In-person or supervised remote registration by the sponsor, with the identity of the sponsor confirmed in accordance with the requirements of Section 3.2.3.1.

3.2.3.3. Authentication for Role-Based Certificates

Prior to issuance of a delegated digital signature certificate, authentication of both the role holder and the private key holder is required. This authentication can be performed either through the same procedures for authentication of individual identity (see Section 3.2.3.1), or through the use

of a private key associated with a current certificate, having same or higher assurance, that identifies the individual.

Practice Note: The RA or CA can leverage a digital signature from supporting auditable artifacts (e.g., authorization form or subscriber agreement) to fulfill authentication requirements for role-based certificates.

3.2.4. Non-verified Subscriber Information

All Subscriber information included in certificates must be verified.

3.2.5. Validation of Authority

The CA must validate the requestor's authority to act in the name of the organization before issuing organizational certificates, such as CA certificates, role-based certificates, or content signing certificates.

For example, before issuing role-based certificates, the CA must validate that the individual either holds that role or has been delegated the authority to sign on behalf of the role or person appointed to the role. Before requesting a role-based certificate for delegated digital signature, the RA must receive signed authorization that the individual role holder named in the certificate has authorized the delegation of signing authority to the individual private key holder(s) who will receive the tokens containing the delegated digital signature certificate(s) and private signature key(s).

In accordance with Section 3.2.3.2, all requests for device certificates in the name of an organization, must be digitally signed by the sponsor. In addition, the CPS must specify a process by which an organization identifies the individuals who may request certificates that assert organizational authority. If an organization specifies, in writing, the individuals who may request a certificate, then the CA must not accept any certificate requests that are outside this specification. The CA must provide an Applicant with a list of the organization's authorized certificate requestors upon the Applicant's verified written request.

3.2.6. Criteria for Interoperation

The FPKIPA must determine the interoperability criteria for CAs operating under this policy.

3.3. *IDENTIFICATION AND AUTHENTICATION FOR RE-KEY REQUESTS*

3.3.1. Identification and Authentication for Routine Re-key

CA certificate re-key must follow the same procedures as initial certificate issuance.

PIV subscriber's identity should be established through the use of a current signature key, except that identity must be re-established and biometrics re-collected through an in-person or supervised remote registration at least every twelve years.

In the event a PIV Subscriber's signature key cannot be used, identity may be verified through the use of biometrics on file through the chain of trust defined in [FIPS 201].

For re-key of Human Subscriber certificates issued under id-fpki-common-high, identity may be established through use of current signature key, except that identity must be established through an in-person registration process at least once every three years from the time of initial registration.

For id-fpki-common-policy, id-fpki-common-hardware, id-fpki-common-authentication, id-fpki-common-pivi-authentication, id-fpki-common-derived-pivAuth, and id-fpki-common-derived-pivAuth-hardware, a Human Subscriber's identity may be established through use of current signature key, except that identity must be re-established through an in-person or supervised remote registration process at least once every twelve years from the time of initial registration.

For re-key of Subscriber certificates issued under id-fpki-common-derived-pivAuth and id-fpki-common-derived-pivAuth-hardware, the department or agency must verify that the Subscriber is eligible to have a PIV credential (i.e., PIV credential is not terminated).

For re-key of Subscriber certificates issued under id-fpki-common-derived-pivAuth-hardware, identity must be established via mutual authentication between the issuer and the cryptographic module containing the current key, if the new key will be stored in the same cryptographic module as the current key. Identity must be established through the initial registration process per Section 3.2 if the new key will be stored in a different cryptographic module than the current key.

For Device Subscribers, identity may be established through the use of the device's current signature key or the signature key of the device's human sponsor.

3.3.2. Identification and Authentication for Re-key after Revocation

In the event of certificate revocation, issuance of a new certificate must require that the Applicant go through the initial registration process per Section 3.2 above, unless identity can be verified through the use of biometrics on file through the chain of trust defined in [FIPS 201].

3.4. IDENTIFICATION AND AUTHENTICATION FOR REVOCATION REQUEST

Revocation requests must be authenticated. Note that revocation requests may be digitally signed using a certificate's private key, regardless of whether or not the private key has been compromised.

3.5. IDENTIFICATION AND AUTHENTICATION FOR KEY RECOVERY REQUESTS

3.5.1. Third-Party Requestor Authentication

This section addresses the requirements for authentication of a Third-Party Requestor, i.e., a Requestor other than the Subscriber themselves. The requirements for authentication, when the Requestor is the Subscriber, are addressed in Section 3.3.1 or Section 3.2.3.1.

Identity authentication must be commensurate with the assurance level of the certificate associated with the key being recovered. Identity must be established using one of the following methods:

- Procedures specified in Section 3.2.3 for authentication of an individual identity during initial registration for the specified certificate policy assurance level (an assurance level equal to or greater than the assurance level of the certificate whose corresponding private key is being recovered).
- Certificate-based authentication (e.g., digitally signed e-mail or client-authenticated TLS) that can be verified using current, valid (i.e., un-revoked) public key certificates at the requested certificate policy assurance level (an assurance level equal to or greater than the assurance level of the certificate whose corresponding private key is being recovered).

The KRA or KRO must verify the identity and authorization of the Requestor prior to initiating the key recovery request.

3.5.2. Subscriber Authentication

The Subscriber identity must be established as specified in Section 3.3.1 above. Alternatively, if the authentication cannot be verified using the public key certificates issued by the associated PKI and for at least the given certificate policy assurance level, then the identity validation can use the steps outlined in Section 3.2.3.1.

For automated self-recovery, the Subscriber must be authenticated to the KED using a valid public key certificate. The assurance level of the Subscriber certificate must be equal to or greater than that of the certificate whose corresponding private key is being recovered.

3.5.3. KRA Authentication

The KRA must authenticate to the KED or DDS directly or using a public key certificate issued by the associated PKI. The assurance level of the certificate must be the same as or greater than that of the certificate whose corresponding private key is being recovered and must meet the requirements of an RA credential.

3.5.4. KRO Authentication

The KRO must authenticate to the KRA using a public key certificate issued by the associated PKI. The assurance level of the certificate must be the same as or greater than that of the certificate whose corresponding private key is being recovered and must meet the requirements of an RA credential.

3.5.5. Data Decryption Server Authentication

The DDS must authenticate to the KED directly using a public key certificate issued by the associated PKI. The assurance level of the certificate must be the same as or greater than that of the highest assurance level encryption certificates issued by the associated PKI.

4. CERTIFICATE LIFE-CYCLE OPERATIONAL REQUIREMENTS

4.1. CERTIFICATE APPLICATION

The Certificate application process must provide sufficient information to:

- Establish the Applicant's authorization by the employing or sponsoring agency to obtain a certificate. See Section 3.2.3 for requirements.
- Establish and record the identity of the Applicant. See Section 3.2.3 for requirements.
- Obtain the Applicant's public key and verify the Applicant's possession of the private key. See Section 3.2.3 for requirements.
- Verify the information included in the certificate.

These steps may be performed in any order, but all must be completed before certificate issuance.

4.1.1. Who Can Submit a Certificate Application

Type of Certificate	Who can submit an application?
CA and Delegated OSCP Responder Certificates	Authorized representative of the CA
Human Subscriber Certificate	An authorized agency official, the Applicant, or a Trusted Agent on behalf of the Applicant
Device Certificate	The human sponsor of the device

4.1.2. Enrollment Process and Responsibilities

All communications supporting the certificate application and issuance process must be authenticated and protected from modification. Communications may be electronic or out-of-band.

Any electronic communication of shared secrets must be protected.

Where electronic communications are used, cryptographic mechanisms commensurate with the strength of the public/private key pair must be used.

Out-of-band communications must protect the confidentiality and integrity of the data.

Subscribers are responsible for providing accurate information on their certificate applications.

4.2. CERTIFICATE APPLICATION PROCESSING

Information in certificate applications must be verified as accurate before certificates are issued. Each CPS must specify procedures to verify information in certificate applications.

4.2.1. Performing Identification and Authentication Functions

The identification and authentication of the Subscriber must meet the requirements specified for Subscriber authentication as specified in Sections 3.2 and 3.3 of this CP.

4.2.2. Approval or Rejection of Certificate Applications

The FPKIPA may approve or reject requests for certificates from the Federal Common Policy CA.

Subscriber certificate approval or rejection is at the discretion of the Agency.

CAs must reject a certificate request if the requested public key has a known weak private key.

Public key parameters generation and quality checking must be conducted in accordance with [NIST SP 800-89]. Key validity must be confirmed in accordance with [NIST SP 800-56A].

4.2.3. Time to Process Certificate Applications

Certificate applications must be processed and a certificate issued within 90 days of identity verification.

4.3. *CERTIFICATE ISSUANCE*

4.3.1. CA Actions During Certificate Issuance

Upon receiving the request, the CAs/RAs will:

- Verify the identity of the requestor.
- Verify the authority of the requestor and the integrity of the information in the certificate request.
- Build and sign a certificate if all certificate requirements have been met (in the case of an RA, have the CA sign the certificate).
- Make the certificate available to the Subscriber after confirming that the Subscriber has formally acknowledged the obligations described in Section 9.6.3.

The certificate request may already contain a certificate built by either the RA or the Subscriber. This certificate will not be signed until all verifications and modifications, if any, have been completed to the CA's satisfaction.

All attribute information received from a prospective Subscriber must be verified before inclusion in a certificate.

4.3.2. Notification to Subscriber by the CA of Issuance of Certificate

CAs operating under this policy must inform the Subscriber (or other certificate subject) of the creation of a certificate and make the certificate available to the Subscriber. For device certificates, the CA must inform the human sponsor.

4.4. CERTIFICATE ACCEPTANCE

Before Human Subscribers can use their private keys, they must accept the responsibilities defined in Section 9.6.3 by accepting the Subscriber agreement.

4.4.1. Conduct Constituting Certificate Acceptance

For CA certificates issued by the Federal Common Policy CA, failure to object to the certificate or its contents constitutes acceptance of the CA certificate.

For certificates issued to Subscribers, a signed Subscriber agreement or auditable record of acceptance constitutes acceptance of the certificates.

4.4.2. Publication of the Certificate by the CA

As specified in Section 2.1, all CA certificates must be published in repositories.

Certificates that contain the FASC-N and/or UUID in the subject alternative name extension, such as PIV Authentication Certificates, must not be distributed via public repositories (e.g., via LDAP or HTTP). This policy makes no other stipulation regarding publication of Subscriber certificates.

4.4.3. Notification of Certificate Issuance by the CA to Other Entities

The FPKIPA must be notified at least two weeks prior to issuance of a CA certificate. In addition, notification must be provided to the FPKIPA when the CA certificate is published.

4.5. KEY PAIR AND CERTIFICATE USAGE

4.5.1. Subscriber Private Key and Certificate Usage

The intended scope of usage for a private key is specified through certificate extensions, including the key usage and extended key usage extensions, in the associated certificate.

4.5.2. Relying Party Public key and Certificate Usage

Common Policy-issued certificates specify restrictions on use through certificate extensions, including the basic constraints and key usage extensions. CAs provide certificate status information. Relying parties should process certificate and status information as specified in [X.509] when relying on Common Policy certificates.

4.6. CERTIFICATE RENEWAL

Renewing a certificate means creating a new certificate with a new serial number where all certificate subject information, including the subject public key and subject key identifier, remain unchanged.

The new certificate may have an extended validity period and may include new issuer information (e.g., different CRL distribution point, AIA and/or be signed with a different issuer key).

Once renewed, the old certificate may or may not be revoked but must not be reused for requesting further renewals, re-keys, or modifications.

4.6.1. Circumstance for Certificate Renewal

Subscriber certificates issued under this policy must not be renewed, except during recovery from CA key compromise (see Section 5.7.3). In such cases, the renewed certificate must expire as specified in the original Subscriber certificate.

CA certificates and Delegated OCSP responder certificates may be renewed so long as the aggregated lifetime of the private key does not exceed the requirements specified in Section 6.3.2.

4.6.2. Who May Request Renewal

For the Federal Common Policy CA, the FPKIMA may request renewal of CA certificates it issues.

For other CA certificates and Delegated OCSP responder certificates, the corresponding operating authority may request renewal.

4.6.3. Processing Certificate Renewal Requests

When a CA re-keys, it may renew the certificates it has issued.

When certificates are renewed as a result of CA key compromise, as described in Section 4.6.1, the CA or RA must verify all certificates issued since the date of compromise were issued appropriately. If the certificate cannot be verified, then it must not be renewed.

4.6.4. Notification of New Certificate Issuance to Subscriber

As specified in Section 4.3.2.

4.6.5. Conduct Constituting Acceptance of a Renewal Certificate

For certificates issued by the Federal Common Policy CA, failure to object to the renewal of the certificate or its contents constitutes acceptance of the certificate.

For all other CAs operating under this policy, no stipulation.

4.6.6. Publication of the Renewal Certificate by the CA

All CA certificates must be published as specified in Section 4.4.2.

This policy makes no stipulation regarding publication of Subscriber certificates, except as noted in Section 9.4.3.

4.6.7. Notification of Certificate Issuance by the CA to Other Entities

As specified in Section 4.4.3.

4.7. CERTIFICATE RE-KEY

Re-key is identical to renewal except the new certificate must have a different subject public key and serial number.

Once re-keyed, the old certificate may or may not be revoked, but must not be reused for requesting further renewals, re-keys, or modifications.

4.7.1. Circumstance for Certificate Re-key

Circumstances requiring certificate re-key include nearing the maximum usage period of a private key, certificate expiration, loss or compromise, issuance of a new hardware token, and hardware token failure.

Section 6.3.2 establishes maximum usage periods for private keys for both CAs and Subscribers.

4.7.2. Who May Request Certification of a New Public Key

For CA certificates and Delegated OCSP responder certificates, the corresponding operating authority may request re-key of its own certificate.

Subscribers with a currently valid certificate may request re-key of the certificate. CAs and RAs may request certification of a new public key on behalf of a Subscriber. The human sponsor of a device may request re-key of the device certificate.

4.7.3. Processing Certificate Re-keying Requests

Subscribers must identify themselves for the purpose of re-keying as required in Section 3.3.

The CA or RA must verify the information provided prior to issuing the new certificate as specified in Section 4.3.

Digitally signed Subscriber re-key requests must be validated before the re-key requests are processed.

4.7.4. Notification of New Certificate Issuance to Subscriber

As specified in Section 4.3.2.

4.7.5. Conduct Constituting Acceptance of a Re-keyed Certificate

For certificates issued by the Federal Common Policy CA, failure to object to the certificate or its contents constitutes acceptance of the certificate.

For all other CAs operating under this policy, no stipulation.

4.7.6. Publication of the Re-keyed Certificate by the CA

All CA certificates must be published as specified in Section 4.4.2.

This policy makes no stipulation regarding publication of Subscriber certificates, except as noted in Section 9.4.3.

4.7.7. Notification of Certificate Issuance by the CA to Other Entities

As specified in Section 4.4.3.

4.8. CERTIFICATE MODIFICATION

Modifying a certificate means creating a new certificate that has the same or a different key and a different serial number, and that differs in one or more other fields from the old certificate. Once modified, the old certificate may or may not be revoked, but must not be reused for requesting further renewals, re-keys, or modifications.

4.8.1. Circumstance for Certificate Modification

CA certificates and Delegated OCSP responder certificates whose characteristics have changed (e.g., assert new policy OID) may be modified.

A certificate associated with a Subscriber whose characteristics have changed (e.g., name change due to marriage) may be modified.

4.8.2. Who May Request Certificate Modification

For CA certificates and Delegated OCSP responder certificates, the corresponding operating authority may request modification.

Subscribers with a currently valid certificate may request modification of the certificate. The human sponsor of a device may request modification of the device certificate. CAs and RAs may request certificate modification on behalf of a Subscriber.

4.8.3. Processing Certificate Modification Requests

A modified certificate may use the same or a different subject public key as the original certificate, depending on issuance constraints. However, if the same key is used, certificate operational periods and key lifetimes as defined in Section 6.3.2 continue to apply.

Proof of all subject information changes (e.g., name changes due to marriage) must be provided to the RA or other designated agent.

The CA or RA must verify the information provided prior to issuing the new certificate as specified in Section 4.3.

If an individual's authorizations or privileges change, such that the modified certificate indicates a reduction in privileges and authorizations, the old certificate must be revoked.

If the modified certificate is issued with a new (different) public key, the additional requirements specified in Section 4.7.3 must also apply.

4.8.4. Notification of New Certificate Issuance to Subscriber

As specified in Section 4.3.2.

4.8.5. Conduct Constituting Acceptance of Modified Certificate

For certificates issued by the Federal Common Policy CA, failure to object to the certificate or its contents constitutes acceptance of the certificate.

For all other CAs operating under this policy, no stipulation.

4.8.6. Publication of the Modified Certificate by the CA

All CA certificates must be published as specified in Section 4.4.2.

This policy makes no stipulation regarding publication of Subscriber certificates, except as noted in Section 9.4.3.

4.8.7. Notification of Certificate Issuance by the CA to Other Entities

As specified in Section 4.4.3.

4.9. *CERTIFICATE REVOCATION AND SUSPENSION*

Revocation requests must be authenticated. Requests to revoke a certificate may be authenticated using that certificate's public key, regardless of whether or not the associated private key has been compromised.

Certificate suspension for CA certificates is prohibited by this policy. However, the use of certificate suspension for Subscriber certificates is permitted.

For CAs operating under this policy, the FPKIPA must be notified at least two weeks prior to the revocation of a CA certificate, whenever possible. For emergency revocation, CAs must follow the notification procedures in Section 5.7.

4.9.1. Circumstances for Revocation

A certificate must be revoked when the binding between the subject and the subject's public key defined within the certificate is no longer considered valid. Examples of circumstances that invalidate the binding are:

- Identifying information or affiliation components of any names in the certificate becomes invalid. Examples include:
 - Subscriber no longer affiliated with sponsoring agency
 - A wild card certificate has been issued with a name where PKI Sponsor does not exercise control of the entire namespace associated with the wild card certificate.
- Privilege attributes asserted in the Subscriber's certificate are reduced.
- The Subscriber can be shown to have violated the stipulations of its Subscriber agreement.
- There is reason to believe the private key has been compromised.
- The Subscriber or other authorized party (as defined in the CPS) asks for his/her certificate to be revoked.

- The failure of a CA to adequately adhere to the requirements of this CP or the approved CPS.

If it is determined that revocation is required, the associated certificate must be revoked and placed on the CRL. Revoked certificates must be included on all new publications of the certificate status information until the certificates expire.

If it is determined that a private key used to authorize the issuance of one or more certificates may have been compromised, all certificates directly or indirectly authorized by that private key since the date of actual or suspected compromise must be revoked or must be verified as appropriately issued.

4.9.2. Who Can Request Revocation

A CA may summarily revoke certificates it has issued. A written notice and brief explanation for the revocation must subsequently be provided to the Subscriber.

A Subscriber or sponsor of device certificates may request revocation of their own certificates.

The RA or other authorized agency officials may request the revocation of a Subscriber's certificate.

The CA must provide Subscribers, Relying Parties, Application Software Suppliers, and other third parties with clear instructions for reporting suspected private key compromise, certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to certificates. The CA must publicly disclose the instructions through a readily accessible online means.

The FPKIPA can request revocation of any CA certificate issued under this CP.

4.9.3. Procedure for Revocation Request

A request to revoke a certificate must identify the certificate to be revoked, explain the reason for revocation, and allow the request to be authenticated (e.g., digitally or manually signed). The steps involved in the process of requesting a certificate revocation must be detailed in the CPS.

Where Subscribers use hardware tokens, revocation is optional if all the following conditions are met:

- the revocation request was not for key compromise;
- the hardware token does not permit the Subscriber to export the signature private key;
- the Subscriber surrenders the token to an authorized individual (e.g., supervisor, human resources, RA, or CA representative);
- the token was zeroized or destroyed promptly upon surrender;
- the token has been protected from malicious use between surrender and zeroization or destruction.

In all other cases, revocation of the certificates is mandatory. Even where all the above conditions have been met, revocation of the associated certificates is recommended.

4.9.4. Revocation Request Grace Period

There is no grace period for revocation under this policy.

4.9.5. Time within which CA must Process the Revocation Request

CAs will revoke subscriber certificates as quickly as practicable upon receipt of an authenticated revocation request. Revocation requests must be processed before the next required CRL issuance as specified in Section 4.9.7, excepting those requests received within two hours of the next required CRL issuance. Revocation requests received within two hours of CRL issuance must be processed before the following CRL is published.

Routine CA certificate revocation must be completed within an agreed time following receipt of an authenticated revocation request. If the revocation is due to a compromise or emergency, the time to revoke must adhere to the requirements of Section 4.9.12.

The CA must maintain a continuous 24x7 ability to respond internally to high-priority problem reports, and where appropriate, forward such a complaint to law enforcement authorities, and/or revoke a certificate that is the subject of such a complaint.

4.9.6. Revocation Checking Requirements for Relying Parties

Relying parties are expected to verify the validity of certificates as specified in [RFC 5280].

Practice Note: Use of revoked certificates could have damaging or catastrophic consequences. The matter of how often new revocation data should be obtained is a determination to be made by the relying party, considering the risk, responsibility, and consequences for using a certificate whose revocation status cannot be guaranteed.

4.9.7. CRL Issuance Frequency

CRLs must be issued periodically, even if there are no changes to be made, to ensure timeliness of information. Certificate status information may be issued more frequently than the issuance frequency described below.

Certificate status information must be published not later than the next scheduled update. This will facilitate the local caching of certificate status information for off-line or remote operation.

	Maximum Interval for Routine CRL Issuance			
	Online CA		Offline CA*	
	Interval	nextUpdate	Interval	nextUpdate
Shared Service Provider CAs	18 hours	48 hours	35 days	37 days

All other CAs	18 hours	180 hours	35 days	37 days
---------------	----------	-----------	---------	---------

*An offline CA may incorporate locally attached network equipment such as an HSM or storage array. The CA system and any such locally attached network equipment must be completely isolated (air-gapped) from all other networks and computing systems. With the exception of Content Signers, offline CAs must not issue certificates to Subscribers, as defined in Section 1.3.6.

Circumstances related to emergency CRL issuance are specified in Section 4.9.12.

4.9.8. Maximum Latency for CRLs

For CAs that operate online, CRLs must be published within 4 hours of generation.

For CAs that operate offline, pre-generated CRLs intended for publication more than 4 hours after generation must be protected in the same manner as the CA. All pre-generated CRLs not yet published must be securely destroyed whenever the CA revokes any certificate. The CPS must describe protections and processes used for generation and protection of any pre-generated CRLs.

Furthermore, each CRL must be published no later than the time specified in the nextUpdate field of the previously issued CRL.

Note: If pre-generation of CRLs is implemented, the thisUpdate field will be the date of generation and the nextUpdate value will be no more than 37 days beyond the date of planned publication.

4.9.9. On-line Revocation/Status Checking Availability

CAs must support on-line status checking via OCSP [RFC 6960] for Subscriber certificates. Since some relying parties cannot accommodate on-line communications, all CAs must support CRLs.

OCSP services must be designed and implemented so as to provide 99% availability overall and limit scheduled down-time to 0.5% annually, with resources sufficient to provide a response time of ten (10) seconds or less under normal operating conditions.

Certificate status information distributed via OCSP must be updated and available to relying parties to meet or exceed the requirements for CRL issuance.

The CA must operate and maintain its CRL capability with resources sufficient to provide a response time of ten (10) seconds or less under normal operating conditions.

4.9.10. On-line Revocation Checking Requirements

On-line revocation status checking is optional for relying parties. For certificates where revocation status online checking is not available, CRLs must be used.

4.9.11. Other Forms of Revocation Advertisements Available

A CA may also use other methods to publicize the certificates it has revoked. Any alternative method must meet the following requirements:

- The alternative method must be described in the CA's approved CPS;
- The alternative method must provide authentication and integrity services commensurate with the assurance level of the certificate being verified.
- The alternative method must meet the issuance and latency requirements for CRLs stated in Sections 4.9.7 and 4.9.8.

4.9.12. Special Requirements Related to Key Compromise

When a CA certificate is revoked a CRL must be issued within 18 hours of notification.

When a CA certificate issued under id-fpki-common-high is revoked or Subscriber certificate issued under id-fpki-common-high is revoked because of compromise or suspected compromise of a private key, a CRL must be issued within six (6) hours of notification.

4.9.13. Circumstances for Suspension and Restoration

For CA certificates, suspension is not permitted.

CAs may support certificate suspension and restoration for Subscriber certificates. If suspension and restoration are supported by the CA, the CPS must describe under what circumstances and provide details as specified in Sections 4.9.14, 4.9.15 and 4.9.16.

Practice Note: Certificate suspension should only be used in circumstances where there is a reasonable possibility that the certificate will need to be restored (e.g., suspension while background investigation outcome is appealed). It is not recommended to use certificate suspension as a mechanism to enforce access controls on a temporary basis or to circumvent account deprovisioning. Additionally, a certificate must be permanently revoked if it meets the circumstances stated in Section 4.9.1.

4.9.14. Who Can Request Suspension and Restoration

For CAs that support suspension and restoration, those authorized to request suspension and restoration of a certificate must be identified.

4.9.15. Procedure for Suspension and Restoration Requests

For CAs that support suspension and restoration, all suspended certificate serial numbers must be populated on a full CRL within a timeframe specified in Section 4.9.7. The reason code CRL entry extension shall be populated with "certificateHold." Restored certificate serial numbers must not be present on the next full CRL published by the CA.

Practice Note: A certificate is considered restored only if its status at the time of CRL

generation is neither suspended nor revoked.

A request to suspend or restore a certificate must include:

- authentication of the requestor,
- identification of the certificate to be suspended or restored, and
- explanation of the reason for suspension or restoration.

If a CA or CMS product conducts certificate suspensions and restorations in an automated fashion (e.g., without a formal request outlined above), the circumstances or parameters associated with those automated suspensions and restorations must be documented in a CPS.

If a subscriber is requesting restoration of their suspended certificate, the identity of the subscriber must be re-established before restoring the certificate. The subscriber's identity may be re-established using processes defined in Section 3.2.3.1, through the use of biometrics on file through the chain of trust defined in [FIPS 201], or by the use of another private signature key of equivalent or greater assurance level issued to the subscriber.

The private key associated with any suspended certificate must not be used to authenticate the identity of the certificate subject.

4.9.16. Limits on Suspension Period

For CAs that support suspension, the maximum time period a certificate may be suspended must be specified. The CPS must describe in detail how this maximum suspension period is enforced. If the subscriber has not removed the certificate from hold (suspension) within that period, the certificate must be revoked. Certificates must not be published on a CRL with a reason code of "certificateHold" beyond the expiration date of the certificate.

Practice Note: In order to mitigate the threat of unauthorized person removing the certificate from hold, the identity of the RA or authorized individual removing the suspension should be authenticated using a mechanism equivalent or higher than the assurance level of the certificate being unsuspended.

4.10. CERTIFICATE STATUS SERVICES

See Section 4.9.9 for OCSP.

If additional certificate status services are supported, they must be described in the CPS.

4.10.1. Operational Characteristics

Where applicable this must be described in the CPS.

4.10.2. Service Availability

Where applicable this must be described in the CPS.

4.10.3. Optional Features

Where applicable this must be described in the CPS.

4.11. END OF SUBSCRIPTION

No stipulation.

4.12. KEY ESCROW AND RECOVERY

4.12.1. Key Escrow and Recovery Policy and Practices

CA private keys are never escrowed.

Human Subscriber key management keys must be escrowed to provide key recovery. Escrowed keys must be maintained within an online KED for a minimum of one year after the expiration of the associated public key certificate.

Practice Note: When considering allowing Third-Party recovery of id-fpki-common-hardware key management keys to software, Entities should carefully consider the risk of unauthorized decryption of data encrypted by the recovered keys and should define which scenarios this risk is acceptable in their CPS, RPS, or KRPS, see Section 6.2.1 for further details.

Subscriber signature keys are never escrowed.

4.12.1.1. Key Escrow Process and Responsibilities

Human subscriber private keys (i.e., decryption private keys) associated with a key management certificate must be securely escrowed by the KED. The CA must ensure that the keys are escrowed successfully prior to issuance of the key management certificates.

Subscriber private keys must be protected during transit and storage using cryptography at least as strong as the key being escrowed.

Subscribers must be notified that the private keys associated with their encryption certificates will be escrowed.

4.12.1.2. Key Recovery Process and Responsibilities

Communications between the various key recovery participants (KED, DDS, KRA, KRO, Requestor, and Subscriber) must be secured from protocol threats such as disclosure, modification, replay, and substitution. The strength of all cryptographic protocols must be equal to or greater than that of the keys they protect.

During delivery, escrowed keys must be protected against disclosure to any party except the Requestor.

When any mechanism that includes a shared secret (e.g., a password) is used to protect the key in transit, the mechanism must ensure that the Requestor and the transmitting party are the only holders of this shared secret.

Subscribers may use electronic or manual means to request their own escrowed keys from the KRS. The Subscriber may submit the request to the KED, KRA or KRO. If the request is made electronically, the subscriber must digitally sign the request or authenticate to a recovery service using an associated authentication or signature certificate with an assurance level equal to or greater than that of the escrowed key. Manual requests must be made in person, and include proper identity verification by the KRA in accordance with Section 3.2.3.1.

Third-Party Requestors may use electronic or manual means to request the Subscribers' escrowed keys. The Requestor must submit the request to the KRA or KRO. If the request is made electronically, the Requestor must digitally sign the request using a trusted authentication or signature certificate, as determined by the recovering organization, with an assurance level equal to or greater than that of the escrowed key. Manual requests must include proper identity verification by the KRA in accordance with Section 3.2.3.1.

DDSs must use electronic means to request Subscribers' escrowed keys. Requests must be authenticated as specified in Section 3.5.5.

Third party key recovery in and of itself does not require revocation of a subscriber certificate. This does not prohibit Subscribers from revoking their own certificates for any reason.

4.12.1.3. Key Recovery Through KRA

The KRA must provide access to a copy of an escrowed key only in response to a properly authenticated and authorized key recovery request. Such access requires the actions of at least two KRAs. All copies of escrowed keys must be protected using two-person control procedures during recovery and delivery to the authenticated and authorized Requestor. Split key or password procedures are considered adequate two-person controls, provided they comply with technical controls in Section 6.2.2.

Practice Note: A combination of physical, procedural and technical security controls can be used to enforce continuous two-person control during recovery and delivery of escrowed keys. The KRS should be designed to maximize the ability to enforce two-person control technically.

The KRA is not required to notify subscribers of a third-party key recovery.

Practice Note: Subscriber notification of key management key recovery is not necessary and may be prohibited in certain use cases (e.g., Counterintelligence or Law Enforcement investigations).

4.12.1.4. Automated Self-Recovery

A current Subscriber's escrowed keys may be provided directly to the Subscriber without imposition of two-person control requirements. The KED must only provide escrowed keys to current Subscribers without two-person control upon:

- Verifying that the authenticated identity of the Requestor is the same as the Subscriber associated with the escrowed keys being requested;
- Sending notification to the Subscriber of all attempts (successful or unsuccessful) to recover the Subscriber's escrowed keys that are made by entities claiming to be the subscriber. If the KED does not have information (e.g., an e-mail address) necessary to send notification to the Subscriber of a key recovery request, then the KED must not provide the Subscriber with the requested key material using the automated recovery process

Practice Note: Where possible, the e-mail address will be from the subject alternative name field of the certificate being recovered.

- Ensuring that the escrowed keys are being sent only to the authenticated Subscriber associated with the escrowed keys; and
- Ensuring that the escrowed keys are encrypted during transmission using cryptography of equal or greater strength than provided by the escrowed keys.

4.12.1.5. Key Recovery During Token Issuance

When a Subscriber (individual and/or group/role sponsor or member) is issued a new certificate on a hardware token, private key management keys for the Subscriber may be recovered as part of the issuance process as long as the KED uses secure means, such as Global Platform Secure Channel Protocol, to inject the key history onto the hardware token directly.

The hardware token must meet FIPS 140 Level 2 hardware requirements and the key must be injected into the token such that it is not thereafter exportable.

4.12.1.6. Key Recovery by Data Decryption Server

A DDS must be under two-person control, as is required for any CA or KED. A DDS is permitted to automatically recover keys from the KED. The KED must perform the following activities prior to releasing the key:

- Authenticating the Requestor as a legitimate DDS;
- Verifying that the DDS is authorized to recover the escrowed key for the Issuing Organization to which the key belongs;
- Ensuring that the escrowed keys are protected during transmission using cryptography or other means of equal or greater strength than provided by the escrowed keys.

In order to prevent any individual KRA, KRO or another trusted role from accessing subscriber encryption keys, a combination of physical, procedural and technical security controls must be

used to enforce continuous two-person control on the DDSs. The DDSs must be designed to maximize the ability to enforce two-person control technically.

4.12.1.7. Who Can Submit a Key Recovery Application

Subscribers may request recovery of their own escrowed keys. Key recovery may also be requested by internal Third-Party Requestor permitted by the Issuing Organization policy, as verified by the KRO, and by authorized external Third-Party Requestors (e.g., law enforcement personnel with a court order from a competent court).

4.12.1.8. Requestor Authorization Validation

The KRA or the KRO, as an intermediary for the KRA, must validate the authorization of the Requestor in consultation with Issuing Organization management and/or legal counsel, as appropriate.

Issuing Organizations must determine internal notification requirements for External Third-Party key recovery requests and account for situations where the law requires the KED to release the Subscriber's private key without organizational notification.

Nothing in this document is intended to change the current procedures for obtaining information about individuals in connection with such requests.

4.12.1.9. Subscriber Authorization Validation

Current Subscribers are authorized to recover their own escrowed key material.

4.12.1.10. KRA Authorization Validation

The KED must verify that the KRA has appropriate privileges to obtain the keys for the identified Subscriber's organization.

4.12.1.11. KRO Authorization Validation

The KED or KRA must verify that the KRO is authorized to request keys for the identified Subscriber.

4.12.1.12. Data Decryption Server Authorization Validation

The KED must verify that the DDS recovery request falls within the organizational scope for which the DDS was established.

4.12.2. Session Key Encapsulation and Recovery Policy and Practices

CAs that support session key encapsulation and recovery must identify the document describing the practices in the applicable CPS.

5. FACILITY, MANAGEMENT, AND OPERATIONAL CONTROLS

5.1. PHYSICAL CONTROLS

CA equipment must be protected from unauthorized access while the cryptographic module is installed and activated. The CA must implement physical access controls to reduce the risk of equipment tampering even when the cryptographic module is not installed and activated. CA cryptographic tokens must be protected against theft, loss, and unauthorized use.

All the physical control requirements specified below apply equally to all CAs, and any remote workstations used to administer the CAs except where specifically noted.

5.1.1. Site Location and Construction

The location and construction of the facility housing the CA equipment, as well as sites housing remote workstations used to administer the CAs, must be consistent with facilities used to house high-value, sensitive information. The site location and construction, when combined with other physical security protection mechanisms such as guards, high security locks, and intrusion sensors, must provide robust protection against unauthorized access to the CA equipment and records.

5.1.2. Physical Access

5.1.2.1. Physical Access for CA Equipment

At a minimum, the physical access controls for CA equipment, as well as remote workstations used to administer the CAs, must:

- Ensure that no unauthorized access to the hardware is permitted.
- Ensure that all removable media and paper containing sensitive plain-text information is stored in secure containers.
- Be manually or electronically monitored for unauthorized intrusion at all times.
- Ensure an access log is maintained and inspected periodically.
- Require two-person physical access control to both the cryptographic module and computer systems.

When not in use, removable cryptographic modules, activation information used to access or enable cryptographic modules, and CA equipment must be placed in secure containers.

Activation data must be either memorized or recorded and stored in a manner commensurate with the security afforded the cryptographic module, and must not be stored with the cryptographic module or removable hardware associated with remote workstations used to administer the CA.

A security check of the facility housing the CA equipment or remote workstations used to administer the CAs must occur if the facility is to be left unattended. At a minimum, the check must verify the following:

- The equipment is in a state appropriate to the current mode of operation (e.g., that cryptographic modules are in place when “open,” and secured when “closed,” and for the CA, that all equipment other than the repository is shut down).
- Any security containers are properly secured.
- Physical security systems (e.g., door locks, vent covers) are functioning properly.
- The area is secured against unauthorized access.

A person or group of persons must be made explicitly responsible for making such checks. When a group of persons is responsible, a log identifying the person performing a check at each instance must be maintained. If the facility is not continuously attended, the last person to depart must initial a sign-out sheet that indicates the date and time and asserts that all necessary physical protection mechanisms are in place and activated.

5.1.2.2. *Physical Access for RA Equipment*

RA equipment must be protected from unauthorized access while the cryptographic module is installed and activated. The RA must implement physical access controls to reduce the risk of equipment tampering even when the cryptographic module is not installed and activated. These security mechanisms must be commensurate with the level of threat in the RA equipment environment.

5.1.2.3. *Physical Access for CSS Equipment*

Physical access control requirements for CSS equipment that has signing capability must meet the CA physical access requirements specified in Section 5.1.2.1. CSS equipment that do not have a private signing key and only distribute pre-generated OCSP responses are not required to meet these requirements.

5.1.2.4. *Physical Access for KED Equipment*

Physical access control requirements for KED equipment that store private keys must meet the CA physical access requirements specified in Section 5.1.2.1.

5.1.2.5. *Physical Access for DDS Equipment*

Physical access control requirements for DDS equipment that store or use private keys must meet the CA physical access requirements specified in Section 5.1.2.1.

5.1.2.6. *Physical Access for KRA and KRO Equipment*

KRA and KRO equipment must be protected from unauthorized access while the cryptographic module is installed and activated. The KRA and KRO must implement physical access controls to reduce the risk of equipment tampering even when the cryptographic module is not installed and activated. These security mechanisms must be commensurate with the level of threat in the equipment environment.

5.1.3. Power and Air Conditioning

The CA must have sufficient alternative power supply in the event of a primary power source failure to either maintain CA operations or, at a minimum, prevent loss of data. The repositories

(containing CA certificates, CRLs, and pre-generated OCSP responses) must be provided with uninterrupted power sufficient for a minimum of six (6) hours operation in the absence of commercial power, to maintain availability and avoid denial of service.

5.1.4. Water Exposures

CA equipment must be installed such that it is not in danger of exposure to water (e.g., on tables or elevated floors).

Potential water damage from fire prevention and protection measures (e.g., sprinkler systems) are excluded from this requirement.

5.1.5. Fire Prevention and Protection

The CA must comply with local commercial building codes for fire prevention and protection.

5.1.6. Media Storage

Media must be stored so as to protect them from accidental damage (e.g., water, fire, or electromagnetic) and unauthorized physical access.

5.1.7. Waste Disposal

Sensitive media and documentation that are no longer needed for operations must be destroyed in a secure manner. For example, sensitive paper documentation must be shredded, burned, or otherwise rendered unrecoverable.

5.1.8. Off-Site Backup

CA backups sufficient to recover from system failure must be made on a periodic schedule, and described in a CA's CPS. Backups are to be performed and stored off-site not less than once per week. At least one full backup copy must be stored at an off-site location (separate from CA equipment). Only the latest full backup need be retained. The backup must be stored at a site with physical and procedural controls commensurate to that of the operational CA.

For offline CAs, the backup must be performed each time the system is turned on or once per week, whichever is less frequent.

Requirements for CA private key backup are specified in Section 6.2.4.1.

5.2. *PROCEDURAL CONTROLS*

5.2.1. Trusted Roles

A Trusted Role is one whose incumbent performs functions that can introduce security problems if not carried out properly, whether accidentally or maliciously. The personnel selected to fill these roles must be extraordinarily responsible, or the integrity of the CA will be weakened. The functions performed in these roles form the basis of trust for the entire PKI. Two approaches are taken to increase the likelihood that these roles can be successfully carried out. The first ensures that the person filling the role is trustworthy and properly trained. The second distributes the functions among more than one person, so that any malicious activity would require collusion.

An auditable record must be created identifying when personnel are added or removed from a trusted role, as well as who added or removed them from the role. The individual who authorized the role assignment, or any series of role assignments over a given period of time, must also be traceable via audit and archive records.

The requirements of this policy are defined in terms of four roles, implementing organizations may define additional roles provided the following separation of duties are enforced.

1. Administrator – authorized to install, configure, and maintain the CA, KED or DDS; establish and maintain system accounts; configure audit parameters; and generate PKI component keys.
2. Officer – authorized to request, approve, or perform certificate issuance, revocations, or key recovery, as appropriate.
3. Auditor – authorized to review, maintain, and archive audit logs.
4. Operator – authorized to perform system backup and recovery.

Administrators do not issue certificates to Subscribers.

These four roles are employed at the CA, RA, KED, DDS and CSS locations as appropriate. Separation of duties must comply with Section 5.2.4, and requirements for two-person control with Section 5.2.2, regardless of the titles and numbers of Trusted Roles.

5.2.2. Number of Persons Required per Task

Two or more persons are required for the following tasks:

- CA, KED, or DDS key generation;
- CA signing key activation;
- CA, KED, or DDS private key backup.

Where multiparty control is required, at least one of the participants must be an Administrator. All participants must serve in a Trusted Role as defined in Section 5.2.1. Multiparty control must not be achieved using personnel that serve in the Auditor Trusted Role.

The participation of two KRAs is required for third-party key recovery.

5.2.3. Identification and Authentication for Each Role

An individual must identify and authenticate him/herself before being permitted to perform any actions set forth above for that role or identity.

5.2.4. Roles Requiring Separation of Duties

Individuals may only assume one of the Officer, Administrator, and Auditor roles, but any individual may assume the Operator role. The CA and RA software and hardware must identify and authenticate its users and must ensure that no user identity can assume both the Administrator and Officer roles, assume both the Administrator and Auditor roles, or assume

both the Auditor and Officer roles. For CAs that issue at id-fpki-common-high, the Auditor may not assume any other role. No individual must have more than one identity.

A Trusted Role may perform the same role on the CA, KED, and DDS.

Under no circumstances will a KRA or KRO be an Administrator or Auditor for a KED or DDS.

A Registration Authority (RA) may fill the role of a KRA or KRO. A Trusted Agent (TA), may fill the role of a KRO.

5.3. PERSONNEL CONTROLS

5.3.1. Qualifications, Experience, and Clearance Requirements

All persons filling Trusted Roles must be selected on the basis of loyalty, trustworthiness, and integrity, and must be U.S. citizens. The requirements governing the qualifications, selection and oversight of individuals who operate, manage, oversee, and audit the CA must be set forth in the CPS.

The FPKIMA Program Manager must hold a Top Secret security clearance.

5.3.2. Background Check Procedures

Trusted Roles must receive a favorable adjudication after undergoing a background investigation covering the following areas:

- Employment;
- Education;
- Place of residence;
- Law Enforcement; and
- References.

The period of investigation must cover at least the last five years for each area, excepting the residence check which must cover at least the last three years. Regardless of the date of award, the highest educational degree must be verified.

Adjudication of the background investigation must be performed by a competent adjudication authority using a process consistent with [Executive Order 12968], or equivalent.

5.3.3. Training Requirements

All personnel performing duties with respect to the operation of the CA or RA must receive comprehensive training. Training must be conducted in the following areas:

- CA (or RA) security principles and mechanisms;
- All PKI software versions in use on the CA (or RA) system;
- All PKI duties they are expected to perform;

- Disaster recovery and business continuity procedures; and
- Stipulations of this policy and appropriate CPS.

5.3.4. Retraining Frequency and Requirements

All individuals responsible for PKI roles must be made aware of changes in the CA operation. Any significant change to the operations must have a training (awareness) plan, and the execution of such plan must be documented. Examples of such changes are CA software or hardware upgrade, changes in automated security systems, and relocation of equipment.

Documentation must be maintained identifying all personnel who received training and the level of training completed.

5.3.5. Job Rotation Frequency and Sequence

Job rotation must not violate role separation. All access rights associated with a previous role must be terminated.

All job rotations must be documented. Individuals assuming an auditor role must not audit their own work from a previous role.

5.3.6. Sanctions for Unauthorized Actions

The CA must take appropriate administrative and disciplinary actions against personnel who have performed actions involving the CA or its RAs that are not authorized in this CP, CPSs, or other published procedures.

5.3.7. Independent Contractor Requirements

Contractors fulfilling Trusted Roles are subject to all personnel requirements stipulated in this policy.

PKI vendors who provide any services must establish procedures to ensure that any subcontractors perform in accordance with this policy and the CPS.

5.3.8. Documentation Supplied to Personnel

Documentation sufficient to define duties and procedures for each role must be provided to the personnel filling that role.

5.4. *AUDIT LOGGING PROCEDURES*

The objective of audit log processing is to review all actions to ensure they are made by authorized parties and for legitimate reasons.

At a minimum, audit records must be generated for all events identified in Section 5.4.1 of this policy, and must be available during audit reviews and third-party audits. For CAs operated in a virtual environment, audit records must be generated for all applicable events on application software and all system software layers. Where possible, the audit records must be automatically

collected. Where this is not possible, a logbook, paper form, other physical or electronic mechanism must be used.

Audit record reviews should be performed using an automated process, and must include verification that the logs have not been tampered with, an inspection of log entries, and a root cause analysis for any alerts or irregularities. Implementation and documentation of automated tools must meet the requirements of the CP such that relevant events and anomalies are identified. Reviews may be performed manually for physical or non-electronic records and logs, or when the audit log is small enough to allow for a thorough manual review.

All anomalous events must be analyzed to determine the cause and to ensure that the system is operating correctly.

A record of the review, all significant events, and any actions taken as a result of these reviews must be explained in an audit log summary. This review summary must be retained as part of the long-term archive.

All KED audit records of unsuccessful key recoveries must be analyzed to determine the cause and to ensure that the KRS is operating correctly and securely, and is not vulnerable to unauthorized use.

5.4.1. Types of Events Recorded

All security auditing capabilities of CA operating system and CA applications required by this CP (including the KRS) must be enabled during installation.

At a minimum, each audit record must include the following (either recorded automatically or manually for each auditable event):

- What type of event occurred;
- Date and time when the event occurred;
- Where the event occurred (e.g., on what systems or in what physical locations);
- Source of the event;
- Outcome of the event to include success or failure; and
- Identity of any individuals, subjects, or objects/entities associated with the event

Any request or action requiring the use of a private key controlled by the CA is an auditable event.

If out-of-band processes are used for authorization of certificate issuance, external artifacts from the process (e.g., forms, emails, etc.) must be recorded.

Practice Note: Events related to CA certificate issuance may be different from those related to subscriber certificate issuance

The CA and KRS must record all events identified in the list below, where applicable to the application, environment, or both. Where these events cannot be electronically logged, electronic audit logs must be supplemented with physical logs as necessary.

- **SECURITY AUDIT:**
 - Any changes to the Audit parameters, e.g., audit frequency, type of event audited
 - Any attempt to delete or modify the Audit logs
- **IDENTIFICATION AND AUTHENTICATION:**
 - Platform or CA application level authentication attempts
 - The value of maximum authentication attempts is changed
 - Maximum authentication attempts unsuccessful authentication attempts occur during user login
 - An Administrator unlocks an account that has been locked as a result of unsuccessful authentication attempts
 - An Administrator changes the type of authenticator, e.g., from smart card login to password
- **DATA ENTRY AND OUTPUT:**
 - Any additional event that is relevant to the security of the CA (such as remote or local data entry or data export); must be documented
- **KEY GENERATION:**
 - Whenever the CA generates a key. (Not mandatory for single session or one-time use symmetric keys)
- **PRIVATE KEY LOAD AND STORAGE:**
 - The loading of CA, RA, CSS, CMS, or other keys used by the CA in the lifecycle management of certificates
 - All access to certificate subject private keys retained within the CA for key recovery purposes
- **TRUSTED PUBLIC KEY ENTRY, DELETION AND STORAGE:**
 - Any changes to public keys used by components of the CA to authenticate other components or authorize certificate lifecycle requests (e.g., RA or CMS trust stores)
- **PRIVATE AND SECRET KEY EXPORT:**
 - The export of private and secret keys (keys used for a single session or message are excluded)
- **CERTIFICATE REGISTRATION:**
 - All records related to certificate request authorization, approval and signature, whether generated directly on the CA or generated by a related external system or process. This includes records associated with authentication and authorization of role-based delegated digital signature certificates.

- **CERTIFICATE STATUS CHANGES:**
 - All records including request authorization, approval and execution related to certificate status changes (e.g., revocation, suspension or restoration) whether generated directly on the CA or generated by a related external system or process
- **CA CONFIGURATION:**
 - Any security-relevant changes to the configuration of the CA. The specific configuration items relevant to the environment in which the CA operates must be identified and documented.
- **ACCOUNT ADMINISTRATION:**
 - Roles and users are added or deleted
 - The access control privileges of a user account or a role are modified
- **CERTIFICATE PROFILE MANAGEMENT:**
 - All changes to the certificate profile
- **CERTIFICATE REVOCATION LIST PROFILE MANAGEMENT:**
 - All changes to the certificate revocation list profile
- **MISCELLANEOUS:**
 - Record of an individual being added or removed from a trusted role, and who added or removed them from the role

Practice Note: If multiparty control is implemented via team separation, these records must include team appointment specifics.

- All records of authentication, authorization, recovery, agreement and delivery of key management keys to a key recovery requestor.
- Installation of the operating system
- Installation of the CA
- Installing hardware cryptographic modules
- Removing hardware cryptographic modules
- Destruction of cryptographic modules
- System startup
- Logon attempts to CA applications
- Receipt of hardware / software
- Attempts to set passwords
- Attempts to modify passwords
- Backing up CA internal database
- Restoring CA internal database

- Records of manipulation of critical files (e.g. creation, renaming, moving), critical files will vary between installation, and must be identified in the relevant documentation
- Posting of any material to a repository
- The date and time any CA artifact is posted to a public repository
- Access to CA internal database
- All certificate compromise notification requests
- Loading tokens with certificates
- Shipment and receipt of tokens containing key material, or tokens that allow access to key material (e.g., HSM operator cards)
- Zeroizing tokens
- Re-key of the CA
- Configuration changes to the CA server involving:
 - Hardware
 - Software
 - Operating system
 - Patches
 - Security profiles
- PHYSICAL ACCESS / SITE SECURITY:
 - Personnel access to room housing CA
 - Access to the CA server
 - Known or suspected violations of physical security
- ANOMALIES:
 - Software error conditions
 - Software check integrity failures
 - Equipment failure
 - Electrical power outages
 - Uninterruptible power supply (UPS) failure
 - Network service or access failures that could affect certificate trust
 - Violations of certificate policy
 - Violations of certification practice statement
 - Resetting operating system clock

5.4.2. Frequency of Processing Log

Audit records must be reviewed at least once every month for CAs that issue certificates under this policy. CSS, CMS, IDMS and KRS audit log processing frequency shall align with the CA audit log processing frequency described above.

5.4.3. Retention Period for Audit Log

Audit records must be accessible until reviewed, in addition to specific records being archived as described in Section 5.5.

5.4.4. Protection of Audit Log

System configuration and operational procedures must be implemented together to ensure that only authorized individuals may move or archive audit records and that audit records are not modified before review.

Collection of the audit records from the CA system must be performed by, witnessed by or under the control of trusted roles who are different from the individuals who, in combination, command the CA signature key.

For RA systems, the individual authorized to move or archive records may not hold an RA Trusted Role.

Procedures must be implemented to protect audit records from deletion or destruction before they are reviewed as described in Section 5.4.2. To protect the integrity of audit records, they must be transferred to a backup environment distinct from the environment where the audit records are generated.

5.4.5. Audit Log Backup Procedures

Audit records and audit summaries must be backed up at least monthly.

If audit records are stored locally in the system where the events occur, they must be transferred to a backup environment and protected as described in Section 5.4.4. The backup procedure may be automated or manual, but must occur no less frequently than the audit log review described in Section 5.4.2.

The process for transferring the audit records to the backup environment must be documented.

5.4.6. Audit Collection System (Internal vs. External)

The audit log collection system may or may not be external to the CA system or KRS. Automated audit processes must be invoked at system or application startup, and cease only at system or application shutdown. Audit collection systems must be configured such that security audit data is protected against loss (e.g., overwriting or overflow of automated log files). If an automated audit system has failed, and the integrity of the system or confidentiality of the information protected by the system is at risk, operations must be suspended until the problem has been remedied.

5.4.7. Notification to Event-Causing Subject

There is no requirement to notify a subject that an event was audited. Real-time alerts are neither required nor prohibited by this policy.

5.4.8. Vulnerability Assessments

CAs must perform routine vulnerability assessments of the security controls described in this policy.

Self-assessment of controls and control effectiveness (e.g., FISMA) must be performed in accordance with the frequency determined by the risk rating of the CA.

Automated vulnerability scans, if executed, should be run no less frequently than required by the risk rating of the component.

The methodology, tools and frequency of the vulnerability assessment must be documented.

Practice Note: The audit data should be reviewed by the auditor for events such as repeated failed actions, requests for privileged information, attempted access of system files, requests for escrowed keys, attempted access of escrowed keys, unauthenticated responses, and other suspicious or unusual activity. Auditors should check for continuity of the audit data.

5.5. RECORDS ARCHIVAL

The primary objective of the CA archive is to prove the validity of any certificate (including those revoked or expired) issued by the CA in the event of dispute regarding the use of the certificate.

The primary objective of the KRS archive is reconstruction of key recovery activities, in case of dispute. Examples of disputes may include:

- Validation of key recovery requests
- Validation of the identity of the recipient of an escrowed key;
- Verification of authorization to obtain the escrowed key copy;
- Verification of transfer of custody of escrowed keys to an authorized Requestor; and
- Establishment of the circumstances under which a copy of the escrowed key was provided.

5.5.1. Types of Events Archived

CA archive records must be sufficiently detailed to determine the proper operation of the CA and the validity of any certificate (including those revoked or expired) issued by the CA. At a minimum, the following data must be recorded for archive:

- Certificate Policy
- Certification Practice Statement / Key Recovery Practice Statement
- Contractual obligations and other agreements concerning operations of the CA or KRS
- System and equipment configuration

- Modifications and updates to system or configuration
- All records related to certificate request authorization, approval and signature, whether generated directly on the CA or generated as part of a related external system or process
- All certificates issued and/or published
- Record of re-key
- All records related to certificate status changes (e.g., revocation, suspension, or restoration) whether generated directly on the CA or generated as part of a related external system or process
- Subscriber identity authentication data as per Section 3.2.3
- Documentation of receipt and acceptance of certificates
- Subscriber agreements, including agreements signed by subscribers who are recipients of role-based certificates and keys.
- Documentation of receipt of tokens
- Other data or applications to verify archive contents (e.g., key escrow software)
- Audit summary reports generated by internal reviews and documentation generated during third party audits
- Any changes to the Audit parameters, e.g., audit frequency, type of event audited
- Any attempt to delete or modify the Audit logs
- Whenever the CA generates a key (not mandatory for single session or one-time use symmetric keys)
- All access to certificate subject private keys retained within the CA for key recovery purposes
- Changes to trusted public keys used or published by the CA including certificates used for trust between the CA and other components such as CMS, RA, etc.
- The export of private and secret keys (keys used for a single session or message are excluded)
- The approval or rejection of a certificate status change request
- Record of an individual being added or removed from a trusted role, and who added or removed them from the role
- Evidence of qualification for Trusted Agents and the associated validity period(s) for which they are authorized to act as Trusted Agents
- Destruction of cryptographic modules
- All certificate compromise notifications
- Remedial action taken as a result of violations of physical security
- Violations of Certificate Policy
- Violations of Certification Practice Statement / Key Recovery Practice Statement

5.5.2. Retention Period for Archive

Archive retention periods begin at the key generation event for any CA. For CAs that leverage key-rollover procedures a new retention period begins for each subsequent key generation event.

CAs will maintain all archived records related to that CA, in an accessible fashion, for 3 years after CA expiration or CA termination.

Individual records associated with certificate request authorization, certificate revocation, subscriber authentication, or subscriber certificate acceptance must be maintained for a minimum of 3 years after the subject certificate expiration date. Issuance of new certificates with extended validity periods (i.e., renewal, rekey or modification) supported by existing subscriber authentication records (i.e., authentication using an existing valid certificate) will result in a new retention period for those initial records, based on the new certificate expiration date.

Practice Note: Archive records can be retained for as long as business purposes require; however, this policy does not waive any organizational policies that may require the destruction of such records or otherwise limits their retention periods.

Practice Note: If the archive records are maintained separately from the CA, communication processes may be required to determine when archive records are no longer needed based on related public certificates.

National Archives and Records Administration General Records Schedules [NARA GRS], 5.6 Item 120, defines other required RA chain-of-trust records, and archive retention periods related to credentials issued in support of HSPD-12.

RA system operations audit records that include any IT resources that facilitate RA functions, must maintain relevant archives for a minimum of 3 years after RA system replacement or termination

5.5.3. Protection of Archive

Only Auditors, as described in Section 5.2, or other personnel specifically authorized by the CA are permitted to add or delete records from the archive. Deletion of records identified in Section 5.5.1 before the end of the retention period is not permitted under any circumstances. The contents of the archive must not be released except in accordance with Sections 9.3 and 9.4, or under circumstances described in the approved CPS.

Archive media must be stored in a safe, secure storage facility geographically separate from the CA using procedures approved by NARA or according to agency-specific policy. The transfer process between the backup environment and archive location must be documented.

In order to ensure that records in the archive may be referenced when required, the CA must do one of the following:

- Maintain the hardware or software required to process or read the archive records, or

- Define a process to transfer records to a new format or medium when the old format or medium becomes obsolete and verify the integrity of the records after transfer

5.5.4. Archive Backup Procedures

No stipulation.

5.5.5. Requirements for Time-Stamping of Records

CA archive records must have accurate time-stamps when they are added to the archive.

The time precision must be such that the sequence of events can be determined.

The CPS or KRPS must describe how system clocks used for time-stamping are maintained in synchrony with an authoritative time standard.

5.5.6. Archive Collection System (Internal or External)

Archive data may be collected in any expedient manner, but must be documented in the associated CPS/KRPS.

5.5.7. Procedures to Obtain and Verify Archive Information

Copies of records of individual transactions may be released upon request of any Subscribers involved in the transaction or their legally recognized agents.

Procedures, detailing how to create, verify, package, transmit, and store the CA/KRS archive information, must be included in the CPS/KRPS.

5.6. *KEY CHANGEOVER*

Each CA's signing key must have a validity period as described in Section 6.3.2.

Prior to the end of a CA's signing key validity period, a new CA must be established or a re-key on the existing CA must be performed. This is referred to as key changeover. From that time on, only the new key must be used to sign CA and Subscriber certificates. The old private key may continue to be used to sign CRLs and OCSP responder certificates. If the old private key is used to sign OCSP responder certificates or CRLs that cover certificates signed with that key, the old key must be retained and protected.

After all certificates signed with the old key have expired or been revoked, the CA may issue a final long-term CRL using the old key, with a nextUpdate time past the validity period of all issued certificates. This final CRL must be available for all relying parties until the validity period of all issued certificates has passed. Once the last CRL has been issued, the old private signing key of the CA may be destroyed.

When a CA performs a key changeover and thus generates a new public key, the CA must notify all CAs, RAs, and Subscribers that rely on the CA's certificate that it has been changed.

When a CA performs a key changeover, the CA may generate key rollover certificates, where the new public key is signed by the old private key, and vice versa. This permits immediate acceptance of newly issued certificates and CRLs by current users.

5.7. COMPROMISE AND DISASTER RECOVERY

CAs under this policy must have an incident handling process, which documents any security incidents. Security incidents may include violation or threat of violation to the system, improper usage, malicious or anomalous activity and violations of the CPS or CP.

5.7.1. Incident and Compromise Handling Procedures

The FPKIPA must be notified within 24 hours if any CAs operating under this policy experience the following:

- suspected or detected compromise of the CA systems;
- physical or electronic penetration of CA systems;
- successful denial of service attacks on CA components;
- any incident preventing the CA from issuing a CRL prior to the nextUpdate time of the previous CRL;
- suspected or detected compromise of a CSS; or
- suspected or detected compromise of an RA.

The notification must include preliminary remediation analysis.

Once the incident has been resolved, the organization operating the CA must provide notification directly to the FPKIPA which includes detailed measures taken to remediate the incident. The notice must include the following:

1. Which CA components were affected by the incident
2. The CA's interpretation of the incident
3. Who is impacted by the incident
4. When the incident was discovered
5. A complete list of all certificates that may have been issued erroneously or are not compliant with the CP/CPS as a result of the incident
6. A statement that the incident has been fully remediated

5.7.2. Computing Resources, Software, and/or Data Are Corrupted

When computing resources, software, and/or data are corrupted, CAs must respond as follows:

- Before returning to operation, ensure that the system's integrity has been restored.
- If the CA signature keys are not destroyed, CA operation must be reestablished, giving priority to the ability to generate certificate status information within the CRL issuance schedule specified in Section 4.9.7.
- If the CA signature keys are destroyed, CA operation must be reestablished as quickly as possible, giving priority to the generation of a new CA key pair.

The customer Agency Points of Contact (POC) must be notified as soon as possible.

In the event of an incident as described above, the organization operating the CA must post a notice on its web page identifying the incident and provide notification to the FPKIPA. See Section 5.7.1 for contents of the notice.

5.7.3. Entity Private Key Compromise Procedures

5.7.3.1. CA Private Key Compromise Procedures

In the event of a CA private key compromise, the following operations must be performed:

- The CA must immediately inform the FPKIPA and any entities known to be distributing the CA certificate (e.g., in a root store).
- The CA must request revocation of any certificates issued to the compromised CA.
- The CA must generate new keys in accordance with Section 6.1.1.1.

If the CA distributed the public key in a Trusted Certificate, the CA must perform the following operations:

- Generate a new Trusted Certificate.
- Securely distribute the new Trusted Certificate as specified in Section 6.1.4.
- Initiate procedures to notify Subscribers of the compromise.

Subscriber certificates issued prior to compromise of the CA private key may be renewed automatically by the CA under the new key pair (see Section 4.6) or the CA may require Subscribers to repeat the initial certificate application process.

The organization operating the CA must post a notice on its web page describing the compromise. See Section 5.7.1 for contents of the notice.

5.7.3.2. KRS Private Key Compromise Procedures

In the event that the KED or DDS is compromised or is suspected to be compromised, the following operations must be performed:

- Notify the FPKIPA of the compromise
- Provide detail concerning the root cause, operational impact and initial remediation actions
- Determine the extent of the compromise
- Gain concurrence from the FPKIPA on planned resolution. This may include revocation of certificates associated with the compromised private keys stored in the KED or DDS.

If a KRA or KRO certificate is revoked due to compromise, the potential exists for some Subscribers' escrowed keys to have been exposed during a recovery process, the following operations must be performed:

- Audit record review by the audit administrator to identify all potentially exposed escrowed keys.
- Revocation of each of the potentially exposed escrowed keys, according to procedures specified in Section 4.9.3, to include Subscriber notification of the revocation
- Reissuance of the KRA or KRO authentication certificate

5.7.4. Business Continuity Capabilities after a Disaster

For the Federal Common Policy CA, recovery procedures must be in place to reconstitute the CA within six (6) hours of failure.

All other CAs operating under this policy must have recovery procedures in place to reconstitute the CA within 72 hours of failure.

In the case of a disaster whereby the CA installation is physically damaged and all copies of the CA signature key are destroyed as a result, the FPKIPA must be notified at the earliest feasible time, and the FPKIPA must take whatever action it deems appropriate.

Practice Note: KED and DDS may take more than 72 hours to restore depending on the business needs of the operator. In this event, the FPKIPA must be notified of the expected recovery timeline.

5.8. CA OR RA TERMINATION

Whenever possible, the FPKIPA must be notified at least two weeks prior to the termination of a CA operating under this policy. For emergency termination, CAs must follow the notification procedures in Section 5.7.

When a CA operating under this policy terminates operations before all certificates have expired, the CA signing keys must be surrendered to the FPKIPA. This Section does not apply to CAs that have ceased issuing new certificates but are continuing to issue CRLs until all certificates have expired. Such CAs are required to continue to conform with all relevant aspects of this policy (e.g., audit logging and archives).

Any issued certificates that have not expired, must be revoked and a final long term CRL with a nextUpdate time past the validity period of all issued certificates must be generated. This final CRL must be available for all relying parties until the validity period of all issued certificates has passed. Once the last CRL has been issued, the private signing key(s) of the CA to be terminated will be destroyed or taken offline, designated as “not in use”, and protected as stipulated in Section 5.1.2.1.

Prior to CA/KRS termination, the CA/KRS must provide archived data to an archive facility as specified in the CPS/KRPS. As soon as possible, the CA will advise all other organizations to which it has issued certificates of its termination, using an agreed-upon method of communication specified in the CPS.

When an organizational RA function operating under this policy terminates operations, the RA must archive all audit logs and other records prior to termination and destroy its private keys upon termination.

6. TECHNICAL SECURITY CONTROLS

6.1. KEY PAIR GENERATION AND INSTALLATION

6.1.1. Key Pair Generation

Key generation must be performed using a FIPS approved method or equivalent international standard. Key generation events should use the configuration that was the basis of the FIPS or other approved standard (e.g., FIPS mode). If the required keys cannot be generated while in an approved configuration, the specific configuration and reason for use of a different method should be documented by the CA.

6.1.1.1. CA Key Pair Generation

Cryptographic keying material used by CAs to sign certificates, CRLs or status information must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1. Multiparty control is required for CA key pair generation, as specified in Section 6.2.2.

CA key pair generation must create a verifiable audit trail that the security requirements for procedures were followed. The documentation of the procedure must be detailed enough to show that appropriate role separation was used. An independent third party must validate the execution of the key generation procedures either by witnessing the key generation or by examining the signed and documented record of the key generation.

Practice Note: If the audit trail identifies and documents any failures or anomalies in the key generation process, along with the corrective action taken, the key generation process need not be restarted but may continue.

6.1.1.2. Subscriber Key Pair Generation

Subscriber key pair generation may be performed by the Subscriber, CA, or RA. If the CA or RA generates Subscriber key pairs, the requirements for key pair delivery specified in Section 6.1.2 must also be met.

Subscriber key pairs must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1.

For PIV, all keys, with the exception of key management, must be generated on the card.

6.1.1.3. CSS Key Pair Generation

Cryptographic keying material used by CSSs to sign status information must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1.

6.1.1.4. PIV Content Signing Key Pair Generation

Cryptographic keying material used by PIV issuing systems or devices for Common PIV Content Signing must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1.

6.1.2. Private Key Delivery to Subscriber

If Subscribers generate their own key pairs, then there is no need to deliver private keys, and this section does not apply.

When CAs or RAs generate keys on behalf of the Subscriber, then the private key must be delivered securely to the Subscriber. Private keys may be delivered electronically or may be delivered on a hardware cryptographic module. In all cases, the following requirements must be met:

- Anyone who generates a private signing key for a Subscriber must not retain any copy of the key after delivery of the private key to the Subscriber.
- The private key(s) must be protected from activation, compromise, or modification during the delivery process.
- The Subscriber must acknowledge receipt of the private key(s).
- Delivery must be accomplished in a way that ensures that the correct tokens and activation data are provided to the correct Subscribers.
 - For hardware modules, accountability for the location and state of the module must be maintained until the Subscriber accepts possession of it.
 - For electronic delivery of private keys, the key material must be encrypted using a cryptographic algorithm and key size at least as strong as the private key. Activation data must be delivered using a separate secure channel.

The CA must maintain a record of the Subscriber acknowledgment of receipt of the token.

6.1.3. Public Key Delivery to Certificate Issuer

Where key pairs are generated by the Subscriber or RA, the public key and the Subscriber's identity must be delivered securely to the CA for certificate issuance. The delivery mechanism must bind the Subscriber's verified identity to the public key. If cryptography is used to achieve this binding, it must be at least as strong as the Subscriber key pair.

6.1.4. CA Public Key Delivery to Relying Parties

The self-signed root CA certificates must be conveyed to relying parties in a secure fashion to preclude substitution attacks. Acceptable methods include:

- Secure distribution of the certificate through secure out-of-band mechanisms;
- Download the certificate from a Federal Government operated web site secured with a currently valid certificate and subsequent comparison of the hash of the certificate against a hash value made available via authenticated out-of-band sources (note that hashes posted in-band along with the certificate are not acceptable as an authentication mechanism)

Practice Note: Other methods that preclude substitution attacks may be considered acceptable.

6.1.5. Key Sizes

All keys must meet requirements listed in [SP 800-57].

This CP requires use of RSA PKCS #1, RSASSA-PSS, or ECDSA signatures; additional restrictions on key sizes and hash algorithms are detailed below. Certificates issued under this policy must contain 2048, 3072, or 4096-bit RSA keys, or 256 or 384-bit elliptic curve keys. CAs that generate certificates and CRLs under this policy must use the SHA-256, SHA-384, or SHA-512 hash algorithm when generating digital signatures.

	CA certificates that expire on or before December 31, 2030	CA certificates that expire after December 31, 2030
Minimum Key Size	RSA: 2048 Elliptic Curve: 256	RSA: 3072 Elliptic Curve: 256
Hash Algorithm	SHA-256, SHA-384, or SHA-512	SHA-256, SHA-384, or SHA-512

KED and DDS keys must be at equal to or stronger than the keys being escrowed.

	Subscriber certificates that expire on or before December 31, 2030	Subscriber certificates that expire after December 31, 2030
Minimum Key Size	RSA: 2048 Elliptic Curve: 256	RSA: 3072 Elliptic Curve: 256
Hash Algorithm	SHA-256, SHA-384, or SHA-512	SHA-256, SHA-384, or SHA-512

Practice Note: Future versions of this policy may specify additional FIPS-approved signature algorithms.

Practice Note: Reference NIST Special Publication 800-78 for algorithms and key sizes for certificates stored on PIV or Derived PIV credentials.

Use of TLS or another protocol providing similar security to accomplish any of the requirements of this CP must require (1) AES for the symmetric key and (2) at least 2048-bit RSA or 256-bit elliptic curve keys, and at least 3072-bit RSA or at least 256-bit elliptic curve keys after December 31, 2030.

6.1.6. Public Key Parameters Generation and Quality Checking

For RSA, the CA shall perform partial public key validation as specified in NIST SP 800-89 (Section 5.3.3).

For ECC, public keys must fall within curves defined in Section 7.1.3. Additionally, the CA should confirm the validity of all keys using either the ECC Full Public Key Validation Routine or the ECC Partial Public Key Validation Routine as specified in NIST SP 800-56A (Sections 5.6.2.3.3, or 5.6.2.3.4).

6.1.7. Key Usage Purposes (as per X.509 v3 Key Usage Field)

The use of a specific key is constrained by the Key Usage extension in the X.509 certificate.

All certificates must include a critical Key Usage extension.

The dataEncipherment, encipherOnly, and decipherOnly bits must not be asserted in certificates issued under this policy.

- Certificates to be used for authentication must set only the digitalSignature bit.
- Certificates to be used by Human Subscribers only for digital signatures must set the digitalSignature and nonRepudiation bits.
- Certificates that have the nonRepudiation bit set, must not have keyEncipherment bit or keyAgreement bit set.
- Certificates to be used for encryption (RSA) must set the keyEncipherment bit.
- Certificates to be used for key agreement (ECC) must set the keyAgreement bit.
- CA certificates must set only cRLSign and keyCertSign bits.

Keys associated with CA certificates must be used only for signing certificates and CRLs.

Keys associated with Human Subscriber certificates must be used only for digital signature (including authentication) or encryption, but not both.

Certificates that assert id-fpki-common-authentication, id-fpki-common-pivi-authentication, id-fpki-common-derived-pivAuth-hardware, id-fpki-common-derived-pivAuth, id-fpki-common-cardAuth, or id-fpki-common-pivi-cardAuth are used solely for authentication.

Keys associated with Device Subscriber certificates may be used for digital signature (including authentication), encryption, or both. Device certificates must not assert the nonRepudiation bit.

For all Subscriber certificates issued after June 30, 2019, the Extended Key Usage extension must always be present.

For all Subscriber certificates, Extended Key Usage OIDs must be consistent with key usage bits asserted. The Extended Key Usage extension must not contain anyExtendedKeyUsage {2.5.29.37.0} or id-kpcodeSigning {1.3.6.1.5.5.7.3.3}.

Certificates that assert id-fpki-common-piv-contentSigning must include a critical Extended Key Usage extension that asserts only id-PIV-content-signing {2.16.840.1.101.3.6.7} (see [CCP-PROF]).

Certificates that assert id-fpki-common-pivi-contentSigning must include a critical Extended Key Usage extension that asserts only id-fpki-pivi-content-signing {2.16.840.1.101.3.8.7} (see [CCP-Prof]).

6.2. PRIVATE KEY PROTECTION AND CRYPTOGRAPHIC MODULE ENGINEERING CONTROLS

6.2.1. Cryptographic Module Standards and Controls

The relevant standard for cryptographic modules is Security Requirements for Cryptographic Modules [FIPS 140]. A FIPS 140 Level 1 or higher validated cryptographic module must be used for all cryptographic operations. Cryptographic modules must be minimally validated to a FIPS 140 level identified in this section, with the exception of Hardware Subscriber Key Management Key(s) only for recovery and when dictated by extenuating circumstances put for by a Third-Party Requestor in alignment with legal or technical requirements.

Private Key	FIPS 140 Level
CA, KED, and DDS all applicable policies	3
CSS all applicable policies	2
PIV and Common PIV-I Content Signing - id-fpki-common-piv-contentSigning - id-fpki-common-pivi-contentSigning	2
Hardware Signature and Authentication - id-fpki-common-authentication - id-fpki-common-derived-pivAuth-hardware - id-fpki-common-cardAuth - id-fpki-common-hardware - id-fpki-common-high - id-fpki-common-pivi-authentication - id-fpki-common-pivi-cardAuth	2
Hardware Subscriber Key Management id-fpki-common-hardware	2 or 1*
Hardware Device id-fpki-common-devicesHardware	2

Software Signature and Authentication ● id-fpki-common-policy ● id-fpki-common-derived-pivAuth	1
Software Subscriber Key Management ● id-fpki-common-policy	1
Software Device ● id-fpki-common-devices	1
Practice Note – All instances of recovered key management keys should be destroyed as early as practicable in consultation with the Third-Party Recovery Requestor (e.g., after required data has been decrypted). See Sections 4.12 and 6.2.6 for additional key recovery requirements to include secure transport.	

*When necessary for completing an authenticated and authorized Third-Party key recovery request (e.g., in support of an investigation) Hardware Subscriber key management keys can only be recovered into a Level 1 module or an encrypted file (.p12 or .pfx) provided there is organizational approval based on the acceptance of risk to data encrypted with the associated public keys.

RAs must use a FIPS 140 Level 2 or higher validated hardware cryptographic module when authenticating to systems to fulfill their duties.

PIV or Common PIV-I cards must only be issued using card stock that has been tested and approved by the FIPS 201 Evaluation Program and listed on the GSA [Approved Products List](#) (APL). Card stock that has been removed from the APL may continue to be issued for no more than one year after GSA approved replacement card stock is available. PIV or Common PIV-I cards issued using the deprecated card stock may continue to be used until the current Subscriber certificates expire, unless otherwise notified by the FPKIPA/FPKIMA.

Any pseudo-random numbers used for key generation material must be generated using a FIPS-validated cryptographic module.

6.2.2. Private Key (n out of m) Multi-Person Control

A single person must not be permitted to activate or access any cryptographic module that contains the complete CA private signing key. CA signature keys may be backed up only under two-person control. Access to CA signing keys backed up for disaster recovery must be under at least two-person control. The names of the parties used for two-person control must be maintained on a list that must be made available for inspection during compliance audits.

6.2.3. Private Key Escrow

CA private keys are never escrowed.

Human Subscriber key management keys must be escrowed to provide key recovery as described in Section 4.12.1. If a device has a separate key management key certificate, the key management private key may be escrowed.

6.2.4. Private Key Backup

All backups of the CA, CSS and PIV Content Signing private signature keys must be accounted for and protected under the same multi-person control as the original signature key. At least one copy of the CA private signature key must be stored off-site. For all other keys, backup, when permitted, must provide security controls consistent with the protection provided by the original cryptographic module. Backed up private signature key(s) must not be exported or stored in plaintext form outside the cryptographic module.

Private Key	Backup
CA all applicable policies	Required
CSS all applicable policies	Optional
PIV and Common PIV-I Content Signing - id-fpki-common-piv-contentSigning - id-fpki-common-pivi-contentSigning	Optional
Hardware Signature and Authentication - id-fpki-common-authentication - id-fpki-common-derived-pivAuth-hardware - id-fpki-common-cardAuth - id-fpki-common-hardware - id-fpki-common-high - id-fpki-common-pivi-authentication - id-fpki-common-pivi-cardAuth	Not Permitted
Hardware Subscriber Key Management id-fpki-common-hardware	Required
Hardware Device id-fpki-common-devicesHardware	Optional
Software Signature and Authentication - id-fpki-common-policy - id-fpki-common-derived-pivAuth	Optional *
Software Subscriber Key Management id-fpki-common-policy	Required
Software Device	Optional

• id-fpki-common-devices	
--	--

* Software Subscriber private signature keys may be backed up or copied, but must be held in the Subscriber's control.

6.2.5. Private Key Archival

CA private signature keys and Subscriber private signature keys must not be archived.

CAs that retain Subscriber private encryption keys for business continuity purposes may require an archive of escrowed Subscriber private keys, so that they can be recovered for as long as the business continuity purposes require. Archives of escrowed private keys must be protected in accordance with Sections 4.12, 5.1, 5.2, and 6.2.

6.2.6. Private Key Transfer into or from a Cryptographic Module

At no time shall the CA private key exist in plaintext outside the cryptographic module boundary.

CA, CSS and PIV Content Signing private signature keys may be exported from the cryptographic module only to perform key backup procedures as described in Section 6.2.4.

In the event that any private key is transported from one cryptographic module to another, to include key recovery operations, the private key must be protected using a FIPS approved algorithm and at a bit strength commensurate with the key being transported. Private keys must never exist in plaintext form outside the cryptographic module boundary.

Private or symmetric keys used to encrypt other private keys for transport must be protected from disclosure.

6.2.7. Private Key Storage on Cryptographic Module

No stipulation beyond that specified in [FIPS 140].

6.2.8. Method of Activating Private Key

Cryptographic modules must be protected from unauthorized access.

Subscriber private key activation requirements are detailed in the following table:

Policy Asserted	Activation Requirements
id-fpki-common-authentication id-fpki-common-derived-pivAuth-hardware id-fpki-common-derived-pivAuth id-fpki-common-policy id-fpki-common-hardware id-fpki-common-high id-fpki-common-pivi-authentication	Passphrases, PINs or biometrics. When passphrases or PINs are used, they must be a minimum of six (6) characters.

	Entry of activation data must be protected from disclosure (i.e., the data should not be displayed while it is entered).
id-fpki-common-devices and id-fpki-common-devicesHardware	May be configured to activate the private key without requiring a human sponsor or authorized administrator to authenticate to the cryptographic token. The appropriate physical and logical access controls must be implemented for the device and its cryptographic token.
id-fpki-common-piv-contentSigning id-fpki-common-pivi-contentSigning	May be configured to activate the private key without requiring a human sponsor or authorized administrator to authenticate to the cryptographic token. The appropriate physical and logical access controls must be implemented for content signing operations conformant with PIV issuance requirements (see [FIPS 201]). The strength of the security controls must be commensurate with the level of threat in the PIV credential issuance system's environment, and must protect the hardware, software, and the cryptographic token and its activation data from compromise.
id-fpki-common-cardAuth id-fpki-common-pivi-cardAuth	None.

6.2.9. Method of Deactivating Private Key

After use, the cryptographic module must be deactivated via a manual logout procedure or automatically after a period of inactivity as defined in the applicable CPS. CA cryptographic modules must be physically secured per requirements in Section 5.1 when not in use.

6.2.10. Method of Destroying Private Key

Individuals in Trusted Roles must destroy all copies of CA, RA, and CSS (e.g., OCSP server) private signature keys and activation data (e.g., operator card set or tokens) when they are no longer needed. Subscribers must either surrender their cryptographic module to CA/RA personnel for destruction or destroy their private signature keys, when they are no longer needed.

or when the certificates to which they correspond expire or are revoked. Physical destruction of hardware is not required.

Practice Note: Destruction will likely be performed by executing a “zeroize” command.

To ensure future access to encrypted data, Subscriber private key management keys should be secured in long-term backups or archived.

6.2.11. Cryptographic Module Rating

See Section 6.2.1.

6.3. OTHER ASPECTS OF KEY PAIR MANAGEMENT

6.3.1. Public Key Archival

Public key archival must be in accordance with Section 5.5.

6.3.2. Certificate Operational Periods and Key Usage Periods

For CAs such as the Federal Common Policy CA that issue certificates only to other CAs or CSSs, the maximum key usage period is 20 years.

All CAs operating under this policy that issue Subscriber certificates, the usage period for a CA key pair is a maximum of 10 years.²

A CA private key may be used to sign CRLs and OCSP responder certificates for the entire usage period. All certificates signed by a specific CA key pair must expire before the end of that key pair’s usage period.

Key	Private Key	Certificate
Subscriber Authentication	3 years	3 years
Subscriber Signature	3 years	3 years
Subscriber Encryption	Unrestricted	3 years
Card Authentication	3 years	3 years

² Content Signing and OCSP Signing certificates are excluded from this requirement.

Content Signing	3 Years	9 Years *
OCSP Responder	3 years	120 days
Device	3 years	3 years

* Expiration of the Content Signing certificate must be later than the expiration of the Subscriber certificates on the same PIV credential.

RA, DDS, KRA and KRO are considered Subscribers.

6.4. ACTIVATION DATA

6.4.1. Activation Data Generation and Installation

CA activation data may be user-selected (by each of the multiple parties holding that activation data). If the activation data must be transmitted, it must be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module.

RA and Subscriber activation data may be user-selected. The strength of the activation data must meet or exceed the requirements for authentication mechanisms stipulated for Level 2 in [FIPS 140]. If the activation data must be transmitted, it must be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module.

6.4.2. Activation Data Protection

Data used to unlock private keys must be protected from disclosure by a combination of cryptographic and physical access control mechanisms. Activation data must be:

- memorized;
- biometric in nature;
- contained within an organizationally approved device or software tool (e.g., password manager) that leverages encryption commensurate with the bit-strength of the key it activates, or
- physically recorded and secured at the level of assurance associated with the activation of the cryptographic module, and stored separately from the cryptographic module.

Practice Note: For [FIPS 140] Level 2 and higher modules, the protection mechanism should include an ability to temporarily lock the account or terminate the application, after a predetermined number of failed login attempts to protect against repeated guessing attacks.

6.4.3. Other Aspects of Activation Data

A CA operating under this policy must define any other aspects of Activation Data in its CPS.

6.5. COMPUTER SECURITY CONTROLS

6.5.1. Specific Computer Security Technical Requirements

For CAs, KEDs, and DDSs operating under this policy, the computer security functions listed below are required. These functions may be provided by the operating system, or through a combination of operating system, software, and physical safeguards. The CA and its ancillary parts must include the following functionality (these functions are applicable to all system software layers where applicable):

- authenticate the identity of users before permitting access to the system, data, or applications;
- manage privileges of users to limit users to their assigned roles;
- generate and archive audit records for all transactions; (see Section 5.4)
- enforce domain integrity boundaries for security critical processes;
- require use of cryptography for session communication and database security;
- require self-test security-related CA services;
- require a trusted path for identification of all users;
- provide residual information protection; and
- require recovery from key or system failure.

For certificate status servers operating under this policy, the computer security functions listed below are required (these functions are applicable to all system software layers where applicable):

- authenticate the identity of users before permitting access to the system or applications;
- manage privileges of users to limit users to their assigned roles;
- enforce domain integrity boundaries for security critical processes;
- provide residual information protection; and
- require recovery from key or system failure.

Methods used to administer the CAs, KEDs, or DDSs must not bypass applicable two-person controls. In addition, the computer security functions listed below are required:

- authenticate the identity of users before permitting access to the system or applications;
- manage privileges of users to limit users to their assigned roles;
- generate and archive audit records for all transactions; (see Section 5.4)
- enforce domain integrity boundaries for security critical processes;
- prohibit object reuse or require separation for random access memory;
- provide residual information protection; and

- require recovery from system failure.

All communications between any PKI Trusted Role and the CA must be authenticated and protected from modification.

6.5.2. Computer Security Rating

CAs operating under this policy must identify any Computer Security Rating requirements in the applicable CPS.

6.6. *LIFE CYCLE TECHNICAL CONTROLS*

6.6.1. System Development Controls

The system development controls for the CA (including any remote workstations used to administer the CA) and RA are as follows:

- Hardware and software used to administer or operate the CA must be procured in a fashion to reduce the likelihood that any particular component was tampered with (e.g., by ensuring the vendor cannot identify the PKI component that will be installed on a particular device).
- Custom hardware and software must be developed in a controlled environment, and the development process must be defined and documented. This requirement does not apply to commercial off-the-shelf hardware or software.
- The CA hardware and software, including all system software layers, must be dedicated to operating and supporting the CA (i.e., the systems and services dedicated to the issuance and management of certificates). There must be no other applications, hardware devices, network connections, or component software installed that are not parts of the CA operation, administration, monitoring and security compliance of the system. CA hardware and system software layers may support multiple CAs and their supporting systems, provided all systems have comparable security controls and are dedicated to the support of the CA in compliance with this CP.
- Proper care must be taken to prevent malicious software from being loaded onto the CA equipment. All applications required to perform the operation of the CA must be obtained from documented sources. With the exception of Offline CAs, CA and RA hardware and software must be scanned for malicious code on first use and periodically thereafter.
- Hardware and software updates must be purchased or developed in the same manner as original equipment, and must be installed by trusted and trained personnel in a defined manner.

6.6.2. Security Management Controls

The configuration of the CA system, in addition to any modifications and upgrades, must be documented and controlled. There must be a mechanism for detecting unauthorized modification to the software or configuration. The CA software, when first loaded, must be verified as being that supplied from the vendor, with no modifications, and be the version intended for use. The CA must periodically verify the integrity of the software.

6.6.3. Life Cycle Security Controls

CAs operating under this policy must identify any Life Cycle Security Control requirements in the applicable CPS.

6.7. NETWORK SECURITY CONTROLS

This section does not apply to offline CAs.

A network guard, firewall, or filtering router must protect network access to CA and KRS equipment. The network guard, firewall, or filtering router must limit services allowed to and from the CA and KRS equipment to those required to perform CA and KRS functions.

Protection of CA and KRS equipment must be provided against known network attacks. All unused network ports and services must be turned off. Any network software present on the CA and KRS equipment must be necessary to the functioning of the CA application.

Any boundary control devices used to protect the network on which PKI equipment is hosted must deny all but the necessary services to the PKI equipment.

Repositories, CSSs, KRA/KRO, and remote workstations used to administer the CAs must employ appropriate network security controls. Networking equipment must turn off unused network ports and services. Any network software present must be necessary to the function of the equipment.

Any remote workstation used to administer the CA must be configured for mutual authentication. The remote workstation to CA communications, to include CA boundary control devices, must incorporate data integrity and confidentiality services. The remote workstation to CA network communications must be encrypted and must not be vulnerable to replay or machine-in-the-middle attacks. If mutual authentication is shared secret based, the shared secret must be changed at least annually, must be randomly generated, and must have entropy commensurate with the cryptographic strength of certificates issued by the PKI being administered.

Once the connection is established between the remote workstation and the CA or boundary control devices, the CA must permit remote administration only after successful multi-factor authentication of the Trusted Role at a level of assurance commensurate with that of the CA.

6.8. TIME-STAMPING

Asserted times must be accurate to within three minutes. Electronic or manual procedures may be used to maintain system time. Clock adjustments are auditable events (see Section 5.4.1).

7. CERTIFICATE, CRL, AND OCSP PROFILES

7.1. CERTIFICATE PROFILE

Certificates issued by a CA under this policy must conform to the Common Policy X.509 Certificate and Certificate Revocation List (CRL) Profiles [CCP-PROF].

7.1.1. Version Number(s)

Certificates must be of type X.509 v3 (populate version field with integer “2”).

7.1.2. Certificate Extensions

Rules for the inclusion, assignment of value, and processing of extensions are defined in [CCP-PROF].

7.1.3. Algorithm Object Identifiers

Certificates must use the following OIDs for signatures:

Signature Algorithm	Object Identifier
sha256WithRSAEncryption	{iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 11} (1.2.840.113549.1.1.11)
sha384WithRSAEncryption	{iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 12} (1.2.840.113549.1.1.12)
sha512WithRSAEncryption	{iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 13} (1.2.840.113549.1.1.13)
id-RSASSA-PSS	{iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 10} (1.2.840.113549.1.1.10)
ecdsa-with-SHA256	{iso(1) member-body(2) us(840) ansi-X9-62(10045) signatures(4) ecdsa-with-SHA2(3) 2} (1.2.840.10045.4.3.2)
ecdsa-with-SHA384	{iso(1) member-body(2) us(840) ansi-X9-62(10045) signatures(4) ecdsa-with-SHA2(3) 3} (1.2.840.10045.4.3.3)
ecdsa-with-SHA512	{iso(1) member-body(2) us(840) ansi-x962(10045) signatures(4) ecdsa-with-SHA2(3) 4} (1.2.840.10045.4.3.4)

The PSS padding scheme OID is independent of the hash algorithm. The hash algorithm is specified as a parameter (for details, see [PKCS#1]). Certificates issued under this CP must use the SHA-256 hash algorithm when generating RSASSA-PSS signatures. The following OID must be used to specify the hash in an RSASSA-PSS digital signature:

SHA-256	{joint-iso-itu-t(2) country(16) us(840) organization(1) gov(101) csor(3) nistalgorithm(4) hashalgs(2) 1} (2.16.840.1.101.3.4.2.1)
---------	---

Certificates must use the following OIDs to identify the algorithm associated with the subject key:

Public Key Algorithm	Object Identifier
rsaEncryption	{iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 1} (1.2.840.113549.1.1.1)

id-ecPublicKey	{iso(1) member-body(2) us(840) ansi-X9-62(10045) id-publicKeyType(2) 1} (1.2.840.10045.2.1)
----------------	---

Where the certificate contains an elliptic curve public key, the parameters must be specified as one of the following named curves:

Curve	Object Identifier
ansip256r1	{iso(1) member-body(2) us(840) 10045 curves(3) prime(1) 7} (1.2.840.10045.3.1.7)
ansip384r1	{iso(1) identified-organization(3) certicom(132) curve(0) 34} (1.3.132.0.34)

7.1.4. Name Forms

The subject and issuer fields of certificates issued under this policy must be populated with an X.500 Distinguished Name as specified in Section 3.1.1.

7.1.5. Name Constraints

Name constraints may be asserted in CA certificates.

7.1.6. Certificate Policy Object Identifier

Certificates issued under this CP must assert at least one policy OID as specified in Section 1.2 in the certificate policies extension.

Certificates that express the id-fpki-common-cardAuth, id-fpki-common-pivi-cardAuth, id-fpki-common-piv-contentSigning, or id-fpki-common-pivi-contentSigning policy OID must not express any other policy OIDs.

Delegated OCSP Responder certificates must assert all policy OIDs for which they are authoritative.

7.1.7. Usage of Policy Constraints Extension

The CAs may assert policy constraints in CA certificates. When this extension appears, at least one of requireExplicitPolicy or inhibitPolicyMapping must be present. When present, this extension may be marked critical.

For certificates issued to the Federal Bridge CA, inhibitPolicyMapping skip certs must be set to 2.

For all other CA certificates issued by the Federal Common Policy CA, inhibitPolicyMapping skip certs must be set to 0. When requireExplicitPolicy is included, skip certs must be set to 0.

7.1.8. Policy Qualifiers Syntax and Semantics

Certificates issued under this CP may contain a policy qualifier containing a CPS URI.

7.1.9. Processing Semantics for the Critical Certificate Policies Extension

Certificates issued under this policy must contain a non-critical certificate policies extension.

7.1.10. Inhibit Any Policy Extension

The CAs may assert InhibitAnyPolicy in CA certificates. When present, this extension may be marked critical. Skip certs must be set to 0, since certificate policies are required in the Federal PKI.

7.2. CRL PROFILE

CRLs issued by a CA under this CP must conform to the CRL profile specified in [CCP-PROF].

7.2.1. Version Number(s)

The CAs must issue X.509 Version two (2) CRLs.

7.2.2. CRL and CRL Entry Extensions

Detailed CRL profiles addressing the use of each extension are specified in [CCP-PROF].

7.3. OCSP PROFILE

CSSs operated under this policy must sign responses using algorithms designated for CRL signing.

All CSSs must accept and return SHA-1 hashes in the CertID and responderID fields. CSS may accept and return additional hash algorithms within the CertID fields. CSSs must not return any response containing a hash algorithm in the CertID that differs from the CertID in the request.

7.3.1. Version Number(s)

CSSs operated under this policy must use OCSP version 1.

7.3.2. OCSP Extensions

Critical OCSP extensions must not be used.

8. COMPLIANCE AUDIT AND OTHER ASSESSMENTS

CAs operating under this policy are subject to an annual review by the FPKIPA to ensure their policies and operations remain compliant with this policy.

CAs operating under this policy must have a compliance audit mechanism in place to ensure that the requirements of their CPS are being implemented and enforced. The organization's PMA must be responsible for ensuring annual audits are conducted for all PKI functions regardless of how or by whom the PKI components are managed and operated.

Agencies must ensure they have appropriate authority to operate, in accordance with [FIPS 201] and [NIST SP 800-79] Guidelines for the Accreditation of PIV Card Issuers and Derived PIV Credential Issuers (DPCI). Agencies must also ensure annual PKI compliance audits are conducted for all PKI operations for which they are responsible.

For the Federal Common Policy CA, the FPKIMA must have a compliance audit mechanism in place to ensure that the requirements of this CP are being implemented and enforced by its CPS.

This CP does not impose a requirement for any particular assessment methodology.

8.1. *FREQUENCY OR CIRCUMSTANCES OF ASSESSMENT*

CAs and RAs operating under this policy must be subject to an annual compliance audit in accordance with the FPKI Annual Review Requirements document [AUDIT]. The FPKIPA has the right to require aperiodic compliance audits of CAs operating under this policy. The FPKIPA must state the reason for any aperiodic compliance audit.

On an annual basis, for each PCI configuration used (as defined by the FIPS 201 Evaluation Program), one populated, representative PIV credential must be submitted to the FIPS 201 Evaluation Program for testing.

8.2. *IDENTITY/QUALIFICATIONS OF ASSESSOR*

The auditor must demonstrate competence in the field of compliance audits, and must be thoroughly familiar with the CA's CPS and this CP. The compliance auditor must perform such compliance audits as a regular ongoing business activity. In addition to the previous requirements, the auditor must be a certified information system auditor (CISA) or IT security specialist, and a PKI subject matter specialist who can offer input regarding acceptable risks, mitigation strategies, and industry best practices.

8.3. *ASSESSOR'S RELATIONSHIP TO ASSESSED ENTITY*

The compliance auditor either must be a private firm that is independent from the entities (CA and RAs) being audited, or it must be sufficiently organizationally separated from those entities to provide an unbiased, independent evaluation. An example of the latter situation may be an agency inspector general. To ensure independence and objectivity, the compliance auditor may not have served the entity in developing or maintaining the entity's CA facility or Certification Practices Statement. The FPKIPA may determine whether a compliance auditor meets this requirement.

Each agency is responsible for identifying and engaging a qualified auditor of agency operations implementing aspects of this CP.

8.4. *TOPICS COVERED BY ASSESSMENT*

The purpose of a compliance audit must be to verify that a CA and its RAs comply with all the requirements of the current versions of this CP and the CA's CPS. All aspects of the CA/RA operation must be subject to compliance audit inspections. Components other than CAs may be audited fully or by using a representative sample.

If the compliance auditor uses statistical sampling, all PKI components, PKI component managers and operators must be considered in the sample. The samples must vary on an annual basis.

8.5. ACTIONS TAKEN AS A RESULT OF DEFICIENCY

When the compliance auditor or FIPS 201 Evaluation Program testing finds a discrepancy between the requirements of this CP or the stipulations in the CPS and the design, operation, or maintenance of the PKI Authorities, the following actions must be performed:

- The discrepancy must be documented;
- The responsible party must be notified; and
- The party responsible for correcting the discrepancy will propose a remedy, including expected time for completion, to the FPKIPA and appropriate agency.

Depending upon the nature and severity of the discrepancy, and how quickly it can be corrected, the FPKIPA may decide to temporarily halt operation of the CA or RA, to revoke a certificate issued to the CA or RA, or take other actions it deems appropriate. The FPKIPA will develop procedures for making and implementing such determinations. A compliance audit or FIPS 201 Evaluation Program test may be required to confirm the implementation and effectiveness of the remedy.

8.6. COMMUNICATION OF RESULTS

On an annual basis, CAs operating under this policy must submit an annual review package to the FPKIPA. This package must be prepared by the CA's PMA, in accordance with the FPKI Annual Review Requirements document. The package must include an assertion that all PKI components have been audited including any components that may be separately managed and operated. The report must identify the versions of this CP and the CPS used in the assessment. Additionally, where necessary, the results must be communicated as set forth in Section 8.5 above.

Each agency must provide an Auditor Letter of Compliance for those PKI components that it operates to its issuing CA or directly to the FPKIPA.

9. OTHER BUSINESS AND LEGAL MATTERS

9.1. FEES

9.1.1. Certificate Issuance or Renewal Fees

CAs operating under this policy must make this determination.

9.1.2. Certificate Access Fees

Section 2 of this policy requires that CA certificates be publicly available. CAs operating under this policy must not charge additional fees for access to this information.

9.1.3. Revocation or Status Information Access Fees

CAs operating under this policy must not charge additional fees for revoking certificates or access to CRLs and OCSP status information.

9.1.4. Fees for other Services

CAs operating under this policy must make this determination.

9.1.5. Refund Policy

CAs operating under this policy must make this determination.

9.2. *FINANCIAL RESPONSIBILITY*

This CP contains no limits on the use of certificates issued by CAs under this policy. Rather, entities, acting as relying parties, must determine what financial limits, if any, they wish to impose for certificates used to consummate a transaction.

9.2.1. Insurance Coverage

CAs operating under this policy must make this determination.

9.2.2. Other Assets

CAs operating under this policy must make this determination.

9.2.3. Insurance or Warranty Coverage for End-Entities

CAs operating under this policy must make this determination.

9.3. *CONFIDENTIALITY OF BUSINESS INFORMATION*

CA information not requiring protection must be made publicly available. Public access to organizational information must be determined by the respective organization.

9.3.1. Scope of Confidential Information

CAs operating under this policy must make this determination.

9.3.2. Information not within the Scope of Confidential Information

CAs operating under this policy must make this determination.

9.3.3. Responsibility to Protect Confidential Information

A CA must not disclose non-certificate information to any third party unless authorized by this policy, required by U.S. law, U.S. government rule or regulation, or order of a U.S. court of competent jurisdiction. The contents of the archives maintained by CAs operating under this policy must not be released except as required by this policy, required by U.S. law, U.S. government rule or regulation, or order of a U.S. court of competent jurisdiction.

9.4. *PRIVACY OF PERSONAL INFORMATION*

9.4.1. Privacy Plan

CAs must conduct a Privacy Threshold Assessment, and implement and maintain any required Privacy Impact Assessments and Privacy Plans in accordance with the requirements of the Privacy Act of 1974, as amended.

9.4.2. Information Treated as Private

Federal entities acquiring services under this policy must protect all Subscriber PII from unauthorized disclosure. Records of individual transactions may be released upon request of any Subscribers involved in the transaction or their legally recognized agents. The contents of the archives maintained by CAs operating under this policy must not be released except as required by law.

Collection of PII must be limited to the minimum necessary to validate the identity of the Subscriber. This may include attributes that correlate identity evidence to authoritative sources. The RA must provide explicit notice to the Subscriber regarding the purpose for collecting and maintaining a record of the PII necessary for identity proofing and the consequences for not providing the information. PII collected for identity proofing purposes must not be used for any other purpose.

9.4.3. Information not Deemed Private

Information included in certificates is not subject to protections outlined in Section 9.4.2, but may not be sold to a third party.

9.4.4. Responsibility to Protect Private Information

Sensitive information must be stored securely, and may be released only in accordance with other stipulations in Section 9.4.

All information collected as part of the identity proofing process must be protected to ensure confidentiality and integrity. In the event an agency terminates PKI activities, it must be responsible for disposing of or destroying sensitive information, including PII, in a secure manner, and maintaining its protection from unauthorized access until destruction.

9.4.5. Notice and Consent to Use Private Information

The FPKIMA or an agency POC is not required to provide any notice or obtain the consent of the Subscriber or authorized agency personnel in order to release private information in accordance with other stipulations of Section 9.4.

9.4.6. Disclosure Pursuant to Judicial or Administrative Process

The FPKIMA or an agency POC must not disclose private information to any third party unless authorized by this policy, required by law, government rule or regulation, or order of a court of competent jurisdiction. Any request for release of information must be processed according to [41 CFR 105-60.605].

9.4.7. Other Information Disclosure Circumstances

None.

9.5. *INTELLECTUAL PROPERTY RIGHTS*

CAs must not knowingly violate intellectual property rights held by others.

9.6. *REPRESENTATIONS AND WARRANTIES*

The obligations described below pertain to the FPKIMA and each issuing agency.

The FPKIPA must:

- Approve the CPS for each CA that issues certificates under this policy;
- Review periodic compliance audits to ensure that CAs are operating in compliance with their approved CPSs;
- Review namespace control procedures to ensure that distinguished names are uniquely assigned for all certificates issued under this CP;
- Revise this CP to maintain the level of assurance and operational practicality;
- Publicly distribute this CP; and
- Coordinate modifications to this CP to ensure continued compliance by CAs operating under approved CPSs.

Each issuing agency must:

- Review periodic compliance audits to ensure that RAs and other components operated by the agency are operating in compliance with their approved CPSs; and
- Review namespace control procedures to ensure that distinguished names are uniquely assigned within their agency.

9.6.1. CA and KED Representations and Warranties

CAs operating under this policy must warrant that their procedures are implemented in accordance with this CP, and that any certificates issued that assert the policy OIDs identified in this CP were issued in accordance with the stipulations of this policy.

A CA that issues certificates that assert a policy defined in this document must conform to the stipulations of this document, including:

- Providing to the FPKIPA a CPS, as well as any subsequent changes, for conformance assessment.
- Maintaining its operations in conformance to the stipulations of the approved CPS.
- Ensuring that registration information is accepted only from approved RAs operating under an approved CPS.
- Including only valid and appropriate information in certificates, and maintaining evidence that due diligence was exercised in validating the information contained in the certificates.

- Revoking the certificates of Subscribers found to have acted in a manner counter to their obligations in accordance with Section 9.6.3.
- Operating or providing for the services of an on-line repository, and informing the repository service provider of their obligations if applicable.

A KED that provides escrowed keys to Requestors under this policy must conform to the stipulations of this document. In particular, the following stipulations apply:

- The FPKIPA must approve the CPS/KRPS prior to key escrow.
- The KED must operate in accordance with the stipulations of the CPS/KRPS and this policy.
- The CA/KED must automatically notify the subscribers when their private keys have been escrowed during the subscriber registration process (e.g., a dialog box may appear on a subscriber's screen during the certificate request process).
- The KED must monitor KRA and KRO activity for patterns of potentially anomalous activity as indicators of possible problems in the infrastructure, and initiate inquiries or investigations as appropriate

9.6.2. RA and KRA/KRO Representations and Warranties

9.6.2.1. RA Obligations

An RA that performs registration functions as described in this policy must comply with the stipulations of this policy, and comply with a CPS approved by the FPKIPA for use with this policy. An RA who is found to have acted in a manner inconsistent with these obligations is subject to revocation of RA responsibilities. An RA supporting this policy must conform to the stipulations of this document, including:

- Maintaining its operations in conformance to the stipulations of the approved CPS.
- Including only valid and appropriate information in certificate requests, and maintaining evidence that due diligence was exercised in validating the information contained in the certificate.
- Ensuring that obligations are imposed on Subscribers in accordance with Section 9.6.3, and that Subscribers are informed of the consequences of not complying with those obligations.

9.6.2.2. KRA Obligations

KRAs that submit requests as described in this policy must comply with the stipulations of this policy and the applicable CPS/KRPS. In particular, the following stipulations apply:

- KRAs must keep a copy of this policy and the applicable CPS/KRPS.
- KRAs must protect subscribers' escrowed keys from unauthorized disclosure, including the encrypted files and associated decryption keys.
- KRAs must protect all information associated with key recovery, including the KRA's own key(s), that could be used to recover subscribers' escrowed keys.

- KRAs must release Subscribers' escrowed keys only for properly authenticated and authorized requests from Requestor.
- KRAs may rely upon the KROs for authentication and verification of the identity and authority of the Requestor. However, KRAs must also authenticate the identity of the Requestor when the Requestor digital signature is available.
- KRAs must authenticate the KROs as described in Section 3.5.4.
- KRAs must validate the authorization of the KRO by ensuring that the KRO is an authorized KRO for the Subscriber for whom key recovery has been requested.
- KRAs must protect all information regarding all occurrences of key recovery.
- KRAs must communicate knowledge of a recovery process only to the KRO and Requestor involved in the key recovery.
- KRAs must not communicate any information concerning a key recovery to the Subscriber except when the Subscriber is the Requestor.
- KRAs must monitor KRO activity for patterns of potentially anomalous behavior as indicators of possible problems in the infrastructure, and initiate inquiries or investigations as appropriate.

9.6.2.3. KRO Obligations

A KRO initiates a key recovery request for a Requestor. When using the services of a KRO, the Requestor is generally a third party, but this policy does not preclude the Subscriber from seeking the assistance of a KRO to recover the Subscriber's private key.

- The KRO must protect Subscribers' recovered keys from compromise.
- After providing the Requestor with the encrypted key, the KRO must destroy the copy of the key in his/her system.
- The KRO must request the Subscriber's keys only upon receipt of a request from an authorized Requestor.
- The KRO, as an intermediary for the KRA, must validate the identity of any Requestor seeking a key recovery.
- When the Requestor is authenticated on the basis of digital signature, the KRO must forward the Requestor's digitally signed object to the KRA in a form verifiable by the KRA.
- In the case of persons other than the Subscriber seeking a key recovery, the KRO must ensure that the Requestor has the authority to request the Subscriber's private decryption key.
- The KRO, as an intermediary for the KRA, must validate the authorization for the request, to include consultation with legal counsel when appropriate.
- The KRO must protect all information associated with key recovery, including the KRO's own private key(s), that could be used to obtain the Subscriber's recovered private decryption key(s).
- The KRO must protect all information regarding all occurrences of key recovery.

- The KRO must communicate knowledge of any recovery process only to the Requestor
- The KRO must not communicate any information concerning a key recovery to the Subscriber except when the Subscriber is the Requestor.
- The KRO must accurately represent himself when requesting key recovery services.
- The KRO must keep records of all recovery requests and disposition, including acknowledgement of receipt by the Requestor.

If an Issuing Organization chooses not to implement the KRO role, then these obligations become the responsibility of the KRA in addition to the obligations in Section 9.6.2.2 above.

9.6.3. Subscriber and Data Decryption Server Representations and Warranties

9.6.3.1. *Subscriber Representations and Warranties*

A Subscriber (or human sponsor for device certificates) must be required to sign a document containing the requirements the Subscriber must meet respecting protection of the private key and use of the certificate before being issued the certificate. Wherever possible, Subscriber documents must be digitally signed.

Subscribers must:

- Accurately represent themselves in all communications with the PKI authorities.
- Protect their private key(s) at all times, in accordance with this policy, as stipulated in their certificate acceptance agreements and local procedures.
- Promptly notify the appropriate CA upon suspicion of loss or compromise of their private key(s). Such notification must be made directly or indirectly through mechanisms consistent with the CA's CPS.
- Abide by all the terms, conditions, and restrictions levied on the use of their private key(s) and certificate(s).
- Subscribers must provide accurate identification and authentication information during key recovery requests.
- When the Subscriber is notified that his or her escrowed key has been recovered, the Subscriber must determine whether revocation of the public key certificate associated with the recovered key is necessary. The Subscriber must request the revocation, if necessary.

If the human sponsor for a device is not physically located near the sponsored device, and/or does not have sufficient administrative privileges on the sponsored device to protect the device's private key and ensure that the device's certificate is only used for authorized purposes, the device sponsor may delegate these responsibilities to an authorized administrator for the device.

9.6.3.2. *Data Decryption Server Representations and Warranties*

Prior to the beginning of the operation of a DDS, the Issuing Organization must formally acknowledge and agree to the obligations described here by signing an appropriate document.

- The DDS must protect Subscribers' recovered key(s) from compromise. The DDS must use a combination of computer security, cryptographic, network security, physical

security, personnel security, and procedural security controls to protect their keys and recovered subscribers' keys.

- The DDS must destroy Subscribers' keys when no longer required (i.e., when the data has been recovered).
- The DDS must request the Subscriber's escrowed key(s) only upon receiving a request to decrypt subscriber data from an authenticated authorized Enterprise system (e.g., an e-mail Server)
- The DDS must use the Subscriber's recovered keys only to recover Subscriber's data requested from an authenticated authorized Enterprise system

The DDS must provide accurate identification and authentication information at the same or higher assurance level as required for issuing new PKI certificates at the assurance level of the key being requested.

9.6.4. Relying Parties Representations and Warranties

This CP does not specify the steps a relying party should take to determine whether to rely upon a certificate. The relying party decides, pursuant to its own policies, what steps to take.

9.6.5. Representations and Warranties of Other Participants

Third-party key recovery Requestors must formally acknowledge and agree to the obligations described here, prior to receiving a recovered key:

- The Third-Party Requestor must protect Subscribers' recovered key(s) from compromise. The Third-Party Requestor must use a combination of computer security, cryptographic, network security, physical security, personnel security, and procedural security controls to protect their keys and recovered Subscribers' keys.
- The Third-Party Requestor must destroy or surrender Subscribers' keys when no longer required (i.e., when the data has been recovered).
- The Third-Party Requestor must request and use the Subscriber's escrowed key(s) only to recover Subscriber's data they are authorized to access.
- The Third-Party Requestor must accurately represent themselves to all entities during any key recovery service.
- When the request is made, the Third-Party Requestor must provide accurate identification and authentication information at least to the same level required for issuing new PKI certificates at the level of the key being requested (e.g., the Third-Party Requestor sends a digitally signed request using the credential issued by the Entity PKI at the same or higher assurance level as the key being recovered).
- The Third-Party Requestor must protect information concerning each key recovery operation.
- Upon receipt of the recovered key(s), the Third-Party Requestor must sign an acknowledgement of agreement to follow the law and the subscriber's organization policies relating to protection and release of the recovered key. Such agreement should include the following attestations:

- Third Party Requestor has accurately represented their identity to all key recovery entities,
- Third Party Requestor has truthfully described the reason(s) for the key recovery request,
- Third Party Requestor has a legitimate and official need to obtain the requested key(s),
- Third Party Requestor has received the recovered key(s),
- Third Party Requestor will use the recovered key(s) only for the stated purpose(s),
- Third Party Requestor will protect the recovered key(s) from unauthorized access. When no longer required, the Third Party Requestor shall either destroy the key(s) and inform the organization of destruction per agency requirements, or return any recovered key(s) stored on hardware to the organization,
- Third Party Requestor is bound by applicable laws and regulations concerning the protection of the recovered key(s) and any data recovered using the key(s).

9.7. *DISCLAIMERS OF WARRANTIES*

CAs operating under this policy may not disclaim any responsibilities described in this CP.

9.8. *LIMITATIONS OF LIABILITY*

The U.S. Government must not be liable to any party, except as determined pursuant to the [Federal Tort Claims Act (FTCA), 28 U.S.C. 2671-2680], or as determined through a valid express written contract between the Government and another party.

9.9. *INDEMNITIES*

No stipulation.

9.10. *TERM AND TERMINATION*

9.10.1. Term

This CP becomes effective when approved by the FPKIPA. This CP has no specified term.

9.10.2. Termination

Termination of this CP is at the discretion of the FPKIPA.

9.10.3. Effect of Termination and Survival

The requirements of this CP remain in effect through the end of the archive period for the last certificate issued.

9.11. INDIVIDUAL NOTICES AND COMMUNICATIONS WITH PARTICIPANTS

The FPKIPA must establish appropriate procedures for communications with CAs operating under this policy via contracts or memoranda of agreement as applicable.

For CAs operating under this policy, any planned changes to the infrastructure that have the potential to affect the FPKI operational environment must be communicated to the FPKIPA at least two weeks prior to implementation. All new artifacts (CA certificates, CRL DP, AIA and/or SIA URLs, etc.) produced as a result of the change must be provided to the FPKIPA within 24 hours following implementation.

For all other communications, no stipulation.

9.12. AMENDMENTS

9.12.1. Procedure for Amendment

The FPKIPA must review this CP at least once every year. Corrections, updates, or changes to this CP must be publicly available. Suggested changes to this CP must be communicated to the contact in Section 1.5.2; such communication must include a description of the change, a change justification, and contact information for the person requesting the change.

9.12.2. Notification Mechanism and Period

Proposed changes to this CP must be distributed electronically to FPKIPA members and observers in accordance with the Charter and By-laws.

9.12.3. Circumstances under which OID must be Changed

OIDS will be changed if the FPKIPA determines that a change in the CP reduces the level of assurance provided.

9.13. DISPUTE RESOLUTION PROVISIONS

The FPKIPA must facilitate the resolution between entities when conflicts arise as a result of the use of certificates issued under this policy. When the dispute is between federal agencies, and the FPKIPA is unable to facilitate resolution, dispute resolution may be escalated to the White House Office of Management and Budget or to the U.S. Department of Justice, Office of Legal Counsel as necessary.

9.14. GOVERNING LAW

The construction, validity, performance and effect of certificates issued under this CP for all purposes must be governed by United States federal law (statute, case law, or regulation).

9.15. COMPLIANCE WITH APPLICABLE LAW

All CAs operating under this policy are required to comply with applicable law.

9.16. MISCELLANEOUS PROVISIONS

9.16.1. Entire Agreement

CAs operating under this policy must make this determination.

9.16.2. Assignment

CAs operating under this policy must make this determination.

9.16.3. Severability

Should it be determined that one section of this CP is incorrect or invalid, the other sections of this CP must remain in effect until the CP is updated. The process for updating this CP is described in Section 9.12.

9.16.4. Enforcement (Attorneys' Fees and Waiver of Rights)

CAs operating under this policy must make this determination.

9.16.5. Force Majeure

CAs operating under this policy must make this determination.

9.17. OTHER PROVISIONS

CAs operating under this policy must make this determination.

APPENDIX A: PIV AND COMMON PIV INTEROPERABLE COMPARISON

	<u>Technical Requirements</u>	<u>PIV</u>	<u>PIV-I</u>
<u>Trust</u>	Suitability Assurance: Favorably adjudicated National Agency Check with Inquiries (minimum) or other Tier 1 investigation	x	
	PIV policy object identifier on PIV Authentication Certificates	x	
	PIV-I equivalent policy object identifier on PIV-I Authentication Certificates		x
	PIV Content Signing object signing certificate	x	
	PIV-I Content Signing equivalent object signing certificate		x
	PIV Card Authentication Certificate	x	
	PIV-I Card Authentication Certificate		x
	Card must not be valid for more than 6 years and card expiration must not exceed the expiration date of object signing certificate	x	x
<u>Credential Edge</u>	Card stock certified by FIPS 201 Evaluation Program	x	x
	Command edge and NIST SP 800-85 conformant	x	x
	NIST SP 800-73 conformant data model and PIV Application Identifier (AID)	x	x
	NIST SP 800-73 conformant to include GUID present in the CHUID	x	x
	RFC 4122 conformant UUID required in the GUID data element of the CHUID	x	x
	RFC 4122 conformant UUID present in the Authentication Certificates	x	x

<u>Topography</u>	FIPS 201 compliant topography	x	
	Minimally contains facial image, cardholder name, issuing organization, and expiration, but does not replicate FIPS 201 topography requirements		x
<u>Card Management System</u>	Card Management Master Key maintained in a FIPS 140-2 Level 2 Cryptographic Module and conforms to [NIST SP 800-78] requirements; activation of the Card Management Master Key requires commensurate authentication of Trusted Roles	x	x

APPENDIX B: REFERENCES

ABADSG	Digital Signature Guidelines, 1996-08-01. http://itlaw.wikia.com/wiki/American_Bar_Association_(ABA)_Digital_Signature_Guidelines
APL	Approved Products List (APL) https://www.idmanagement.gov/fips201/
AUDIT	FPKI Annual Review Requirements https://www.idmanagement.gov/docs/fpki-annual-review-requirements.pdf
CCP-PROF	Common Policy X.509 Certificate and Certificate Revocation List (CRL) Profiles https://www.idmanagement.gov/docs/fpki-x509-cert-profile-common.pdf
Executive Order 12968	Executive Order 12968 - Access to Classified Information https://www.govinfo.gov/content/pkg/FR-1995-08-07/pdf/95-19654.pdf
FIPS 140	Security Requirements for Cryptographic Modules, FIPS 140-3 https://csrc.nist.gov/publications/detail/fips/140/3/final
FIPS 201	Personal Identity Verification (PIV) of Federal Employees and Contractors, FIPS 201-3 https://csrc.nist.gov/publications/detail/fips/201/3/final
ITMRA	40 U.S.C. 1452, Information Technology Management Reform Act of 1996. https://govinfo.library.unt.edu/npr/library/misc/itref.html
NARA GRS	National Archives and Records Administration, General Records Schedules https://www.archives.gov/records-mgmt/grs.html
NS4009	NSTISSI 4009, National Information Systems Security Glossary, January 1999.
PACS	<i>Technical Implementation Guidance: Smart Card Enabled Physical Access Control Systems</i> , Version 2.3, The Government Smart Card Interagency Advisory Board's Physical Security Interagency Interoperability Working Group, December 20, 2005. https://www.idmanagement.gov/docs/pacs-tig-scepacs.pdf
PIV-I Issuers	Personal Identity Verification Interoperability for Issuers https://www.idmanagement.gov/university/pivi/
PKCS#1	Jakob Jonsson and Burt Kaliski, Public-Key Cryptography Standards (PKCS) #1: RSA Cryptography Specifications Version 2.1, RFC 3447,

	February 2003. http://www.ietf.org/rfc/rfc3447.txt
PKCS#12	PKCS #12: Personal Information Exchange Syntax v1.1 July 2014. https://tools.ietf.org/html/rfc7292
RFC 2585	Internet X.509 Public Key Infrastructure: Operational Protocols: FTP and HTTP, Russel Housley and Paul Hoffman, May 1999. https://www.ietf.org/rfc/rfc2585.txt
RFC 3647	Certificate Policy and Certification Practices Framework, Chokhani and Ford, Sabett, Merrill, and Wu, November 2003. http://www.ietf.org/rfc/rfc3647.txt
RFC 4122	A Universally Unique IDentifier (UUID) URN Namespace, Paul J. Leach, Michael Mealling, and Rich Salz, July 2005. http://www.ietf.org/rfc/rfc4122.txt
RFC 5280	Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. https://www.ietf.org/rfc/rfc5280.txt
RFC 5322	Internet Message Format http://www.ietf.org/rfc/rfc5322.txt
RFC 6960	X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP. https://tools.ietf.org/html/rfc6960
RFC 8551	Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 4.0 Message Specification, J. Schaad, B. Ramsdell, S. Turner, April 2019. https://tools.ietf.org/rfc/rfc8551.txt
SP 800-37	Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach, NIST Special Publication 800-37, Revision 2, December 2018. https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final
SP 800-56A	Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography, NIST Special Publication 800-56A https://csrc.nist.gov/publications/detail/sp/800-56a/rev-3/final
SP 800-57	Recommendation for Key Management: Part 1- General, NIST Special Publication 800-57 Part 1 Revision 5, May 2020 https://csrc.nist.gov/publications/detail/sp/800-57-part-1/rev-5/final
SP 800-63-3	Digital Identity Guidelines

	https://csrc.nist.gov/publications/detail/sp/800-63/3/final
SP 800-76-2	Biometric Specifications for Personal Identity Verification, NIST Special Publication 800-76-2, July 2013. https://csrc.nist.gov/publications/detail/sp/800-76/2/final
SP 800-78-4	Cryptographic Algorithms and Key Sizes for Personal Identity Verification, NIST Special Publication 800-78-4, May 2015. https://csrc.nist.gov/publications/detail/sp/800-78/4/final
SP 800-79-2	Guidelines for the Accreditation of Personal Identity Verification Card Issuers, NIST Special Publication 800-79 https://csrc.nist.gov/publications/detail/sp/800-79/2/final
SP 800-89	Recommendation for Obtaining Assurances for Digital Signature Applications, NIST Special Publication 800-89 https://csrc.nist.gov/publications/detail/sp/800-89/final
SP 800-157	Guidelines for Derived Personal Identity Verification (PIV) Credentials, NIST Special Publication 800-157. https://csrc.nist.gov/publications/detail/sp/800-157/final
X.509	ITU-T Recommendation X.509 (2005) ISO/IEC 9594-8:2005, Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks.

APPENDIX C: ACRONYMS AND ABBREVIATIONS

AIA	Authority Information Access
CA	Certification Authority
CHUID	Card Holder Unique Identifier
CMS	Card Management System
CP	Certificate Policy
CPS	Certification Practice Statement
CRL	Certificate Revocation List
CSOR	Computer Security Objects Registry
DDS	Data Decryption Server
DN	Distinguished Name
DPCI	Derived PIV Credential Issuer
ECDSA	Elliptic Curve Digital Signature Algorithm
EKU	Extended Key Usage
FPKIMA	Federal Public Key Infrastructure Management Authority
FPKI	Federal Public Key Infrastructure
FPKIPA	Federal PKI Policy Authority
FQDN	Fully Qualified Domain Name
HTTP	Hypertext Transfer Protocol
IDMS	Identity Management System
IETF	Internet Engineering Task Force
IP	Internet Protocol
KED	Key Escrow Database

KRA	Key Recovery Agent
KRO	Key Recovery Officer
KRPS	Key Recovery Practice Statement
KRS	Key Recovery System
LDAP	Lightweight Directory Access Protocol
ISO	International Organization for Standardization
ISSO	Information Systems Security Officer
NARA	U.S. National Archives and Records Administration
NIST	National Institute of Standards and Technology
NSA	National Security Agency
OCSP	Online Certificate Status Protocol
OID	Object Identifier
PCI	PIV Card Issuer
PII	Personal Identifying Information
PIN	Personal Identification Number
PIV	Personal Identity Verification
PIV-I	Personal Identity Verification Interoperable
PKCS	Public Key Cryptography Standards
PKI	Public Key Infrastructure
PKIX	Public Key Infrastructure X.509
PSS	Probabilistic Signature Scheme
RA	Registration Authority
RDN	Relative Distinguished Name
RFC	Request For Comments
RSA	Rivest-Shamir-Adleman (encryption algorithm)
RSASSA	RSA Signature Scheme with Appendix

SHA	Secure Hash Algorithm
S/MIME	Secure/Multipurpose Internet Mail Extensions
SP	Special Publication
SSP-REP	Shared Service Provider Repository Service Requirements
TLS	Transport Layer Security
URL	Uniform Resource Locator
U.S.C.	United States Code
UUID	Universal Unique Identifier
WWW	World Wide Web

APPENDIX D: GLOSSARY

Access	Ability to make use of any information system (IS) resource. [NS4009]
Access Control	Process of granting access to information system resources only to authorized users, programs, processes, or other systems. [NS4009]
Accreditation	Formal declaration by a Designated Approving Authority that an Information System is approved to operate in a particular security mode using a prescribed set of safeguards at an acceptable level of risk. [NS4009]
Activation Data	Private data, other than keys, that are required to access cryptographic modules (i.e., unlock private keys for signing or decryption events).
Applicant	The Subscriber is sometimes also called an "Applicant" after applying to a certification authority for a certificate, but before the certificate issuance procedure is completed. [ABADSG footnote 32]
Archive	A collection of documents created or gathered by the CA and selected for long-term preservation as evidence of their activities.
Audit	Independent review and examination of records and activities to assess the adequacy of system controls, to ensure compliance with established policies and operational procedures, and to recommend necessary changes in controls, policies, or procedures. [NS4009]
Audit Log	A chronological record of information system activities, including records of system accesses and operations performed in a given period.
Audit Record	An individual entry in an audit log related to an audited event.
Authenticate	To confirm the identity of an entity when that identity is presented.
Authentication	Security measure designed to establish the validity of a transmission, message, or originator, or a means of verifying an individual's authorization to receive specific categories of information. [NS4009]
Backup	Copy of files and programs made to facilitate recovery if necessary. [NS4009]

Binding	Process of associating two related elements of information. [NS4009]
Biometric	A physical or behavioral characteristic of a human being.
Certificate	A digital representation of information which at least (1) identifies the certification authority issuing it, (2) names or identifies its Subscriber, (3) contains the Subscriber's public key, (4) identifies its operational period, and (5) is digitally signed by the certification authority issuing it. [ABADSG]. As used in this CP, the term "certificate" refers to X.509 certificates that expressly reference the OID of this CP in the certificatePolicies extension.
Certification Authority (CA)	An authority trusted by one or more users to issue and manage X.509 public key certificates and CRLs.
CA Facility	The collection of equipment, personnel, procedures and structures that are used by a certification authority to perform certificate issuance and revocation.
Certification Authority Software	Key management and cryptographic software used to manage certificates issued to Subscribers.
Certificate Policy (CP)	A certificate policy is a specialized form of administrative policy tuned to electronic transactions performed during certificate management. A certificate policy addresses all aspects associated with the generation, production, distribution, accounting, compromise recovery and administration of digital certificates. Indirectly, a certificate policy can also govern the transactions conducted using a communications system protected by a certificate-based security system. By controlling critical certificate extensions, such policies and associated enforcement technology can support provision of the security services required by particular applications.
Certification Practice Statement (CPS)	A statement of the practices that a CA employs in issuing, suspending, revoking, and renewing certificates and providing access to them, in accordance with specific requirements (i.e., requirements specified in this CP, or requirements specified in a contract for services).
Certificate-Related Information	Information, such as a Subscriber's postal address, that is not included in a certificate. May be used by a CA managing certificates.
Certificate Revocation List (CRL)	A list maintained by a certification authority of the certificates that it has issued that are revoked prior to their stated expiration date.

Certificate Status Server (CSS)	A trusted entity that provides on-line verification to a relying party of a subject certificate's revocation status.
Client (application)	A system entity, usually a computer process acting on behalf of a human user that makes use of a service provided by a server.
Compromise	Disclosure of information to unauthorized persons, or a violation of the security policy of a system in which unauthorized intentional or unintentional disclosure, modification, destruction, or loss of an object may have occurred. [NS4009]
Computer Security Objects Registry (CSOR)	Computer Security Objects Registry operated by the National Institute of Standards and Technology.
Confidentiality	Assurance that information is not disclosed to unauthorized entities or processes. [NS4009]
Containerization	A form of operating system virtualization, through which applications are run in isolated user spaces called containers, all using the same shared operating system (OS).
Cross-Certificate	A certificate used to establish a trust relationship between two certification authorities.
Cryptographic Module	The set of hardware, software, firmware, or some combination thereof that implements cryptographic logic or processes, including cryptographic algorithms, and is contained within the cryptographic boundary of the module. [FIPS 140]
Data Decryption Server	An automated system that obtains subscriber private keys from the Key Escrow Database or another Data Decryption Server in order to support decryption of data entering and leaving the Enterprise. An example of such data is e-mail.
Data Integrity	Assurance that the data are unchanged from creation to reception.
Device	A non-person entity, i.e., a piece of hardware or a software application
Digital Signature	The result of a transformation of a message by means of a cryptographic system using keys such that a relying party can determine: (1) whether the transformation was created using the private key that corresponds to the public key in the signer's digital certificate; and (2) whether the message has been altered since the transformation was made.

Encryption Certificate	A certificate containing a public key that is used to encrypt electronic messages, files, documents, or data transmissions, or to establish or exchange a session key for these same purposes.
FPKI Management Authority (FPKIMA)	The Federal Public Key Infrastructure Management Authority is the organization responsible for operating the Federal Common Policy Certification Authority.
Federal Public Key Infrastructure Policy Authority (FPKIPA)	The FPKIPA is a Federal Government body responsible for setting, implementing, and administering policy decisions regarding the Federal PKI Architecture.
Firewall	Gateway that limits access between networks in accordance with local security policy. [NS4009]
Hypervisor	Computer software, firmware or hardware that creates and runs virtual machines. A hypervisor uses native execution to share and manage hardware, allowing for multiple environments which are isolated from one another, yet exist on the same physical machine. Also known as an isolation kernel or virtual machine monitor.
Information Systems Security Officer (ISSO)	Person responsible to the Designated Approving Authority for ensuring the security of an information system throughout its life-cycle, from design through disposal. [NS4009]
Integrity	Protection against unauthorized modification or destruction of information. [NS4009]. A state in which information has remained unaltered from the point it was produced by a source, during transmission, storage, and eventual receipt by the destination.
Intellectual Property	Useful artistic, technical, and/or industrial information, knowledge or ideas that convey ownership and control of tangible or virtual usage and/or representation.
Intermediate CA	A CA that is subordinate to another CA, and has a CA subordinate to itself.
Key Escrow	A deposit of the private key of a Subscriber and other pertinent information pursuant to an escrow agreement or similar contract binding upon the Subscriber, the terms of which require one or more agents to hold the Subscriber's private key for the benefit of the Subscriber, an employer, or other party, upon provisions set forth in the agreement. [adapted from ABADSG, "Commercial key escrow service"]

Key Escrow Database (KED)	The function, system, or subsystem that maintains the key escrow repository and responds to key escrow and key recovery requests from one or more Key Recovery Agents, as specified by this policy.
Key Exchange	The process of exchanging public keys in order to establish secure communications.
Key Generation Material	Random numbers, pseudo-random numbers, and cryptographic parameters used in generating cryptographic keys.
Key Pair	Two mathematically related keys having the properties that (1) one (public) key can be used to encrypt a message that can only be decrypted using the other (private) key, and (2) even knowing the public key, it is computationally infeasible to discover the private key.
Key Recovery	Production of a copy of an escrowed key and delivery of that key to an authorized requestor.
Key Recovery Agent (KRA)	An individual authorized to interface with the key escrow database in conjunction with one or more other key recovery agents, to cause the key escrow database to carry out key recovery requests, as specified by this policy.
Key Recovery Official (KRO)	An individual authorized to authenticate and submit key recovery requests to the Key Recovery Agent on behalf of requestor, as specified by this policy.
Key Recovery Practices Statement (KRPS)	A statement of the practices that a Key Recovery System employs in protecting and recovering key management private keys, in accordance with specific requirements (i.e., requirements specified in the CP or KRP).
Modification (of a certificate)	The act or process by which data items bound in an existing public key certificate are changed by issuing a new certificate.
Mutual Authentication	Occurs when parties at both ends of a communication activity authenticate each other (see authentication).
National Security System	Any telecommunications or information system operated by the United States Government, the function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions, but does not include a system that

	is to be used for routine administrative and business applications (including payroll, finance, logistics, and personnel management applications). [ITMRA]
Network Guard	An enclave boundary protection device that controls access between a local area network that an enterprise system has a requirement to protect, and an external network that is outside the control of the enterprise system, with a high degree of assurance.
Non-Repudiation	Assurance that the sender is provided with proof of delivery and that the recipient is provided with proof of the sender's identity so that neither can later deny having processed the data. [NS4009] Technical non-repudiation refers to the assurance a relying party has that if a public key is used to validate a digital signature, that signature had to have been made by the corresponding private signature key.
Object Identifier (OID)	A specialized formatted number that is registered with an internationally recognized standards organization, the unique alphanumeric/numeric identifier registered under the ISO registration standard to reference a specific object or object class. In the Federal PKI, OIDs are used to uniquely identify certificate policies and cryptographic algorithms.
Offline CA	An offline certification authority is a certification authority isolated from network access, and is often kept in a powered-down state.
Out-of-Band	Communication between parties utilizing a means or method that differs from the current method of communication (e.g., one party uses U.S. Postal Service mail to communicate with another party where current communication is occurring on-line).
Physically Isolated Network	A network that is not connected to entities or systems outside a physically controlled space.
PKI Sponsor	Fills the role of a Subscriber for non-human system components that are named as public key certificate subjects, and is responsible for meeting the obligations of Subscribers as defined throughout this CP.
Policy Management Authority (PMA)	The individual or group that is responsible for the creation and maintenance of Certificate Policies and Certification Practice Statements, and for ensuring that all Entity PKI components (e.g., CAs, CSSs, Card Management Systems, RAs) are audited and operated in compliance with the entity PKI CP. The PMA evaluates non-domain policies for acceptance within the domain, and generally

	oversees and manages the PKI certificate policies. For the Common Policy, the PMA is the FPKIPA.
Privacy	Restricting access to Subscriber or relying party information in accordance with federal law.
Private Key	(1) The key of a signature key pair used to create a digital signature. (2) The key of an encryption key pair that is used to decrypt confidential information. In both cases, this key must be kept secret.
Public Key	(1) The key of a signature key pair used to validate a digital signature. (2) The key of an encryption key pair that is used to encrypt confidential information. In both cases, this key is normally made publicly available in the form of a digital certificate.
Public Key Infrastructure (PKI)	A set of policies, processes, server platforms, software, and workstations used for the purpose of administering certificates and public/private key pairs, including the ability to issue, maintain, and revoke public key certificates.
Registration Authority (RA)	An entity that is responsible for identification and authentication of certificate subjects, but that does not sign or issue certificates (i.e., a Registration Authority is delegated certain tasks on behalf of an authorized CA).
Re-key (a certificate)	To change the value of a cryptographic key that is being used in a cryptographic system application; this normally entails issuing a new certificate that contains the new public key.
Relying Party	A person or entity who has received information that includes a certificate and a digital signature verifiable with reference to a public key listed in the certificate, and is in a position to rely on them.
Remote Workstation	A workstation used to administer the CA, CMS, CSS and/or associated HSMs from a secure location outside the security perimeter of the equipment being administered. The secure location housing the Remote Workstation should be protected as a logical extension of the enclave in which the administered CA equipment resides. A remote workstation is not connected to the CA, CMS, CSS and/or HSM via a dedicated network. Note: Reference Sections 5.1, 6.5, 6.6.1, and 6.7 for additional technical controls required of remote workstations. This term does not refer to consoles within the CA's security perimeter or to Registration Authority workstations.

Renew (a certificate)	The act or process of extending the validity of the data binding asserted by a public key certificate by issuing a new certificate.
Repository	A system containing data relating to certificates or revocation data as specified in this CP. May refer to a directory, web server, or server which only hosts pre-generated OCSP responses.
Revoke a Certificate	To prematurely end the operational period of a certificate effective at a specific date and time.
Risk	An expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.
Risk Tolerance	The level of risk an entity is willing to assume in order to achieve a potential desired result.
Root CA	In a hierarchical PKI, the CA whose public key serves as the most trusted datum (i.e., the beginning of trust paths) for a security domain.
Server	A system entity that provides a service in response to requests from clients.
Signature Certificate	A public key certificate that contains a public key intended for verifying digital signatures rather than encrypting data or performing any other cryptographic functions.
Structural Container	An organizational unit attribute included in a distinguished name solely to support local directory requirements, such as differentiation between Human Subscribers and devices.
Subordinate CA	In a hierarchical PKI, a CA whose certificate signature key is certified by another CA, and whose activities are constrained by that other CA. (See superior CA).
Subscriber	A Subscriber is an entity that (1) is the subject named or identified in a certificate issued to that entity, (2) holds a private key that corresponds to the public key listed in the certificate, and (3) does not itself issue certificates to another party. This includes, but is not limited to, an individual, an application or network device.
Superior CA	In a hierarchical PKI, a CA that has certified the certificate signature key of another CA, and that constrains the activities of that CA. (See subordinate CA).

Supervised Remote Identity Proofing	A real-time identity proofing event where the RA/Trusted Agent is not in the same physical location as the Applicant/Subscriber. The RA/Trusted Agent controls a device which is utilized by the Applicant/Subscriber in order to ensure the remote identity proofing process employs physical, technical and procedural measures to provide sufficient confidence that the remote session can be considered equivalent to a physical, in-person identity proofing process. Supervised Remote Identity Proofing must meet the criteria specified in NIST SP 800-63A Section 5.3.3; and must have the capacity to capture an approved biometric.
System Software Layer	A layer of software that manages lower layer hardware and software resources and provides services through well-defined interfaces to the higher layers of software. Examples of system software layers are virtual machines, hypervisors, operating systems, and any containerized architectures.
Threat	Any circumstance or event with the potential to cause harm to an information system in the form of destruction, disclosure, adverse modification of data, and/or denial of service. [NS4009]
Trust List	Collection of Trusted Certificates used by relying parties to authenticate other certificates.
Trusted Agent	Entity authorized to act as a representative of a CA in confirming Subscriber identification during the registration process. Trusted agents do not have automated interfaces with certification authorities.
Trusted Certificate	A certificate that is trusted by the relying party on the basis of secure and authenticated delivery. The public keys included in trusted certificates are used to start certification paths. Also known as a "trust anchor".
Trustworthy System	Computer hardware, software, and procedures that: (1) are reasonably secure from intrusion and misuse; (2) provide a reasonable level of availability, reliability, and correct operation; (3) are reasonably suited to performing their intended functions; and (4) adhere to generally accepted security procedures.
Two-Person Control	Continuous surveillance and control of positive control material at all times by a minimum of two authorized individuals, each capable of detecting incorrect and/or unauthorized procedures with respect to the task being performed and each familiar with established security and safety requirements. [NS4009]

Zeroize	A method of erasing electronically stored data by altering the contents of the data storage so as to prevent the recovery of the data. [FIPS 140]
---------	--

APPENDIX E: FULL REVISION HISTORY

Document Version	Document Date	Revision Details
1.0	May 7, 2007	Revised Common Policy (RFC 3647 format)
1.1	July 17, 2007	2007-01: Alignment of Cryptographic Algorithm Requirements with SP 800-78-1
1.2	September 12, 2007	2007-02: Requiring the inclusion of a subject DN in PIV Authentication Certificates
1.3	October 16, 2007	2007-03: Accommodating legacy PKIs for PIV Authentication
1.4	April 3, 2008	2008-01: § 8.3 Assessor's Relationship to Assessed Entity
1.5	November 20, 2008	2008-02: Include a provision for a role-based signature certificate
1.6	February 11, 2009	2009-01: nextUpdate in Certificate Revocation Lists (CRL) published by legacy Federal PKIs
1.7	April 15, 2009	2009-02: Allow the use of the PIV Authentication certificate as proof of identity and employment
1.8	January 21, 2010	2010-01: Align key length requirements w/ SP 800-57 2010-02: Remote Administration of Certification Authorities
1.9	March 15, 2010	2010-03: Allowing inclusion of UUIDs in Card Authentication Certificates
1.10	April 8, 2010	2010-04: § 8.1 & 8.4
1.11	August 16, 2010	2010-05: Clarify the archive definition and how its records are intended to be used

1.12	October 15, 2010	2010-06: Allow Federal Legacy PKIs to Directly Cross Certify with Common Policy CA
1.13	November 18, 2010	2010-07: Legacy use of SHA-1 during transition period Jan 1, 2011 to Dec 31, 2013
1.14	December 17, 2010	2010-08: Clarify requirement to support CA Key Rollover
1.15	January 24, 2011	2011-01: CAs to assert policy OIDs in OCSP responder certificates for which the OCSP responder is authoritative
1.16	September 23, 2011	2011-02: Clarify requirements for device Subscribers and certificates
1.17	December 13, 2011	2011-03: Remove Requirements for LDAP References in Certificates
1.18	April 26, 2012	2012-01: Clarify RA audit requirements: revise Section 1.3.1.5, add new last sentence to first paragraph of Section 8, revise first paragraph of Section 8.1, revise Sections 8.4, 8.5, and 8.6, revise "Policy Management Authority (PMA)" glossary definition.
1.19	June 22, 2012	2012-02: Add new Section 4.1.1.4, Code Signing Certificates, to address change proposal (approved by FPKIPA on 6/12/12) requiring organizations receiving a code signing certificate to have access to a Time Stamp Authority.
1.20	August 19, 2012	2012-03: Add new language to Sections 3.2.3.2 and 9.6.3 to address change proposal (approved by FPKIPA on 8/14/12) to allow a human device sponsor, who is not physically located near the sponsored device, and/or who does not have sufficient administrative privileges on the sponsored device to fulfill these responsibilities, to delegate them to an authorized administrator of the device.

		2012-04: Revise Section 4.9.7 to address change proposal (approved by FPKIPA on 8/12/12) to detail and clarify the Common Policy CA's CRL issuance policies to ensure Offline Root CA operations are permitted.
1.21	December 18, 2012	2012-05: Revise Sections 1.2, 1.4.1, 3.1.1, 6.2.8, 6.3.2, 7.1.4, 7.1.6, and add new Sections 6.1.1.4 and 6.2.4.6 to address change proposal (approved by FPKIPA on 12/6/12) to create a new Common PIV Content Signing Policy OID.
1.22	December 2, 2013	2013-01: Clarify places in the Common Policy CP which were flagged during the FPKIMA Annual Audit as either contradictory with the FBCA CP or contradictory to current best practices. Clarify division of responsibilities between Trusted Roles (Section 5.2.1); clarify meaning of "all Security Audit logs (Section 5.4.1), and allow audit logs to be removed from production site once reviewed (Section 5.4.3) 2013-02: Remove SHA-1 policies from Common Policy.
1.23	May 5, 2014	2013-03: Require PIV Cards to be on the GSA Approved Products List (APL) Prior to Issuance and require annual PIV card testing.
1.24	May 7, 2015	2015-01: Create two new Common Derived PIV Authentication Certificate Policy OIDs in the Common Policy, and change/add text in appropriate sections throughout the CP.
1.25	September 22, 2016	2016-01: Alignment with CAB Forum Baseline Requirements (BR) v1.3.4. This will facilitate FPKI conformance to CAB Forum BRs for publicly-trusted SSL/TLS certificates, which will help promote inclusion of the Federal Root in public trust

		stores and provide guidance for issuance of publicly-trusted device certificates. 2016-02: Allow a long term CRL when a CA retires a key after performing a key changeover to align with the FPKI CPS.
1.26	February 2, 2017	2016-03: Remove or update references to obsoleted RFCs. Changes to Sections 1.3.1.7, 3.1.2, 3.1.4, 4.9.7, and 10.
1.27	June 29, 2017	2017-01: Align CP with current FPKIMA practice for CA certificates. 2017-02: Require CAs to publish information pertaining to resolved incidents on their websites. 2017-03: Require CAs to notify the FPKIPA whenever a change is made to their infrastructure 2017-04: Clarifies the period of time PIV card stock can continue to be used once it has been removed from the GSA APL.
1.28	April 4, 2018	2018-01: Key Recovery for key management certificates issued under the COMMON Policy
1.29	May 10, 2018	2018-02: Add reference to Annual Review Requirements 2018-03: Mandate specific EKUs in certificates issued after June 30, 2019 2018-04: Certificate revocation requirements for Transitive Closure after August 15, 2018 2018-05: Requirements for virtual implementations
1.30	October 4, 2018	2018-06: Incorporate “supervised remote identity proofing” and other new guidance as defined in NIST SP 800-63-3 effective as of October 4, 2018

1.31	February 8, 2019	2018-07: Remove the common-public-trusted-serverAuth certificate policy and associated requirements effective as of February 8, 2019 2018-08: Permit retention of private signing key(s) following CA termination effective as of February 8, 2019
1.32	April 14, 2020	2020-01: Add support for federally issued Personal Identity Verification-Interoperable (PIV-I) credentials
2.0	September 1, 2020	2020-02: Consolidated update to Common Policy and associated profiles, effective as of September 1, 2021. See the change proposal cover sheet for more detail.
2.1	May 18, 2021	2021-01: Consolidated Key Recovery Policy requirements into Common Policy.
2.2	December 1, 2021	2020-02: Updates to Section 5.4 and Section 5.5 to clarify the purpose of audit and archive, align recorded events and clarify archive retention periods. Updated reference links included. Implementation date is November 1, 2022. 2020-03: Removes the prohibition on container technology and generalizes terminology. Effective as of December 1, 2021.
2.3	September 9, 2022	2022-01A: Update to Section 5.5.2 to provide specificity for archive record retention periods, assisting RAs, or other archiving elements, to understand what artifacts need to be archived, and for how long in certain scenarios. Implementation date is November 1, 2022.
2.4	April 17, 2023	2023-02: Incorporates changes to multiple sections based on the comments received by the CPWG to include certificate suspension requirements, 3 rd party key recovery request handling, public key parameters, key

		generation specifics, and remote workstation definition. Changes effective as of September 1, 2023.
2.5	July 6, 2023	2023-04: Clarifies the audit and archive requirements for assignment of Trusted Roles. Additionally, removes obsolete references. Change effective immediately.
2.6	November 3, 2023	2023-06: Clarify the requirements around certificate modifications, define requirements for certificate restoration, align audit and archive terminology for certificate status changes, and generalize two document references. Change effective immediately.
2.7	February 2, 2024	2024-02: Clarify the definition of a “remote workstation used to administer the CA” in order to accommodate current secure practices. 2024-03: Clarify policy language based on the 2023 FPKI annual compliance audit, specifically regarding interoperation with CAs issuing under different policies and the time to process revocation requests. Change effective immediately.
2.8	May 8, 2024	2024-05: Clarify the definition of a “remote workstation used to administer the CA” in order to more clearly delineate parity with CA security controls. Change effective immediately.
2.9	October 25, 2024	2024-06: Add requirements around role-based certificates that can be used to support delegated digital signatures that convey the authority of a given role to specific delegates.

		2024-07: Clarify the description of the trusted agent role to ensure that it is not confused with a standard trusted role. Additionally, clarify seemingly conflicting policy language regarding Key Recovery Officials (KROs) and Third Party Key Recovery Requestors to include their responsibilities. 2024-08: Clarify the key storage requirements for Third-Party recovery of PIV key management keys that were originally issued to subscribers asserting common-hardware policies. Additionally, clarify requirements for securely recording private key activation data. Change effective immediately.
--	--	--